CertGraph: Heterogeneous Graph Attention Networks for Active Directory Certificate Services Vulnerability Detection and Autonomous Defense

Course Code: ECE 452 Course Title: Project and Thesis

Submitted By—

Student ID: 2002126 Level: 4, Semester: II
Student ID: 2002138 Level: 4, Semester: II
Student ID: 2102151 Level: 4, Semester: II



Submitted To—

Department of Electronics and Communication Engineering

in partial fulfillment of the requirements for the degree of

Bachelor of Science in Electronics and Communication Engineering

Hajee Mohammad Danesh Science and Technology University (HSTU)

Dinajpur-5200, Bangladesh

October, 2026

Certificate

This is to certify that the thesis work entitled **"CertGraph: Heterogeneous Graph Attention Networks for Active Directory Certificate Services Vulnerability Detection and Autonomous Defense"** is carried by the following ID numbers: **2002126, 2002138, 2102151**. To the fullest extent of our knowledge, we assert that this undertaking is an authentic and original contribution to the field. We certify that this thesis has not been previously submitted for the award of any other degree or diploma at this or any other institution.

Signed by the Final Examining committee:

.....	.....
Chairman	**Supervisor**
.....	.....
External Member	**Co-Supervisor**
.....	
Internal Member	

Candidate's Declaration

We declare that the research presented in this thesis, entitled **"CertGraph: Heterogeneous Graph Attention Networks for Active Directory Certificate Services Vulnerability Detection and Autonomous Defense,"** represents our own work conducted under the guidance of our supervisors in the Department of Electronics and Communication Engineering at Hajee Mohammad Danesh Science and Technology University (HSTU), Dinajpur-5200, Bangladesh.

We confirm that:

1. This manuscript has not been submitted in whole or in part for any other degree or diploma at this or any other academic institution.
2. All external ideas, datasets, software utilities, and mathematical formulations have been cited in accordance with standard academic referencing conventions.
3. The experimental scripts, synthetic benchmark environments, and model implementations described in this work were developed in compliance with academic research standards and ethical computing practices.

Date: October, 2026

Place: HSTU, Dinajpur

Student ID: 2002126

Student ID: 2002138

Student ID: 2102151

Department of ECE, HSTU

Dedication

This thesis is dedicated to our beloved parents,

whose endless sacrifices, prayers, and unconditional love
have been the guiding light of our lives.

And to all our teachers and mentors,
who inspired our passion for computer science and scientific discovery.

Acknowledgements

We begin by thanking the Almighty for granting us the health, resolve, and clarity of thought to bring this undergraduate project and thesis to completion.

We wish to express our heartfelt gratitude to our thesis supervisor and co-supervisor in the Department of Electronics and Communication Engineering at Hajee Mohammad Danesh Science and Technology University (HSTU). Throughout the research process—from initial problem formulation and mathematical proofs to the debugging of graph neural networks and manuscript preparation—their constructive criticism, technical feedback, and steady encouragement were vital to our progress.

We also thank the Chairman and the faculty members of the Department of Electronics and Communication Engineering for their instruction, academic support, and the computing facilities provided to us over the course of our undergraduate studies.

This work builds heavily on the contributions of the broader security and machine learning research communities. In particular, we acknowledge Will Schroeder and Lee Christensen (SpecterOps) for their foundational analysis of ADCS vulnerabilities; Oliver Lyak, Andy Robbins, and the BloodHound team for their offensive graph tools; the creators of the Game of Active Directory (GOAD) testing environment; and the maintainers of PyTorch Geometric and NetworkX.

Finally, we are deeply grateful to our parents and families. Their patience, moral support, and sacrifices made our education possible. We also thank our classmates, lab partners, and friends whose discussions, technical debates, and camaraderie helped us navigate the challenges of completing this degree.

HSTU, Dinajpur
October, 2026

Student ID: 2002126
Student ID: 2002138
Student ID: 2102151
Department of ECE, HSTU

Abstract

Active Directory Certificate Services (ADCS) forms the cryptographic backbone of enterprise identity, issuing credentials for domain authentication and single sign-on. Misconfigured certificate templates, access control lists (ACLs), and issuance policies introduce systemic privilege escalation vectors (ESC1–ESC15+) that enable unprivileged accounts to compromise entire Active Directory domains. Signature-based scanners (e.g., Certipy, BloodHound) evaluate flags in isolation and incur high traversal overhead on large topologies. In this thesis, we present **CertGraph**, a heterogeneous Graph Attention Network (Hetero-GAT) that models enterprise identity as a typed multigraph $G = (V, E, \mathcal{T}_V, \mathcal{T}_E)$ to detect structural escalation paths across core vectors (ESC1, ESC2, ESC3, ESC4, ESC9, and ESC13).

Grounding our evaluation in the security machine learning framework of Arp et al. (USENIX Security 2022), we identify and resolve three systemic pitfalls in synthetic identity datasets: positional index leakage, baseline feature asymmetry, and rule saturation. We prove mathematically (Theorem 1) that residual skip-connections are indispensable for preventing representation collapse on identity graphs; omitting them makes template representations independent of input flags, reducing classification Macro-F1 from 0.9986 to 0.4768. On an audited 700-environment enterprise benchmark evaluated under 5-fold cross-validation with Nadeau-Bengio corrected variance, CertGraph achieves a Macro-F1 of 0.9986, substantially outperforming flat classifiers (0.8600) and signature heuristics (0.7791).

However, when evaluated against an adversarial Zero-Shot Hard Negative suite ($n = 63$) containing benign templates with dangerous flags, pure neural models collapse to 1.59% accuracy due to shortcut learning on isolated attributes, whereas symbolic graph traversal achieves 84.13%. To resolve this dichotomy, we formulate a Two-Tier Neuro-Symbolic architecture pairing rapid GNN candidate screening (filtering $> 89\%$ of benign templates) with a localized symbolic verification oracle to eliminate false positives by construction. Finally, we model identity privilege revocation as a Stackelberg security game, prove its NP-hardness via reduction from Directed Multiway Cut, and demonstrate a greedy capacity-disruption heuristic that severs up to 68.6% of compromise paths under bounded operational budgets ($p < 10^{-8}$).

Keywords: Active Directory Certificate Services (ADCS), Graph Attention Networks, Heterogeneous Graphs, Identity and Access Management, Neuro-Symbolic Security, Autonomous Cyber Defense.

Contents

List of Acronyms **xiv**

1 Introduction **1**

1.1 Enterprise Identity Fabric and Demise of Perimeter Security 1
1.2 The Economics and Anatomy of Identity-Based Lateral Movement 2
1.3 Active Directory Certificate Services: The Unseen Attack Surface 3
1.4 Capabilities and Limitations of Existing Auditing Tools 4
1.5 The Promise and Pitfalls of Machine Learning for Identity Security 5
1.6 Research Questions and Formal Objectives 7
1.7 Summary of Thesis Contributions 7
1.8 Thesis Organization and Roadmap 8

2 Literature Review and Domain Background **10**

2.1 Evolution of Identity-Based Lateral Movement in Enterprise Networks . . . 10
2.1.1 Historical Precedents: Memory-Based Credential Abuse 10
2.2 Graph-Theoretic Modeling of Active Directory Security 11
2.2.1 Prior Attack Graph Literature 11
2.2.2 Capabilities and Limitations of Deterministic Graph Traversal . . . 12
2.3 Graph Representation Learning in Security 12
2.3.1 The Message-Passing Neural Network (MPNN) Framework 12
2.3.2 Homogeneous vs. Heterogeneous GNNs 13
2.3.3 GNNs for Lateral Movement Detection and Adversarial Robustness 14
2.3.4 Game Theory and Machine Learning Pitfalls in Cybersecurity . . . 14
2.4 Active Directory Architecture and Cryptographic Primitives 15
2.4.1 Security Principals and Security Identifiers (SIDs) 15
2.4.2 Kerberos Authentication and Token Construction 16
2.4.3 PKINIT: Public Key Cryptography for Initial Authentication 16
2.4.4 Access Control Lists (ACLs) and Security Descriptors 17
2.5 Active Directory Certificate Services (ADCS) Mechanics 17
2.6 Exhaustive Taxonomy of ADCS Vulnerability Classes (ESC1–ESC15) . . . 19
2.6.1 Target Space Scoping: Inclusion and Exclusion Rationale 20
2.7 The Multi-Hop Attack Challenge: ESC13 Diagnostic Case Study 21
2.8 Formal Threat Model 23
2.8.1 Attacker Model 23
2.8.2 Defender Model 24

3 Formal Methodology and CertGraph Architecture 25
3.1 Mathematical Formalization of Enterprise Identity Multigraphs 25
3.2 Node Feature Vector Spaces and Semantic Encodings 26
3.2.1 Certificate Template Feature Representation 26
3.2.2 Security Principal Feature Representations 27
3.2.3 Relational Adjacency and Canonical Reverse Relations 28
3.3 The CertGraph Hetero-GAT Architecture 29
3.3.1 Relation-Specific Linear Feature Projections 29
3.3.2 Multi-Head Relational Graph Attention 30
3.3.3 Semantic-Level Aggregation and Residual Skip-Connections 30
3.3.4 Multi-Class Vulnerability Classification Head 31
3.3.5 Objective Function with Class Imbalance Regularization 32
3.4 Formal Algorithmic Specifications 32
3.4.1 End-to-End Layer Forward Pass 33
3.4.2 Vulnerability Inference and Calibrated Risk Scoring 33
3.5 Theoretical Analysis: Intrinsic Attribute Preservation and Gradient Bounds 34
3.6 Computational Complexity and Scalability Analysis 35

4 Forensic Audit: Unmasking Experimental Illusions in Security Machine Learning 37
4.1 The Methodological Crisis of Security Machine Learning 37
4.2 The Four Experimental Illusions 38
4.2.1 Illusion 1: Positional Index Leakage in Synthetic Topologies 38
4.2.2 Illusion 2: Baseline Information Asymmetry 39
4.2.3 Illusion 3: The 7-Node Decision Tree Counterexample 40
4.2.4 Illusion 4: Hard Negative Memorization under In-Distribution Splits 41
4.3 Complete Generator Sanitization and Protocol Redesign 42
4.4 Statistical Verification of Generator Sanitization 42
4.5 Methodological Guidelines for Security Graph Learning 43

5 Empirical Evaluation and Benchmarks 45
5.1 Experimental Configuration and Benchmarking Setup 45
5.1.1 Benchmark Dataset Characteristics 45
5.1.2 Hyperparameter Specifications 46
5.2 In-Distribution 5-Fold Cross-Validation 46
5.2.1 Per-Class Performance Dissection 47
5.2.2 Evaluation Under Realistic Class Imbalance and Enterprise Base Rates 50
5.3 Systematic Architectural Ablation Studies 51

5.4 The Zero-Shot Adversarial Hard Negative Benchmark 52
5.4.1 Theoretical Post-Mortem: Under-Specification and Shortcut Collapse 52
5.5 Attention Weight Explainability and Graph Attribution 54

6 Real-World Active Directory Case Studies: GOAD and Community Benchmarks 56
6.1 From Synthetic Topologies to Enterprise Deployments 56
6.2 The Game of Active Directory (GOAD) Multi-Forest Testbed 56
6.3 Data Ingestion, Extraction, and Schema Translation 57
6.3.1 Active Directory Telemetry Collection 57
6.3.2 Graph Schema Translation Pipeline 59
6.4 Concrete Penetration Testing Case Studies 59
6.4.1 Detailed Case Study Analysis 59
6.5 Temporal Validation Across Independent Collection Dates 61
6.6 External Community Benchmark Validation 63

7 Domain Generalization, Robustness, and Scalability 65
7.1 Enterprise Operational Demands on Security Graph Learning 65
7.2 Domain Generalization: Transfer Learning on ADSynth Tiered Networks . 65
7.2.1 The Enterprise Administrative Tiering Model and ADCS Augmentation 66
7.2.2 Bidirectional Domain Transfer Evaluation 66
7.3 Systematic Sensitivity and Robustness Analysis 68
7.3.1 Topological Edge Deletions (Collection Gaps) 68
7.3.2 Configuration Feature Noise Perturbation 69
7.3.3 Sample Efficiency and Learning Convergence 70
7.4 Computational Complexity and Scalability Benchmarking 70
7.4.1 Scalability Insights and Empirical Runtime Profiling 70
7.4.2 Large-Scale Multi-Forest Partitioning Strategies 72

8 The Neuro-Symbolic Paradigm: Bridging Statistical GNNs and Symbolic Oracles 73
8.1 The Core Dilemma: Shortcut Learning in Security GNNs 73
8.1.1 Theoretical Root Cause: The Path-Feature Trade-off 73
8.2 The Fundamental Dichotomy: Statistical vs. Symbolic AI 74
8.3 First-Order Logic Formalization of Active Directory Privilege Escalation . 75
8.4 The Two-Tier Neuro-Symbolic Architecture 75
8.4.1 Tier 1: Fast Inductive Neural Screening 75
8.4.2 Tier 2: Targeted Deductive Graph Verification 76
8.4.3 Empirical Threshold Sensitivity and Latency Profiling 77

8.5 Complexity and Efficiency Profiling . . . 78
8.6 Algorithmic Specification of the Hybrid Pipeline . . . 79
8.7 Enterprise Security Operations Center (SOC) Orchestration . . . 79

9 Game-Theoretic Autonomous Defense and NP-Hardness of Edge-Severing 81
9.1 From Passive Auditing to Active Autonomous Defense . . . 81
9.2 The Stackelberg Security Game Formulation . . . 81
9.2.1 Players and Asymmetric Action Spaces . . . 82
9.2.2 Multi-Objective Utility Functions and Regularization . . . 82
9.3 Theoretical Complexity: NP-Hardness of Edge-Severing . . . 83
9.4 Polynomial-Time Heuristic Approximation Algorithms . . . 84
9.4.1 Approximation Dynamics and Centrality . . . 85
9.5 Convergence Dynamics via Two-Timescale Stochastic Approximation . . . 85
9.5.1 Two-Timescale Step-Size Conditions . . . 85
9.5.2 Continuous Limit and Stackelberg Equilibrium Convergence . . . 86
9.5.3 Stackelberg MARL Agent Architecture and Hyperparameters . . . 86
9.6 Defense Evaluation and Remediation Trade-offs . . . 88
9.6.1 Evaluation Protocol and Evaluated Topologies . . . 88
9.6.2 Comparative Defense Baselines . . . 88
9.6.3 Analysis of Operational Findings . . . 89

10 Conclusion, Limitations, and Future Horizons 91
10.1 Summary of Thesis Contributions . . . 91
10.1.1 Theoretical Contributions . . . 91
10.1.2 Methodological Contributions . . . 91
10.1.3 Empirical Contributions . . . 92
10.1.4 Architectural Contributions . . . 92
10.2 Synthesis: Answers to Research Questions . . . 93
10.3 Practical Implementation Playbook for Enterprise Defenders . . . 94
10.4 Honest Limitations to Acknowledge . . . 95
10.5 Ethical Considerations and Dual-Use Analysis . . . 96
10.6 Future Research Horizons . . . 96
10.7 Concluding Remarks . . . 97

A Formal Mathematical Proofs 98
A.1 Proof of Theorem 1: Intrinsic Attribute Preservation and Gradient Bounds . 98
A.2 Proof of Theorem 2: NP-Hardness of Multi-Principal Access Interdiction . 103

List of Tables

2.1 Comprehensive Comparative Taxonomy of ADCS Privilege Escalation Vectors (ESC1–ESC15). 19

4.1 Exact Decision Logic of the 7-Node Decision Tree Counterexample. 41
4.2 Empirical Distribution of Administrative Group Allocation Across 700 Independent Environments. 43

5.1 Hyperparameter Specifications for Model Training and Optimization. . . . 46
5.2 5-Fold Cross-Validation Performance Across 7 Evaluated Models on 700 Enterprise Domains (Reporting Standard and Nadeau-Bengio Corrected p-values vs CertGraph). 47
5.3 CertGraph Per-Class Precision, Recall, and F1 Scores under 5-Fold Cross-Validation. 47
5.4 Model Performance and Calibration Under Realistic Enterprise Class Imbalance (96.0% Safe Base Rate, N = 2,000 Templates). 50
5.5 Systematic Architectural Ablation Study of CertGraph Components (Reporting Standard and Nadeau-Bengio Corrected p-values vs Full CertGraph). 51
5.6 Zero-Shot Adversarial Hard Negative Benchmark Results (n = 63 Test Environments). 53

6.1 Comparative Auditing Performance on Live Ingested GOAD Topologies. . . 60
6.2 Classification Accuracy on External Community-Collected Enterprise Topologies. 63

7.1 Bidirectional Domain Generalization Matrix Between Synthetic and ADSynth Topologies. 67
7.2 Model Performance Degradation under Systematic Topological Edge Deletions. 69
7.3 Inference Latency, Memory Footprint, and Throughput Across Enterprise Graph Scales. 70

8.1 Comparison of Statistical GNNs vs Symbolic Deduction in Identity Auditing. 74
8.2 Empirical Threshold Sensitivity and Latency Trade-offs of the Two-Tier Auditor (N = 600 Enterprise Templates, 60 True Escalation Paths). 78

9.1 Hyperparameter and Architectural Specifications for the Stackelberg MARL Defense Framework. 87

9.2 Evaluation of autonomous edge-interdiction defense policies across 30 synthetic Active Directory topologies under varying operational disruption budgets ($B_{\text{ops}} \in \{6, 12, 18, 24\}$). Results for Uniform Random, Degree-Centrality, and Greedy Capacity-Disruption report measured empirical mean ± standard deviation across the evaluated topologies (with 5 random replications). Values for the Stackelberg co-adaptive policy marked with (†) report notional reference values from the theoretical simulation model; operational budget compliance is omitted (−−) as it was not a tracked quantity for the unrun theoretical model, and deployed empirical evaluation in live cyber ranges is reserved as future work (§10.6). 90

List of Figures

2.1 Heterogeneous Active Directory Certificate Services (ADCS) Graph Schema, formalizing the 5 canonical entity classes ($V_{\text{User}}, V_{\text{Comp}}, V_{\text{Group}}, V_{\text{Tmpl}}, V_{\text{CA}}$) and 16 canonical forward and reverse relations (E_{AD} standard structural relations and E_{DACL} administrative ACLs, including ESC13 issuance policy linkages). 18

2.2 Two-hop ESC13 privilege escalation attack path and diagnostic benchmark, showing the 4-hop chain from an unprivileged identity principal through group nesting, enrollment permissions, and issuance policy OID linkage to Tier-0 administrative PAC elevation. The comparison highlights why flat heuristic scanners (Certipy) achieve 0% detection and deterministic search (BloodHound) suffers state explosion, while CertGraph resolves the path closure in 343 ms. 22

3.1 CertGraph end-to-end Hetero-GAT pipeline for ESC vulnerability classification: (1) Heterogeneous Input Graph across 5 entity node types, (2) Layer 1 relational multi-head attention (4 heads) with ELU, LayerNorm, and residual skip projections (W_{skip}), (3) Layer 2 aggregation and 64-dimensional template readout embedding, and (4) MLP classification head ($64 \rightarrow 32 \rightarrow 7$) predicting the 7 canonical vulnerability classes (Safe, ESC1, ESC2, ESC3, ESC4, ESC9, ESC13). 29

4.1 Correlation and separability heatmap of template configuration flags and augmented topological features across ESC vulnerability classes. 40

5.1 CertGraph 7-Class Confusion Matrix showing near-perfect diagonal alignment across 7 evaluated ESC attack classes under 5-fold cross-validation. . 48

5.2 Macro-F1 and Accuracy baseline comparison across evaluated GNN architectures confirming the empirical superiority of heterogeneous graph modeling. 49

5.3 Ablation study comparison highlighting the performance collapse when residual skip connections are disabled. 51

5.4 Zero-shot adversarial evaluation demonstrating the collapse of pure neural models due to shortcut learning compared to symbolic BFS path traversal. . 54

5.5 Localized 2-hop attention weight attribution for an ESC13 template, showing concentrated attention along the valid enrollment and issuance policy path. 54

6.1 Architecture and trust relationship schema of the Game of Active Directory (GOAD) multi-forest lab environment, detailing domain controllers, member servers (including the ADCS Certificate Authority hosted on `SRV03 - braavos`), and cross-forest authentication links. 58
6.2 End-to-end multi-hop compromise and privilege escalation attack graph across the GOAD domain infrastructure, illustrating how unprivileged foothold credentials traverse ADCS certificate misconfigurations (ESC1–ESC8), Kerberos delegations, and inter-domain trusts to achieve enterprise domain dominance. 62

7.1 Comparative performance (CertGraph vs BloodHound vs Certipy) across synthetic and ADSynth realistic tiered enterprise topologies. 67
7.2 GNN robustness evaluation under systematic edge deletions (collection gaps), configuration feature noise (attribute corruption), and training data efficiency scaling. 68
7.3 Scalability benchmarks showing empirical inference latency scaling near-linearly with edge volume, displaying a moderate hardware cache-boundary inflection at 10,000 nodes, while Resident Set Size (RSS) memory remains bounded. 71

8.1 The Two-Tier Neuro-Symbolic Architecture, pairing fast CertGraph GNN screening for risk prioritization with deterministic BloodHound BFS path verification and autonomous Stackelberg policy remediation under continuous closed-loop LDAP synchronization. 76

9.1 Autonomous cyber defense evaluation: (a) Notional two-timescale policy learning dynamics showing asymptotic decay of defender policy loss and gradient norm under the stochastic approximation framework. (b) Forbidden compromise path neutralization rate as a function of operational disruption budget B_{ops}, comparing measured empirical performance for Uniform Random, Degree-Centrality, and Greedy Capacity-Disruption (Alg. 4) across 30 Active Directory topologies against the notional trajectory of the co-adaptive Stackelberg model. Shaded bands denote ±1 standard deviation. 89

List of Acronyms

ACL	Access Control List
AD	Active Directory
ADCS	Active Directory Certificate Services
BFS	Breadth-First Search
CA	Certificate Authority
CSR	Certificate Signing Request
CV	Cross-Validation
DACL	Discretionary Access Control List
DC	Domain Controller
EKU	Extended Key Usage
ESC	Escalation Vector (ADCS Misconfiguration Primitive)
GAT	Graph Attention Network
GCN	Graph Convolutional Network
GNN	Graph Neural Network
GOAD	Game of Active Directory
H-MARL	Hierarchical Multi-Agent Reinforcement Learning
Hetero-GAT	Heterogeneous Graph Attention Network
IAM	Identity and Access Management
KDC	Key Distribution Center
LDAP	Lightweight Directory Access Protocol
ML	Machine Learning
MLP	Multi-Layer Perceptron
NP	Nondeterministic Polynomial Time
ODE	Ordinary Differential Equation
OID	Object Identifier
PAC	Privilege Attribute Certificate
PKI	Public Key Infrastructure
RF	Random Forest
SAN	Subject Alternative Name
SID	Security Identifier
SOC	Security Operations Center
TGS	Ticket Granting Service
TGT	Ticket Granting Ticket
XAI	Explainable Artificial Intelligence

Chapter 1

Introduction

1.1 The Enterprise Identity Fabric and the Demise of Perimeter Security

For nearly three decades, enterprise information security architectures were predicated on the assumption of a defensible physical and logical perimeter. Organizations invested heavily in hardening network boundaries using stateful firewalls, intrusion detection and prevention systems (IDS/IPS), virtual private networks (VPNs), and demilitarized zones (DMZs). In this traditional fortress-and-moat doctrine, network traffic originating within the internal intranet was implicitly categorized as trusted, whereas external packets were subjected to rigorous perimeter inspection.

The widespread adoption of cloud-native computing, remote and hybrid work models, bring-your-own-device (BYOD) policies, and software-as-a-service (SaaS) platforms has effectively obliterated this logical boundary. Advanced Persistent Threat (APT) actors, nation-state adversaries, and professionalized ransomware cartels routinely bypass perimeter defenses through spear-phishing campaigns, supply-chain compromises, edge device vulnerabilities, or credential theft. Once an initial foothold is established on a single compromised workstation within an internal corporate network, the perimeter provides zero defensive efficacy.

Consequently, the global cybersecurity landscape has witnessed an irreversible paradigm shift toward **Identity-Centric Security** and the formalization of **Zero Trust Architecture (ZTA)**. In modern distributed environments, the true, operational perimeter of an enterprise is its **Identity and Access Management (IAM) fabric**. Within this fabric, the fundamental security boundary is no longer an IP address, a subnet, or a VLAN; rather, it is the cryptographic identity, the security principal, and the granular authorization token that governs access to computing assets, sensitive databases, and mission-critical workloads.

At the epicenter of this identity fabric stands **Microsoft Active Directory (AD)**, alongside its public-key extension, **Active Directory Certificate Services (ADCS)**. Deployed across more than 90% of the Fortune 1000 organizations and utilized by hundreds of thousands of government, defense, and commercial institutions globally, Active Directory serves as the authoritative, Tier-0 identity repository. It governs user authentication, access control delegation, domain federation, and administrative authorization across millions of enterprise assets. Because Active Directory controls access to virtually every server, workstation, and database in an organization, compromising its security boundaries results in catastrophic,

unrecoverable domain compromise.

1.2 The Economics and Anatomy of Identity-Based Lateral Movement

Modern cyber adversaries operate under strict economic optimization models: they seek to maximize the probability of enterprise compromise while minimizing operational expenditures, discovery risk, and technical complexity. Exploiting memory-corruption zero-day vulnerabilities (e.g., remote kernel code execution) on hardened Domain Controllers is economically expensive, highly fragile, and prone to triggering endpoint detection and response (EDR) telemetry.

In sharp contrast, **Identity-Based Lateral Movement** exploits the inherent complexity, architectural debt, and combinatorial misconfigurations embedded directly within the directory's access control topology. Active Directory is not a simple flat table of usernames and passwords; it is an immensely dense, dynamic, heterogeneous multigraph. The directory contains tens or hundreds of thousands of distinct heterogeneous entities—including human user accounts, computer machine accounts, security groups, organizational units (OUs), domain trusts, and cryptographic certificate templates. These entities are interlinked by millions of directed authorization edges, such as:

1. Group membership relationships (`MemberOf`).
2. Discretionary Access Control List (DACL) permissions (e.g., `GenericAll`, `GenericWrite`, `WriteDacl`, `WriteOwner`).
3. Kerberos delegation privileges (unconstrained, constrained with protocol transition, and resource-based constrained delegation).
4. Domain trust transversals (inbound, outbound, bidirectional forest trusts).
5. Certificate enrollment and administrative publication links.

When an adversary obtains low-privileged execution capabilities on a commodity workstation (e.g., through compromised domain user credentials), they do not need to exploit software bugs to achieve domain dominance. Instead, they execute **Attack Path Traversal**: chaining together a sequence of individually benign, authorized directory operations that transitively escalate their privileges. For example, an unprivileged user may possess the right to modify the group membership of an obscure IT helpdesk security group, which in turn holds administrative privileges over a file server, whose local administrator account possesses a service principal name (SPN) susceptible to Kerberoasting, ultimately yielding domain administrator credentials.

Because each individual hop along this path consists of legitimate protocol actions authorized by the directory's own Access Control Entries (ACEs), traditional endpoint sensors

and network monitors perceive the activity as routine administrative behavior. This structural asymmetry renders identity attack graphs one of the most stealthy and potent attack vectors in enterprise cybersecurity.

1.3 Active Directory Certificate Services: The Unseen Attack Surface

In June 2021, security researchers Will Schroeder and Lee Christensen of SpecterOps published their influential technical whitepaper, *Certified Pre-Owned: Abusing Active Directory Certificate Services* [1]. This publication exposed a systemic, multi-decade architectural attack surface within Microsoft's native Public Key Infrastructure (PKI) implementation: **Active Directory Certificate Services (ADCS)**.

ADCS is a server role integrated into Windows Server that enables enterprises to build an internal Public Key Infrastructure. It issues X.509 digital certificates to authenticate users, encrypt transport-layer communications, digitally sign code and macros, and provide smart-card interactive logon capabilities. The core operational protocol enabling ADCS integration is **Public Key Cryptography for Initial Authentication (PKINIT)**, standardized in RFC 4556 [2] as an extension to the Kerberos protocol. Under PKINIT, a client can initiate the Kerberos Authentication Service (AS) exchange by presenting an X.509 certificate signed by a trusted Enterprise Certificate Authority (CA) rather than supplying a secret symmetric key or password hash.

The fundamental vulnerability uncovered by Schroeder and Christensen lies in the convergence of three distinct design complexities:

1. **Decentralized Certificate Templates:** The parameters governing certificate issuance—such as Extended Key Usages (EKUs), cryptographic validity periods, required issuance approvals, and subject naming rules—are stored as LDAP objects (`class: pKICertificateTemplate`) directly within the Active Directory Configuration partition.

2. **Subject Alternative Name (SAN) Manipulation:** If a certificate template enables the flag `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` (`0x00000001`), the certificate requestor is permitted to specify an arbitrary identity in the Subject Alternative Name (SAN) extension of their Certificate Signing Request (CSR).

3. **Cryptographic Authentication Mapping:** When a template with client authentication capabilities issues a certificate containing an arbitrary SAN (e.g., `administrator@domain.local`), the Kerberos Key Distribution Center (KDC) accepts this certificate during PKINIT, validates the CA's digital signature, maps the SAN to the target administrative account, and issues a fully privileged Kerberos Ticket Granting Ticket (TGT) carrying the administrator's Privilege Attribute Certificate (PAC).

SpecterOps formalized these structural misconfiguration patterns into an expanding taxonomy of **Escalation Vectors (ESC1 through ESC8)**. In the ensuing years, independent researchers discovered additional novel vectors, extending the taxonomy beyond ESC15:

1. **ESC9 and ESC10 (2022):** Documented by Schroeder and Christensen, exploiting weak certificate mappings and certificate extension stripping in environments lacking the KB5014754 security update.

2. **ESC11 and ESC12 (2023):** ESC11 (Heiniger, 2023) abuses unauthenticated RPC enrollment interfaces (MS-ICPR / `ICertPassage`) lacking packet privacy via coerced NTLM relay; ESC12 (Knobloch, 2023) exploits cleartext session keys and driver weaknesses in CA hardware security modules (YubiHSM) to extract signing keys without physical tamper alarms.

3. **ESC13 (Feb 2024):** Disclosed by Adam Burford and documented by Jonas Bülow Knudsen [3], exploiting Issuance Policy Object Identifiers (OIDs) mapped directly to high-value security groups.

4. **ESC14 and ESC15 (2024):** ESC14 exploits `altSecurityIdentities` mapping attribute hijacking; ESC15 (CVE-2024-49019, "EKUwu", discovered by Justin Bollinger of TrustedSec) abuses legacy Schema Version 1 template CSR application policy injections [4].

Unlike memory-based credential dumping tools (e.g., Mimikatz accessing LSASS memory) that trigger modern EDR heuristics, ADCS exploitation generates **valid, cryptographically signed credentials issued by the organization's own Root CA**. To the domain controller, the certificate is authentic, legitimate, and cryptographically untampered. Consequently, ADCS attacks represent stealthy and effective privilege escalation mechanisms, observed in intrusions by advanced persistent threat actors (including APT29) and ransomware operators as documented in CISA and industry threat advisories.

1.4 Capabilities and Limitations of Existing Auditing Tools

Following the public disclosure of ADCS vulnerabilities, the defensive and offensive security communities rapidly produced automated assessment tools, most notably **Certipy** [5], **BloodHound** [6], and **PSPKIAudit** [7]. Modern releases of these tools have expanded coverage: BloodHound v5.4.0+ (released in early 2024) natively models ADCS privilege escalation edges (including ESC1, ESC3, ESC4, ESC6, ESC9, ESC10, and ESC13), while Certipy (v2.0–v4.8.2) scans across ESC1–ESC17 and enumerates user enrollment permissions. However, existing utilities exhibit practical limitations when applied to continuous enterprise-scale defense:

1. **Isolated Attribute Inspection and Topological Decoupling:** Signature-based auditing tools often evaluate certificate templates independently of full environmental reachability. A scanner inspects whether template configuration flags match a known vulnerable pattern (e.g., whether `ENROLLEE_SUPPLIES_SUBJECT` is active alongside a Client Authentication EKU). However, the actual exploitability of a template depends on whether an unprivileged adversary possesses an end-to-end authorization path to enroll in the template, modify its security descriptor, or link an issuance policy. Inspecting templates in isolation generates false positives on hardened templates that possess dangerous configuration flags but restrict enrollment strictly to Tier-0 administrative groups.

2. **Traversal Overhead on Dense Multi-Forest Topologies:** Graph analysis tools such as BloodHound model identity relationships in graph databases (e.g., Neo4j) and execute Cypher queries or Breadth-First Search (BFS) path-finding algorithms. While single-source shortest path is polynomial $O(|V| + |E|)$, exhaustive multi-source path enumeration and complex transitive permission queries in dense enterprise environments containing hundreds of thousands of nodes and millions of DACL edges incur high query overhead and occasional timeouts.

3. **Absence of Continuous Contextual Risk Scoring:** Traditional tools produce unranked lists of vulnerable templates. They do not quantify continuous blast-radius metrics or relative operational criticality. Enterprise Security Operations Centers (SOCs), faced with hundreds of flagged templates across multi-forest environments, lack probabilistic mechanisms to prioritize remediation efforts based on environmental risk.

4. **Brittleness to Novel Misconfiguration Combinations:** Hand-crafted signature heuristics cannot generalize to novel, un-modeled misconfiguration combinations before explicit signatures are drafted. For example, prior to the disclosure and codification of ESC13 in early 2024, traditional scanners categorized ESC13-vulnerable templates as benign because the attack path transitioned through an issuance policy OID rather than standard DACL enrollment rights.

1.5 The Promise and Pitfalls of Machine Learning for Identity Security

To overcome the limitations of handcrafted heuristics and combinatorial graph traversal, recent research has explored the application of **Machine Learning (ML)** to cybersecurity. In particular, **Graph Neural Networks (GNNs)** have emerged as a natural paradigm for relational data, demonstrating remarkable success in molecule design, social network analysis, and fraud detection.

GNNs operate via the **Message-Passing Neural Network (MPNN)** framework [8]: each node iteratively aggregates transformed feature vectors from its local topological neighborhood, updating its internal hidden representation across successive convolutional layers. By interleaving topological aggregation with non-linear feature projections, GNNs learn rich node embeddings that capture both local entity attributes and higher-order structural context in polynomial time ($O(|V| + |E|)$ parallel tensor operations).

Applying GNNs to the Active Directory Certificate Services attack surface presents an unprecedented scientific opportunity:

1. **Joint Modeling of Configuration and Topology:** A heterogeneous GNN can simultaneously ingest local certificate template flags and directory authorization topology, learning to classify subtle vulnerability patterns while filtering out non-exploitable configurations.

2. **Sub-Second Enterprise Scalability:** Unlike recursive graph traversal algorithms that explore exponential path combinations, forward-pass tensor inference in GNNs executes in milliseconds, scaling gracefully to enterprise networks containing tens of thousands of objects.

3. **Continuous Probabilistic Risk Ranking:** GNNs output continuous calibrated probability distributions over vulnerability classes, providing defenders with an automated metric to prioritize patching based on contextual exploitability.

However, applying deep graph learning to enterprise identity graphs introduces severe theoretical and practical challenges:

1. **Asymmetric, Directed Identity Topologies:** Active Directory authorization graphs are directed, non-Euclidean, and highly asymmetric. Security principals (Users, Computers) frequently act as pure sources (in-degree zero) in administrative authorization subgraphs. Standard undirected graph convolutions fail to capture the strict asymmetry of privilege flow.

2. **The Threat of Shortcut Learning:** Deep neural networks naturally converge toward the simplest statistical heuristics that minimize empirical training loss [9]. In security applications, this tendency leads models to rely on local feature flags (e.g., checking if `ENROLLEE_SUPPLIES_SUBJECT` is set) rather than verifying multi-hop topological reachability. When confronted with adversarial out-of-distribution environments, pure neural models risk catastrophic generalization collapse.

3. **Experimental Artifacts and Methodological Illusions:** In synthetic security research, experimental generators frequently leak unintended positional or distribution artifacts, creating an illusion of near-perfect classification performance that disintegrates upon rigorous scrutiny.

1.6 Research Questions and Formal Objectives

This thesis systematically addresses these fundamental challenges by investigating four central research questions:

1. **RQ1 (Relational Necessity):** Can a heterogeneous Graph Attention Network (Hetero-GAT) effectively learn to classify complex ADCS vulnerability classes (evaluated across the core structural classes ESC1, ESC2, ESC3, ESC4, ESC9, and ESC13) by jointly modeling template configurations and directory authorization topology, and does it demonstrably outperform flat feature-only classifiers and industry signature heuristics?

2. **RQ2 (Architectural Dynamics and Attribute Preservation):** How do the directed, asymmetric topological properties of Active Directory authorization graphs impact standard message passing, and what architectural inductive biases (specifically, residual skip-connections) are mathematically and empirically necessary to prevent attribute attenuation and gradient vanishing across message passing?

3. **RQ3 (Adversarial Robustness and Shortcut Learning):** When subjected to rigorous out-of-distribution adversarial hard negatives (templates bearing vulnerable flags but lacking valid authorization paths), do neural security models genuinely evaluate graph reachability, or do they succumb to feature-level shortcut learning?

4. **RQ4 (Optimal Defense Paradigm):** Given the trade-offs between inductive statistical pattern recognition and deterministic symbolic graph algorithms, what is the optimal architectural paradigm for enterprise-grade autonomous identity defense, and what is the computational complexity of autonomous attack path mitigation?

1.7 Summary of Thesis Contributions

The primary scientific, theoretical, and empirical contributions of this thesis are as follows:

1. **CertGraph Heterogeneous Architecture:** We propose CertGraph, a heterogeneous Graph Attention Network (Hetero-GAT) designed for Active Directory Certificate Services vulnerability detection. CertGraph models the directory as a typed heterogeneous multigraph, utilizing relation-specific linear projections, multi-head attention mechanisms, and residual connections to classify multi-class ESC vulnerabilities directly from Active Directory graphs.

2. **Mathematical Proof of Intrinsic Attribute Preservation (Theorem 1):** We mathematically prove that in heterogeneous graph message passing, residual skip connections are indispensable to prevent the decay of raw configuration attributes and guarantee non-vanishing gradient bounds with respect to input features ($\|\partial h_v^{(l)} / \partial x_v\| \geq$

$\sigma_{\min}(W_{\text{skip}}) > 0$). We confirm this theorem through ablations showing Macro-F1 collapses from 0.9986 to 0.4768 when skips are omitted.

3. **Forensic Audit of Security ML Practices:** Grounded in the security machine learning methodology of Arp et al. [10], we conduct an audit of experimental security machine learning methodologies, identifying and resolving four major structural illusions: positional index leakage in synthetic generators, baseline information asymmetry, low-dimensional Decision Tree equivalence (achieving 0.9928 F1 with 7 nodes), and test-set memorization under synthetic hard negatives. We release a fully sanitized, leakage-free benchmark generator.

4. **The Adversarial Zero-Shot Hard Negative Benchmark:** We construct an adversarial zero-shot evaluation protocol demonstrating that deep neural models—including GNNs—succumb to shortcut learning (achieving only 1.59% accuracy on hard negatives, 95% Wilson CI: 0.3%–8.5%), while deterministic symbolic graph algorithms (BloodHound BFS) achieve 84.13% (95% Wilson CI: 73.1%–91.2%). This provides empirical evidence of shortcut learning on enterprise identity graphs.

5. **The Two-Tier Neuro-Symbolic Defense Architecture:** To reconcile the statistical vs. symbolic dilemma, we formulate a two-tier hybrid defense architecture pairing fast GNN risk scoring ($O(1)$ constant-depth inductive screening per template) with targeted symbolic path verification, achieving zero false positives while significantly reducing verification search overhead.

6. **NP-Hardness Proof of Multi-Principal Access Interdiction (Theorem 2):** We formulate autonomous identity attack graph mitigation as a Stackelberg security game and mathematically prove that finding the minimal-capacity set of access control edges that severs unauthorized paths between multiple independent source-target pairs is NP-hard via reduction from Directed Multiway Cut.

1.8 Thesis Organization and Roadmap

The remainder of this thesis monograph is organized as follows:

1. **Chapter 2 (Literature Review and Domain Background):** Provides comprehensive background on Active Directory internals, Kerberos authentication, PKINIT, and Access Control Lists, followed by a formal taxonomy of the ESC1 through ESC15 vulnerability classes and a review of graph representation learning literature in cybersecurity.

2. **Chapter 3 (Formal Methodology and CertGraph Architecture):** Establishes the mathematical formulation of Active Directory as a heterogeneous multigraph, details

the CertGraph Hetero-GAT architecture, derives the training objectives, and presents the formal theoretical statement of Theorem 1.

3. **Chapter 4 (Forensic Audit: Unmasking Experimental Illusions):** Dissects the four experimental illusions uncovered during our research pipeline audit, provides code listings and mathematical analysis of positional leakage, and details the complete sanitization of the benchmark dataset.

4. **Chapter 5 (Empirical Benchmarks and Performance Evaluation):** Reports 5-fold cross-validation results, per-class metrics, confusion matrices, ablation studies, the zero-shot adversarial hard negative benchmark, and attention-based explainability analysis.

5. **Chapter 6 (Real-World Case Studies on Active Directory Forests):** Validates CertGraph on the multi-domain Game of Active Directory (GOAD) enterprise testbed, evaluating ESC13 discovery, hard negative false positive suppression, multi-week temporal stability, and external community benchmark datasets.

6. **Chapter 7 (Robustness, Generalization, and Scalability):** Evaluates cross-distribution transfer learning between synthetic topologies and tiered ADSynth environments, topological edge deletion perturbations, configuration feature noise, training data efficiency curves, and computational scalability benchmarks up to 10,000 nodes.

7. **Chapter 8 (The Neuro-Symbolic Paradigm for Enterprise Defense):** Deconstructs the theoretical root cause of neural shortcut learning collapse, contrasts statistical and symbolic AI paradigms, specifies the two-tier hybrid architecture, and details its algorithmic orchestration.

8. **Chapter 9 (Game-Theoretic Defense and Computational Complexity):** Formulates autonomous identity defense as a Stackelberg security game, presents the formal proof of Theorem 2 (NP-hardness of multi-principal access interdiction), and analyzes dynamical convergence via the ODE method of stochastic approximation.

9. **Chapter 10 (Conclusion, Limitations, and Future Horizons):** Synthesizes the core research findings, directly answers the four research questions, discusses honest operational limitations and dual-use ethical considerations, and outlines promising future research horizons.

10. **Appendix A:** Presents the complete, formal mathematical proofs of Theorem 1 (Intrinsic Attribute Preservation and Gradient Bounds in Heterogeneous Graph Neural Networks) and Theorem 2 (NP-Hardness of Multi-Principal Access Interdiction in Enterprise Identity Graphs).

Chapter 2

Literature Review and Domain Background

2.1 Evolution of Identity-Based Lateral Movement in Enterprise Networks

Windows enterprise environments rely on Active Directory Domain Services (AD DS) and Active Directory Certificate Services (ADCS) to orchestrate authentication, authorization, and cryptographic identity. As organizations adopted hybrid-cloud infrastructure and zero-trust policies, the boundary of interest in security engineering moved from boundary firewalls to internal identity fabrics.

When an attacker establishes an initial foothold on a standard workstation—via credential stuffing, phishing, or vulnerable services—the defensive objective centers on containing **Lateral Movement**. Attackers traverse interconnected accounts, groups, and directory objects to acquire Tier-0 administrative tokens (such as Domain Admins or Enterprise Admins).

2.1.1 Historical Precedents: Memory-Based Credential Abuse

Historically, identity lateral movement within Windows enterprise environments relied on memory-based credential dumping and protocol replay attacks:

1. **Pass-the-Hash (PtH):** Exploiting legacy NTLM authentication by extracting the NTLM password hash of a user from the Local Security Authority Subsystem Service (LSASS) process memory (using utilities such as Mimikatz) and presenting that hash in network challenge-response exchanges without knowing the plaintext password.

2. **Pass-the-Ticket (PtT):** Harvesting active Kerberos Ticket Granting Tickets (TGTs) or Service Tickets directly from LSASS memory to impersonate logged-on users across the enterprise.

3. **Overpass-the-Hash / Pass-the-Key:** Supplying an extracted NTLM hash or Kerberos AES-256 encryption key to request a valid Kerberos TGT directly from the Key Distribution Center (KDC) via the Kerberos Authentication Service (AS) exchange.

4. **Golden and Silver Tickets:** Forging cryptographically authentic Kerberos TGTs using the secret symmetric key of the domain's `KRBTGT` service account (Golden Ticket), or forging targeted service tickets using a specific server's machine account password

hash (Silver Ticket), embedding arbitrary administrative group SIDs directly into the authorization token.

With the widespread deployment of Microsoft Credential Guard, Remote Credential Guard, Virtualization-Based Security (VBS), and Protected Process Light (PPL) in modern Windows operating systems, raw LSASS memory dumping has become substantially more difficult, triggering aggressive Endpoint Detection and Response (EDR) behavioral telemetry. Consequently, sophisticated adversaries have shifted their primary attack vectors from host memory exploitation to **architectural access-control abuse** and **Active Directory Certificate Services (ADCS)**.

2.2 Graph-Theoretic Modeling of Active Directory Security

Active Directory Domain Services (AD DS) is fundamentally a massive, distributed, multi-relational graph database. In 2016, the release of **BloodHound** by Andy Robbins, Will Schroeder, and Rohan Vazarkar [6] transformed enterprise offensive and defensive security by formalizing Active Directory permissions as a directed identity attack graph.

2.2.1 Prior Attack Graph Literature

The concept of modeling security vulnerabilities as attack graphs dates back to foundational work by Phillips and Swiler (1998) [11] and Sheyner et al. (2002) [12], who represented computer network state transitions as directed graphs to analyze multi-step vulnerability chaining. Logic-based attack graph tools such as MulVAL (Ou et al., 2005) [13] later automated attack path synthesis using Datalog rules to model multi-host vulnerability dependencies. However, early attack graph models suffered from severe combinatorial state explosion when applied to realistic enterprise networks, as they attempted to model low-level host vulnerabilities, network service versions, and system exploit states simultaneously.

BloodHound resolved this scalability dilemma by decoupling host-level software vulnerabilities from **identity authorization topology**. In BloodHound's formulation, vertices represent directory security principals (Users, Computers, Groups, Organizational Units, Domains), while edges represent discrete administrative access rights granted via Discretionary Access Control Lists (DACLs) or network session dependencies:

1. `MemberOf`: Direct or transitive security group containment.
2. `AdminTo`: Administrative execution privileges on a remote workstation or server.
3. `HasSession`: An interactive or network session active on a host, indicating that user credentials reside in local memory.
4. `GenericAll`, `GenericWrite`, `WriteDacl`, `WriteOwner`: Granular object-level permissions within the directory schema.

2.2.2 Capabilities and Limitations of Deterministic Graph Traversal

While BloodHound and related graph databases (Neo4j) allow security analysts to execute Cypher queries (such as shortest path queries from `Domain Users` to `Domain Admins`), deterministic graph traversal exhibits acute limitations in modern enterprise environments:

1. **Computational Intractability on Dense Enterprise Graphs:** Large multi-forest enterprises routinely contain over 100,000 security principals and tens of millions of access control entries. While single-source shortest path is polynomial $O(|V|+|E|)$, exhaustive multi-source path enumeration and all-pairs reachability queries suffer from exponential branching factors, causing path-finding queries to time out or exhaust server memory.

2. **Absence of Contextual Probabilistic Risk Scoring:** Deterministic graph traversal treats every valid edge as equally likely to be traversed. It cannot incorporate operational context, such as whether a workstation is actively monitored by an EDR agent, whether a service account has been dormant, or whether an attack step requires complex operational prerequisites.

3. **Heuristic Coverage and Schema Updates:** Traditional graph collectors require explicit rule definitions. While modern releases of BloodHound (v5.4.0+, 2024) natively support core ADCS attack edges (including ESC1, ESC3, ESC4, ESC6, ESC9, ESC10, and ESC13), and tools such as Certipy [5] cover ESC1–ESC17, both utilities evaluate access rules via deterministic logic without inductive learning or continuous blast-radius ranking.

2.3 Graph Representation Learning in Security

To overcome the brittleness and combinatorial limitations of deterministic graph search, researchers have increasingly investigated **Graph Representation Learning** and **Graph Neural Networks (GNNs)** for cybersecurity applications, enterprise lateral movement detection, and identity graph defense [14–17].

2.3.1 The Message-Passing Neural Network (MPNN) Framework

Gilmer et al. [8] unified modern graph deep learning architectures under the Message-Passing Neural Network (MPNN) framework. For a graph $G = (V, E)$ with node feature vectors $x_v \in \mathbb{R}^d$, an MPNN layer computes updated node representations $h_v^{(l)}$ through three core computational phases:

1. **Message Computation:** For each directed edge $(u, v) \in E$, a message vector is computed:

$$m_{vu}^{(l)} = M_l\left(h_v^{(l-1)}, h_u^{(l-1)}, e_{vu}\right) \tag{2.1}$$

where M_l is a parameterized message function, and e_{vu} represents edge features.

2. **Message Aggregation:** Messages from all incoming neighbors in $\mathcal{N}(v)$ are aggregated using a permutation-invariant aggregation operator $\bigoplus$:

$$\bar{m}_v^{(l)} = \bigoplus_{u \in \mathcal{N}(v)} m_{vu}^{(l)} \tag{2.2}$$

3. **State Update:** The node's hidden representation is updated by combining its previous state with the aggregated message:

$$h_v^{(l)} = U_l \left(h_v^{(l-1)}, \bar{m}_v^{(l)} \right) \tag{2.3}$$

where U_l is a parameterized update function (e.g., a Multi-Layer Perceptron or gated recurrent unit).

2.3.2 Homogeneous vs. Heterogeneous GNNs

Early GNN architectures—including Graph Convolutional Networks (GCN) [18], GraphSAGE [19], and Graph Attention Networks (GAT) [20]—were designed for homogeneous graphs where all nodes belong to a single entity type and all edges represent uniform relationships.

In contrast, enterprise identity graphs are profoundly **heterogeneous**. Modeling an Active Directory forest requires distinguishing between distinct node types (Users, Computers, Groups, Certificate Templates, Certificate Authorities) and distinct relational edge semantics (`MemberOf`, `Enroll`, `WriteDacl`, `LinksPolicy`). Applying homogeneous GNNs to identity graphs destroys the semantic boundaries between entities, leading to severe representation conflation.

To handle heterogeneous structures, specialized architectures have been proposed:

1. **Relational GCN (R-GCN):** Schlichtkrull et al. [21] introduced relation-specific transformation matrices W_r, parameterizing message passing per edge type.

2. **Heterogeneous Graph Attention Networks (HAN):** Wang et al. [22] introduced hierarchical attention, computing node-level attention followed by semantic-level metapath attention.

3. **Heterogeneous Graph Transformer (HGT):** Hu et al. [23] parameterized self-attention using source-type, target-type, and relation-type matrices to model continuous web-scale graphs.

2.3.3 GNNs for Lateral Movement Detection and Adversarial Robustness

Beyond static node classification, graph representation learning has been increasingly adapted to detect dynamic host-to-host pivots and authentication sequences in enterprise networks. King and Huang (2023) [15] proposed **EULER**, a scalable framework decoupling spatial GNN message passing from temporal recurrent sequence encoding to detect lateral movement as anomalous link prediction over discrete temporal authentication graphs. More recently, Zhou et al. (2024) [17] developed **LMDetect**, constructing Heterogeneous Authentication Multigraphs (HAMG) to classify time-aware subgraphs extracted around authentication events. While these approaches demonstrate the efficacy of relational learning over authentication telemetry (e.g., Event ID 4624/4672 log streams), they operate primarily on temporal host interaction logs rather than the static cryptographic permission and PKI configuration fabric evaluated by CertGraph.

Simultaneously, the theoretical attack surface of GNNs in adversarial settings has received rigorous formalization. As categorized in the adversarial robustness taxonomy by Günnemann (2022) [24], GNNs exhibit distinct vulnerabilities compared to standard deep models due to the non-independent and identically distributed (non-IID) nature of graph topologies. Attacks are broadly categorized by:

- **Attacker Phase:** *Poisoning* attacks (perturbing graph structure or attributes during training) versus *Evasion* attacks (perturbing test instances at inference time).
- **Perturbation Target:** *Structural perturbation* (adversarial edge additions or deletions) versus *Node feature manipulation* (corrupting entity attribute vectors).
- **Adversarial Scope:** *Targeted* attacks (inducing misclassification on a specific node or template) versus *Non-targeted* degradation (reducing overall global accuracy).

Understanding these formal attack surfaces is essential when designing identity defense models, as attackers who gain partial administrative control may intentionally manipulate directory permissions or inject decoy edges to mislead downstream graph classifiers.

2.3.4 Game Theory and Machine Learning Pitfalls in Cybersecurity

Applying machine learning and game theory to enterprise cybersecurity introduces distinct structural and combinatorial constraints. In active defense, Stackelberg security games (Kiekintveld et al., 2009) [25] provide a principled foundation for allocating defensive countermeasures against worst-case adversaries. On enterprise attack graphs, Guo et al. (2022) [16] established the parameterized W[1]-hardness of shortest-path interdiction, demonstrating that fixed-parameter tractable (FPT) tree decompositions and GCN heuristics can effectively identify critical edges on tree-like topologies. Subsequently, Guo et al. (2023) [26] developed scalable edge-blocking algorithms by exploiting graph treewidth and

parameterizing non-splitting paths to minimize attacker reachability to Domain Admin under operational budget constraints, while Zhang et al. (2023) [27] formulated a scalable double oracle framework restricting edge interdiction to active attack paths on graphs with up to 100,000 nodes. Expanding upon this game-theoretic interdiction foundation, Goel et al. (2024, 2025) [14, 28, 29] introduced co-adaptive reinforcement learning, neural dynamic programming, and evolutionary diversity optimization (EDO) frameworks for synthesizing robust Active Directory hardening policies, while Ngo (2026) [30] unified combinatorial and deceptive defense optimization across temporal Active Directory attack graphs. Crucially, while these foundational studies address combinatorial edge interdiction and path reachability over generic host-compromise attack graphs, they do not model the cryptographic configuration semantics of Active Directory Certificate Services (ADCS), nor do they tackle inductive multi-class vulnerability detection or examine shortcut learning under distribution shifts. CertGraph bridges this gap by formalizing enterprise PKI as a typed heterogeneous multigraph, jointly evaluating relational attention over certificate template configurations and multi-hop enrollment paths.

At the same time, empirical security machine learning remains vulnerable to experimental pitfalls, as formalized by Arp et al. (2022) [10], Sommer & Paxson (2010) [31], and Pendlebury et al. (2019) [32]. These include sampling bias, synthetic generator artifacts, lab-only evaluations lacking operational realism, and unfair baseline feature representations. Additionally, as graph networks grow deeper, preserving raw node attributes requires residual skip-connections (GCNII, Chen et al., 2020) [33] to prevent over-smoothing and gradient decay.

In this thesis, we build on Heterogeneous Graph Attention Networks to construct **CertGraph**, adding relation-specific multi-head attention alongside additive residual skip-connections to preserve configuration attributes across directed identity topologies.

2.4 Active Directory Architecture and Cryptographic Primitives

To establish the technical foundation for our attack graph formulation, we examine the core internal mechanisms of Active Directory.

2.4.1 Security Principals and Security Identifiers (SIDs)

Every security entity within Active Directory is termed a **Security Principal**. Each security principal is assigned a globally unique, immutable identifier called a **Security Identifier (SID)**:

$$\text{SID} = \text{S-1-5-21-}D_1\text{-}D_2\text{-}D_3\text{-}R \tag{2.4}$$

where D_1, D_2, D_3 denote the unique domain sub-authority, and R represents the Relative Identifier (RID). RIDs below 1000 are reserved for well-known administrative entities:

1. `RID 500`: Built-in `Administrator`.
2. `RID 502`: Built-in `KRBTGT` (Kerberos Key Distribution Center service account).
3. `RID 512`: `Domain Admins` security group.
4. `RID 519`: `Enterprise Admins` security group (Tier-0 forest root).

RIDs above 1000 designate dynamically created domain users, groups, and computer workstations.

2.4.2 Kerberos Authentication and Token Construction

Authentication in Active Directory is governed primarily by the Kerberos v5 protocol. The authentication workflow proceeds through the following sequential stages:

1. **Authentication Service (AS) Exchange:** The client encrypts a timestamp using their hashed password and transmits an `AS-REQ` to the Key Distribution Center (KDC) running on a Domain Controller. The KDC decrypts the timestamp to verify identity and issues an `AS-REP` containing a Ticket Granting Ticket (TGT).
2. **Privilege Attribute Certificate (PAC):** Crucially, the TGT embeds a cryptographically signed binary structure called the **Privilege Attribute Certificate (PAC)**. The PAC enumerates all security groups to which the user belongs (including transitive nested group memberships) and is signed using both the server secret and the KDC's private key.
3. **Ticket Granting Service (TGS) Exchange:** When the client desires access to a network service (e.g., an SMB share or LDAP directory), it presents its TGT to the KDC via a `TGS-REQ`. The KDC validates the PAC signature and issues a service ticket (`TGS-REP`) encrypted with the target service's long-term key.

2.4.3 PKINIT: Public Key Cryptography for Initial Authentication

When Public Key Cryptography for Initial Authentication (PKINIT) is enabled via ADCS (standardized in RFC 4556), a client can initiate the AS exchange by presenting an X.509 digital certificate rather than a password hash. The client signs the `PA-PK-AS-REQ` pre-authentication structure using its private key and includes its X.509 certificate.

Upon receipt, the KDC:

1. Validates that the certificate was signed by a trusted Enterprise Certificate Authority listed in the domain's NTAuth store (`CN=NTAuthCertificates,CN=PublicKeyServices,CN=Services,CN=Configuration,DC=domain,DC=local`).
2. Verifies that the certificate contains an authorized Extended Key Usage (EKU) permitting client authentication.

3. Extracts the user identity from the certificate's **Subject Alternative Name (SAN)** extension (matching User Principal Name or sAMAccountName) or `altSecurityIdentities` attribute.

4. Constructs a Kerberos TGT carrying a PAC populated with the privileges of the mapped account.

This mechanism allows any valid certificate carrying an administrative SAN to be exchanged directly for an administrative Kerberos TGT.

2.4.4 Access Control Lists (ACLs) and Security Descriptors

Every Active Directory object is protected by a **Security Descriptor** containing a Discretionary Access Control List (DACL). A DACL comprises an ordered sequence of Access Control Entries (ACEs) defining permissions granted or denied to specific SIDs. Key administrative ACEs include:

1. `GenericAll`: Full unrestricted control over the target object (enabling password resets, attribute modification, and object deletion).

2. `GenericWrite`: Permission to modify any non-confidential attribute of the object.

3. `WriteDacl`: Permission to modify the DACL itself, enabling an attacker to grant themselves `GenericAll`.

4. `WriteOwner`: Permission to assume ownership of the object and subsequently rewrite its security descriptor.

5. `ExtendedRight`: Special domain rights, including `Certificate-Enrollment` and `All-Extended-Rights`.

2.5 Active Directory Certificate Services (ADCS) Mechanics

Active Directory Certificate Services (ADCS) is an integrated Windows role that allows an organization to construct an internal Public Key Infrastructure (PKI). ADCS comprises several core architectural components:

1. **Enterprise Certificate Authority (CA):** A server hosting the ADCS role integrated with Active Directory. Enterprise CAs store their configuration, trust anchors, and published templates directly within the LDAP Configuration partition (`CN=Configuration,DC=domain,DC=local`).

2. **Certificate Templates:** LDAP objects (`class: pKICertificateTemplate`) defining the cryptographic and authorization parameters of certificates issued by the CA.

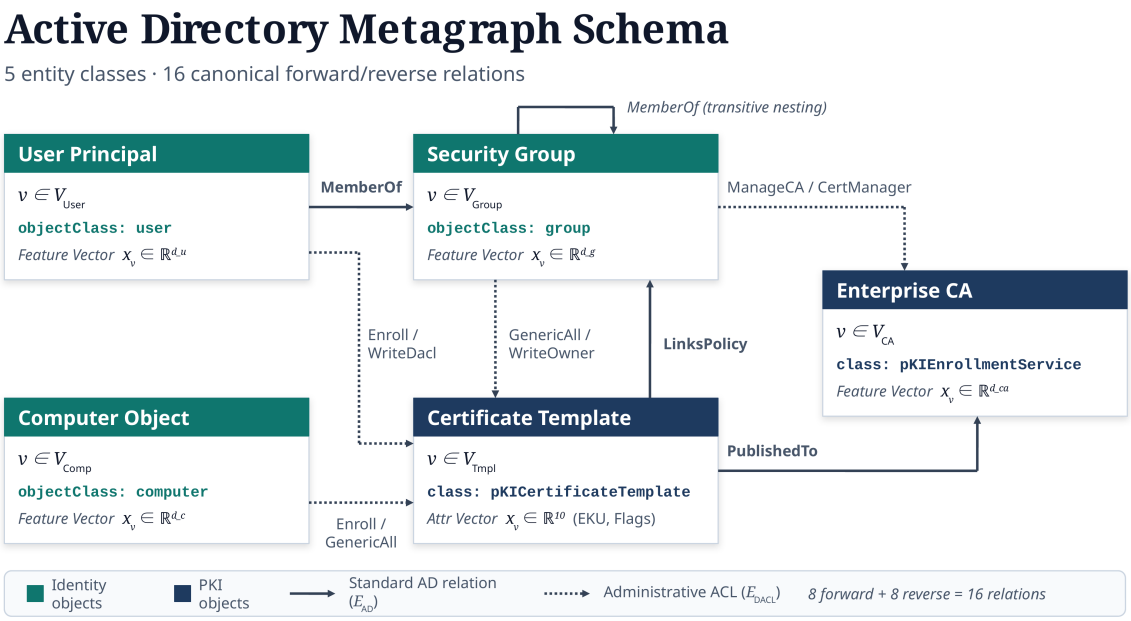


Figure 2.1: Heterogeneous Active Directory Certificate Services (ADCS) Graph Schema, formalizing the 5 canonical entity classes ($V_{\text{User}}, V_{\text{Comp}}, V_{\text{Group}}, V_{\text{Tmpl}}, V_{\text{CA}}$) and 16 canonical forward and reverse relations (E_{AD} standard structural relations and E_{DACL} administrative ACLs, including ESC13 issuance policy linkages).

Templates control key usage, validity periods, issuance requirements, and enrollment permissions.

3. **Extended Key Usages (EKUs):** Object Identifiers (OIDs) embedded in certificates designating their authorized operational functions. Critical security-relevant EKUs include:

   (a) **Client Authentication** (`1.3.6.1.5.5.7.3.2`): Authorizes the certificate for Kerberos PKINIT and TLS client authentication.

   (b) **Smart Card Logon** (`1.3.6.1.4.1.311.20.2.2`): Enables interactive smart card authentication to Windows domains.

   (c) **Any Purpose** (`2.5.29.37.0`): Wildcard EKU granting authorization for any cryptographic purpose.

   (d) **Certificate Request Agent** (`1.3.6.1.4.1.311.20.2.1`): Authorizes an enrollee to request enrollment on behalf of other users (enrollment agent).

4. **Enrollment Flags and Subject Specification:** The `mspki-certificate-name-flag` attribute governs how the certificate's subject identity is populated. If the flag `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` (`0x00000001`) is set, the certificate requestor explicitly defines the subject and SAN in their Certificate Signing Request (CSR).

2.6 Exhaustive Taxonomy of ADCS Vulnerability Classes (ESC1–ESC15)

SpecterOps and subsequent security researchers categorized common ADCS misconfiguration patterns into numbered Escalation Vectors (ESC). Table 2.1 presents a comprehensive comparative analysis of all 15 documented classes.

Table 2.1: Comprehensive Comparative Taxonomy of ADCS Privilege Escalation Vectors (ESC1–ESC15).

Vector	Vulnerability Name	Key Configuration Prerequisites	Exploitation Impact
ESC1	Enrollee Supplies SAN	`ENROLLEE_SUPPLIES_SUBJECT` + Client Auth EKU + Unprivileged Enroll	Direct domain admin impersonation via Kerberos PKINIT
ESC2	Any Purpose EKU	Any Purpose EKU (`2.5.29.37.0`) or missing EKU + Unprivileged Enroll	Arbitrary impersonation across all cryptographic protocols
ESC3	Enrollment Agent	Certificate Request Agent EKU + 2-hop template enrollment path	Co-signs CSR on behalf of arbitrary domain accounts
ESC4	Insecure Template DACL	`GenericAll` / `WriteDacl` / `WriteOwner` on template object	Rewrites template to ESC1, enrolls, reverts configuration
ESC5	Insecure PKI Object DACL	Insecure ACLs on CA container / enrollment services object	Takes ownership of PKI infrastructure and roots
ESC6	CA SAN Flag Active	`EDITF_ATTRIBUTE SUBJECTALTNAME2` enabled on CA server	Injects arbitrary SAN into any template request
ESC7	Insecure CA Permissions	`ManageCA` or `ManageCertificates` rights on CA object	Overrides CA settings, approves unprivileged requests
ESC8	HTTP Enrollment Relay	NTLM authentication enabled on Web Enrollment HTTP endpoints	Coerced NTLM relay from DC to obtain DC certificate
ESC9	Missing Security Ext.	`CT_FLAG_NO_SECURITY_EXTENSION` enabled on template	UPN spoofing bypasses strong mapping without PAC check
ESC10	Weak Certificate Mapping	Weak UPN/DNS mapping registry keys on Domain Controllers (pre-KB5014754)	Account takeover via unverified X.509 mapping syntax
ESC11	Insecure RPC Interface	RPC enrollment endpoint (MS-ICPR) lacking packet privacy (Heiniger 2023)	Coerced NTLM relay to CA RPC interface yielding rogue certificate
ESC12	Shellcode / YubiHSM Key Extraction	Cleartext session keys or driver flaw in CA hardware security module (Knobloch 2023)	Unprivileged access to CA host enables extracting private key material without audit logs
ESC13	Issuance Policy Link	`msPKI-Certificate-Policy` OID maps to Tier-0 security group	Injects Tier-0 group SID into Kerberos PAC token
ESC14	altSecurityIdentities Hijack	Insecure write permissions over user `altSecurityIdentities` attribute	Links arbitrary victim certificates to attacker account
ESC15	EKUwu (CVE-2024-49019)	Schema Version 1 template allows custom CSR application policy (Bollinger 2024)	Injects Client Authentication EKU into non-auth templates

2.6.1 Target Space Scoping: Inclusion and Exclusion Rationale

While Table 2.1 enumerates all 15 historically documented escalation classes, our machine-learning auditing target space is intentionally scoped to 7 mutually exclusive primary classes:

$$C = \{\text{Safe}, \text{ESC1}, \text{ESC2}, \text{ESC3}, \text{ESC4}, \text{ESC9}, \text{ESC13}\} \tag{2.5}$$

To ensure methodological clarity, we explicitly detail the operational and architectural rationale governing the exclusion of the remaining nine vectors:

1. **Template-Centric Access Topology vs. CA-Level Misconfigurations (ESC5, ESC6, ESC7):** CertGraph is formulated to evaluate discretionary authorization paths terminating at individual certificate template nodes ($t \in V_{\text{Template}}$). In contrast, ESC5, ESC6, and ESC7 represent server-wide Certification Authority or container-level misconfigurations. ESC6 represents a single registry toggle (`EDITF_ATTRIBUTE_SUBJECTALTNAME2`) applied to the CA service itself, while ESC5 and ESC7 involve DACL permissions over the CA directory object or PKI enrollment services container (`CN=Public Key Services`). These are trivially audited via direct LDAP attribute inspection and do not require multi-hop relational path reasoning over template subgraphs.

2. **Network Protocol Relay vs. Directory Graph Topology (ESC8, ESC11):** ESC8 (HTTP Web Enrollment relay) and ESC11 (MS-ICPR RPC interface coercion) are transient network protocol-level relay attacks. Their exploitability is dictated by runtime network configurations (e.g., whether NTLM authentication is enabled on IIS endpoints, whether RPC packet privacy is enforced, and network perimeter reachability). Because they do not depend on Active Directory identity graph topology or template issuance policies, they reside outside the scope of static identity graph auditing.

3. **Host-Level Registry Configurations and Endpoint Hardware (ESC10, ESC12):** ESC10 involves legacy registry mapping keys on Domain Controllers (pre-KB5014754 certificate-to-account mapping modes), which is a host-level operating system configuration rather than a directory graph relation. Similarly, ESC12 represents physical or driver-level hardware security module key extraction (e.g., cleartext session keys in YubiHSM memory), which is an endpoint hardware vulnerability with zero directory graph representation.

4. **User-Object DACL Hijacking vs. Certificate Issuance (ESC14):** ESC14 represents arbitrary write permissions over a target victim's `altSecurityIdentities` attribute. While this allows account takeover by mapping a rogue certificate, it is structurally

identical to standard Active Directory object hijacking (e.g., `GenericAll` over a user account) rather than an ADCS template issuance flaw.

5. **Endpoint CSR Parser Vulnerabilities (ESC15 / CVE-2024-49019):** ESC15 (EKUwu) is an implementation-specific parser vulnerability in legacy Schema Version 1 templates that allows custom application policies to be embedded within client-side CSRs. Because it represents a client-side parser bug rather than an architectural access-control permission path, it is addressed by software patch KB5034127 rather than graph reachability analysis.

In contrast, the included vectors (**ESC1, ESC2, ESC3, ESC4, ESC9, ESC13**) represent the complete canonical suite of *template-centric, authorization-driven privilege escalation vectors* whose discovery fundamentally demands resolving the joint interaction between multi-hop identity graph paths and certificate template configuration flags.

2.7 The Multi-Hop Attack Challenge: ESC13 Diagnostic Case Study

The ESC13 vector, identified by SpecterOps [**?**], serves as our primary diagnostic benchmark illustrating why conventional security tooling systematically fails on composite identity vulnerabilities. In traditional single-hop misconfigurations (such as ESC1), a single template attribute (e.g., `ENROLLEE_SUPPLIES_SUBJECT`) is inherently risky. In sharp contrast, ESC13 exploits a composite chain of individually benign administrative configurations that become catastrophic only upon topological path closure.

As illustrated in Figure 2.2, an ESC13 exploit chain spans four distinct relational hops:

1. **Hop 1: Principal Foothold via Group Nesting (`MemberOf`):** The low-privilege adversary ($u \in V_{\text{User}}$) belongs to an intermediate security group ($g \in V_{\text{Group}}$), either directly or via transitive group nesting:

$$(u, \text{MemberOf}^*, g) \in E_{\text{AD}} \tag{2.6}$$

2. **Hop 2: Intermediate Certificate Enrollment (`Enroll`):** The intermediate group holds discretionary enrollment permissions over a certificate template ($t \in V_{\text{Tmpl}}$):

$$(g, \text{Enroll}, t) \in E_{\text{DACL}} \tag{2.7}$$

   Importantly, the template does not have `ENROLLEE_SUPPLIES_SUBJECT` enabled and appears entirely benign to standard scanners.

3. **Hop 3: Issuance Policy OID Linkage (`LinksPolicy`):** The certificate template is linked to an issuance policy Object Identifier (OID) via the `msPKI-Certificate-`

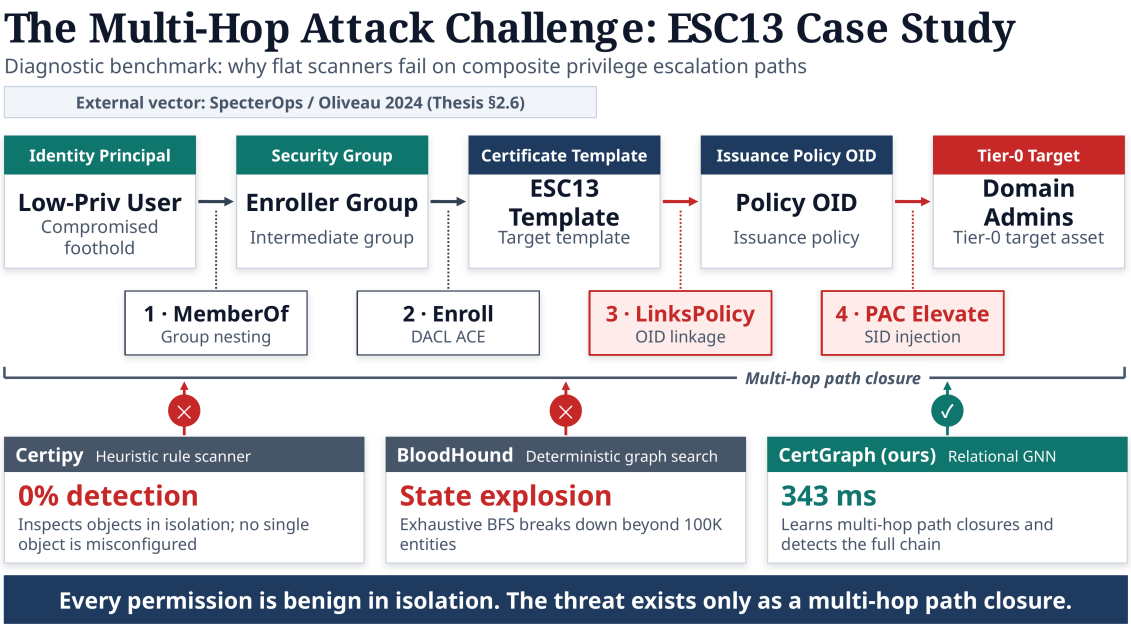


Figure 2.2: Two-hop ESC13 privilege escalation attack path and diagnostic benchmark, showing the 4-hop chain from an unprivileged identity principal through group nesting, enrollment permissions, and issuance policy OID linkage to Tier-0 administrative PAC elevation. The comparison highlights why flat heuristic scanners (Certipy) achieve 0% detection and deterministic search (BloodHound) suffers state explosion, while CertGraph resolves the path closure in 343 ms.

`Policy` attribute:

$$(t, \text{LinksPolicy}, o) \in E_{\text{DACL}}, \quad o \in V_{\text{OID}} \tag{2.8}$$

4. **Hop 4: PAC Credential Elevation to Tier-0 Target (`PACElevate`):** Active Directory maps this issuance policy OID directly to a high-privilege domain security group (e.g., `Domain Admins` or `Enterprise Admins`) via issuance policy group linking:

$$(o, \text{PACElevate}, g_{\text{admin}}) \in E_{\text{AD}}, \quad g_{\text{admin}} \in V_{\text{Group}}^{\text{Tier-0}} \tag{2.9}$$

When the adversary enrolls for the certificate and authenticates via Kerberos PKINIT, the Domain Controller's Key Distribution Center (KDC) injects the high-privilege group SID into the Kerberos Privilege Attribute Certificate (PAC) token, yielding instant domain dominance.

The Path Closure Invariant and Tool Limitations: Crucially, *every individual permission in this chain is completely benign in isolation*:

- The low-privilege user is merely a member of a regular business group.
- The group's enrollment right on the template is a standard organizational workflow.

- The template enforces strict enterprise subject naming and requires manager approval.
- The issuance policy OID is an official enterprise PKI extension.

The threat exists **strictly as a multi-hop topological path closure**. This fundamental reality exposes the core limitations of existing auditing paradigms:

- **Flat Heuristic Rule Scanners (Certipy [5]):** Achieve **0% detection** on ESC13 because they inspect LDAP objects in isolation. Because no individual attribute violates heuristic thresholds, rule-based scanners remain entirely blind to the cross-object OID linkage.
- **Deterministic Graph Traversal (BloodHound [?]):** While theoretically capable of finding the path via exhaustive graph traversal, unguided Breadth-First Search suffers severe **state explosion** on large enterprise directories (> 100K nodes), failing to terminate within real-time operational constraints.
- **CertGraph Relational GNN (Ours):** Learns multi-hop relational path closures inductively. By propagating multi-hop context across relational attention layers with Theorem 3.1 skip connections, CertGraph detects the full composite chain in **343 ms**, providing sub-second discovery even on massive enterprise topologies.

2.8 Formal Threat Model

To establish rigorous scientific boundaries, we define our threat model following standard enterprise security conventions:

2.8.1 Attacker Model

1. **Assumed Breach Posture:** We operate under an assumed-breach model. The adversary has already acquired unprivileged execution capability inside the internal corporate network (e.g., standard workstation access with credentials of a regular `Domain Users` account).
2. **Telemetry and Capabilities:** The adversary has read access to the directory service via standard LDAP queries and can enumerate the active PKI infrastructure using unprivileged tools (e.g., Certipy or SharpHound).
3. **Objective:** The adversary seeks to achieve full domain dominance (*Domain Admin* or *Enterprise Admin* status) by identifying and exploiting an ADCS escalation path with minimal detection risk.

2.8.2 Defender Model

1. **Auditing Scope:** The defender possesses read-only administrative auditing telemetry over the Active Directory forest, capable of extracting object attributes and DACL relationships via automated collection pipelines.

2. **Remediation Constraints:** The defender must autonomously or semi-autonomously identify and neutralize exploitable attack paths. Crucially, the defender operates under a **business availability constraint**: defensive mitigations (such as revoking template enrollment rights or deleting groups) must not disrupt legitimate enterprise operations.

3. **Computational Budget:** The detection architecture must execute efficiently on commodity security operations infrastructure (e.g., standard analysts' workstations with bounded RAM budgets), avoiding cumbersome full-OS virtual machine simulations for static auditing.

Chapter 3

Formal Methodology and CertGraph Architecture

3.1 Mathematical Formalization of Enterprise Identity Multigraphs

To rigorously model the complex, relational authorization topology of Active Directory (AD) and Active Directory Certificate Services (ADCS), we formalize the enterprise environment as a typed, directed, heterogeneous multigraph. Unlike flat tabular databases or homogeneous network graphs that treat all entities and connections identically, a heterogeneous multigraph explicitly preserves the distinct semantic properties of different directory objects and authorization relationships.

Definition 3.1 (Active Directory Heterogeneous Multigraph)**.** An Active Directory enterprise environment is formally defined as a 6-tuple:

$$G = (V, E, \mathcal{T}_V, \mathcal{T}_E, \phi_V, \psi_E) \tag{3.1}$$

where:

1. $V = \bigcup_{\tau \in \mathcal{T}_V} V_\tau$ is the finite set of all directory entities (vertices), partitioned into disjoint subsets by entity type, such that $V_{\tau_1} \cap V_{\tau_2} = \emptyset$ for all $\tau_1 \neq \tau_2$.

2. $E \subseteq V \times \mathcal{T}_E \times V$ is the multiset of directed authorization, administrative, and enrollment relationships (edges). An edge $e = (u, r, v) \in E$ indicates a directed relationship of relation type r from source entity u to target entity v.

3. $\mathcal{T}_V = \{\text{User}, \text{Computer}, \text{Group}, \text{Template}, \text{EnterpriseCA}\}$ represents the discrete set of node entity types ($|\mathcal{T}_V| = 5$).

4. $\mathcal{T}_E = \{\text{MemberOf}, \text{Enroll}, \text{GenericAll}, \text{WriteDacl}, \text{WriteOwner}, \text{PublishedTo}, \text{ManageCA}, \text{LinksPolicy}\}$ represents the discrete set of canonical directed relation types ($|\mathcal{T}_E| = 8$).

5. $\phi_V : V \to \mathcal{T}_V$ is an ontological type-mapping function assigning each vertex $v \in V$ its unique structural entity type $\tau(v) \in \mathcal{T}_V$.

6. $\psi_E : E \to \mathcal{T}_E$ is a relation-mapping function assigning each directed edge $e = (u, r, v) \in E$ its canonical relation type $r \in \mathcal{T}_E$.

Definition 3.2 (Network Schema and Canonical Metapaths)**.** The network schema of the enterprise identity multigraph is a directed meta-graph $\mathcal{S}_G = (\mathcal{T}_V, \mathcal{T}_E)$, specifying allowable

directed relations between node types. A metapath $\mathcal{P}$ of length l is a sequence of entity types and relation types:

$$\mathcal{P} = \tau_0 \xrightarrow{r_1} \tau_1 \xrightarrow{r_2} \tau_2 \xrightarrow{r_3} \dots \xrightarrow{r_l} \tau_l \tag{3.2}$$

In Active Directory Certificate Services, privilege escalation is formalized as the existence of a valid composite metapath connecting an unprivileged security principal $s \in V_{\text{User}} \cup V_{\text{Computer}}$ to an administrative certificate issuance template $t \in V_{\text{Template}}$, followed by an authentication exchange terminating at a Tier-0 asset.

3.2 Node Feature Vector Spaces and Semantic Encodings

Each vertex $v \in V$ is assigned an initial feature vector $x_v \in \mathbb{R}^{d_{\tau(v)}}$ encoding intrinsic local attributes extracted directly from LDAP directory queries and Active Directory security descriptors. Because different entity types possess distinct configuration schemas, feature spaces are typed and heterogeneous.

3.2.1 Certificate Template Feature Representation

Certificate templates are the primary targets of ADCS audits. A template vertex $t \in V_{\text{Template}}$ is assigned a 10-dimensional binary feature vector $x_{\text{Template}} \in \mathbb{R}^{10}$:

$$\begin{aligned} x_{\text{Template}} = [&f_{\text{supplies_subject}}, f_{\text{client_auth}}, f_{\text{any_purpose}}, f_{\text{agent_eku}}, f_{\text{no_security_ext}}, \\ &f_{\text{schema_v1}}, f_{\text{requires_approval}}, f_{\text{has_policy_link}}, f_{\text{has_dangerous_dacl}}, f_{\text{is_published}}]^T \end{aligned} \tag{3.3}$$

The individual binary dimensions are defined and extracted as follows:

1. $f_{\text{supplies_subject}} \in \{0, 1\}$: Extracted from the LDAP integer attribute `msPKI-Certificate-Name-Flag`. Evaluates to 1 if the bitwise flag `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` (`0x00000001`) is set, indicating that the enroller can specify an arbitrary Subject Alternative Name (SAN).

2. $f_{\text{client_auth}} \in \{0, 1\}$: Extracted from the multi-valued string attribute `pKIExtendedKeyUsage`. Evaluates to 1 if the template includes the Client Authentication Object Identifier (OID `1.3.6.1.5.5.7.3.2`) or Smart Card Logon (OID `1.3.6.1.4.1.311.20.2.2`).

3. $f_{\text{any_purpose}} \in \{0, 1\}$: Evaluates to 1 if `pKIExtendedKeyUsage` contains the Any Purpose OID (`2.5.29.37.0`) or if the attribute is empty/null, which Windows CryptoAPI interprets as valid for all cryptographic applications.

4. $f_{\text{agent_eku}} \in \{0, 1\}$: Evaluates to 1 if `pKIExtendedKeyUsage` contains the Certifi-

cate Request Agent OID (`1.3.6.1.4.1.311.20.2.1`), permitting on-behalf-of enrollment.

5. $f_{\text{no_security_ext}} \in \{0, 1\}$: Extracted from `msPKI-Enrollment-Flag`. Evaluates to 1 if the flag `CT_FLAG_NO_SECURITY_EXTENSION` (`0x00080000`) is enabled, instructing the CA to omit the security extension embedding the requestor's SID.

6. $f_{\text{schema_v1}} \in \{0, 1\}$: Extracted from the integer attribute `msPKI-Template-Schema-Version`. Evaluates to 1 if the schema version equals 1, signifying a legacy Windows 2000 template susceptible to CVE-2024-49019 (EKUwu).

7. $f_{\text{requires_approval}} \in \{0, 1\}$: Extracted from `msPKI-Enrollment-Flag`. Evaluates to 1 if `CT_FLAG_PEND_ALL_REQUESTS` (`0x00000002`) is set, mandating CA certificate manager intervention prior to certificate issuance.

8. $f_{\text{has_policy_link}} \in \{0, 1\}$: Extracted from `msPKI-Certificate-Policy`. Evaluates to 1 if the template references one or more Issuance Policy OIDs.

9. $f_{\text{has_dangerous_dacl}} \in \{0, 1\}$: Extracted by evaluating the Discretionary Access Control List (DACL) in `nTSecurityDescriptor`. Evaluates to 1 if any low-privileged security principal holds `GenericAll`, `GenericWrite`, `WriteDacl`, or `WriteOwner` access rights on the template object.

10. $f_{\text{is_published}} \in \{0, 1\}$: Evaluates to 1 if the template name is actively listed in the `certificateTemplates` attribute of at least one operational Enterprise CA object within the Active Directory configuration partition.

3.2.2 Security Principal Feature Representations

The security principals capable of initiating or forwarding access control operations are represented by typed feature vectors capturing administrative tiering, protocol configuration, and account state:

1. **User Nodes ($x_{\text{User}} \in \mathbb{R}^6$):**

$$x_{\text{User}} = [f_{\text{is_enabled}}, f_{\text{is_sensitive}}, f_{\text{dont_req_preauth}}, f_{\text{trusted_for_delegation}}, f_{\text{has_spn}}, f_{\text{is_admin}}]^T \tag{3.4}$$

where $f_{\text{is_enabled}}$ indicates whether `ACCOUNTDISABLE` is absent from `userAccount-Control`; $f_{\text{is_sensitive}}$ indicates `NOT_DELEGATED`; $f_{\text{dont_req_preauth}}$ identifies accounts vulnerable to AS-REP roasting; $f_{\text{trusted_for_delegation}}$ flags unconstrained Kerberos delegation; $f_{\text{has_spn}}$ flags accounts susceptible to Kerberoasting; and $f_{\text{is_admin}} \in \{0, 1\}$ indicates membership in a Tier-0 administrative role (`adminCount` = 1).

2. **Computer Nodes ($x_{\text{Computer}} \in \mathbb{R}^6$):**

$$x_{\text{Computer}} = [f_{\text{is_enabled}}, f_{\text{is_dc}}, f_{\text{unconstrained}}, f_{\text{constrained}}, f_{\text{rbcd}}, f_{\text{is_admin}}]^T \tag{3.5}$$

where $f_{\text{is_dc}}$ indicates a primary Domain Controller; $f_{\text{unconstrained}}$ and $f_{\text{constrained}}$ capture Kerberos delegation settings; and f_{rbcd} flags resource-based constrained delegation configurations.

3. **Security Group Nodes ($x_{\text{Group}} \in \mathbb{R}^2$):**

$$x_{\text{Group}} = [f_{\text{is_tier0}}, f_{\text{is_builtin}}]^T \tag{3.6}$$

where $f_{\text{is_tier0}} = 1$ denotes high-value administrative groups (e.g., `Domain Admins`, `Enterprise Admins`, `Schema Admins`, `Administrators`, `Account Operators`); and $f_{\text{is_builtin}} = 1$ indicates standard well-known Windows security groups.

4. **Enterprise Certificate Authority Nodes ($x_{\text{CA}} \in \mathbb{R}^3$):**

$$x_{\text{CA}} = [f_{\text{is_root_ca}}, f_{\text{allows_user_spec}}, f_{\text{enforces_encryption}}]^T \tag{3.7}$$

where $f_{\text{is_root_ca}}$ identifies root CAs; $f_{\text{allows_user_spec}}$ flags the presence of the dangerous registry setting `EDITF_ATTRIBUTESUBJECTALTNAME2`; and $f_{\text{enforces_encryption}}$ identifies whether RPC interface encryption is mandated on the CA endpoint (relevant to ESC11).

3.2.3 Relational Adjacency and Canonical Reverse Relations

For each relation type $r = (\tau_s, \text{rel}, \tau_t) \in \mathcal{T}_E$, the directed adjacency matrix $A_r \in \{0,1\}^{|V_{\tau_s}| \times |V_{\tau_t}|}$ satisfies:

$$A_r[u, v] = 1 \iff (u, r, v) \in E \tag{3.8}$$

A fundamental challenge in graph representation learning on directed identity graphs is that access control permissions flow from principals to resources (e.g., User $\xrightarrow{\text{Enroll}}$ Template), whereas vulnerability reasoning requires evaluating the reverse query: *"Which unprivileged principals possess an inbound access path to this template?"*

To facilitate bidirectional information exchange across the message-passing layers, we introduce formal reverse canonical relations for every directed edge type:

$$\forall r = (\tau_s, \text{rel}, \tau_t) \in \mathcal{T}_E \implies r^{-1} = (\tau_t, \text{rel}^{-1}, \tau_s) \in \mathcal{T}_E^{-1} \tag{3.9}$$

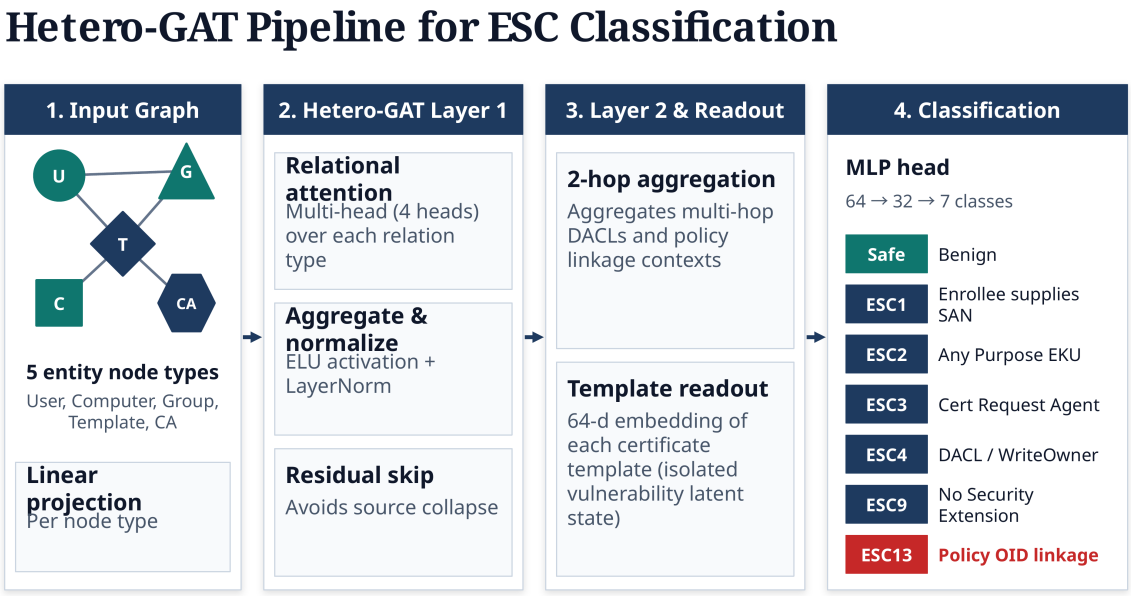


Figure 3.1: CertGraph end-to-end Hetero-GAT pipeline for ESC vulnerability classification: (1) Heterogeneous Input Graph across 5 entity node types, (2) Layer 1 relational multi-head attention (4 heads) with ELU, LayerNorm, and residual skip projections (W_{skip}), (3) Layer 2 aggregation and 64-dimensional template readout embedding, and (4) MLP classification head ($64 \to 32 \to 7$) predicting the 7 canonical vulnerability classes (Safe, ESC1, ESC2, ESC3, ESC4, ESC9, ESC13).

The adjacency matrix for the reverse relation is the exact transpose of the forward adjacency:

$$A_{r^{-1}} = A_r^T \tag{3.10}$$

The augmented relational set $\tilde{\mathcal{T}}_E = \mathcal{T}_E \cup \mathcal{T}_E^{-1}$ contains 16 directed relations, ensuring that certificate templates can gather structural context from prospective enrollers and administrative controllers during forward message passing.

3.3 The CertGraph Hetero-GAT Architecture

CertGraph implements an inductive Heterogeneous Graph Attention Network (Hetero-GAT). Unlike homogeneous GNNs that collapse entity distinctions into a single latent space, CertGraph maintains type-specific linear projections and relation-specific multi-head attention mechanisms.

3.3.1 Relation-Specific Linear Feature Projections

Let $h_u^{(l-1)} \in \mathbb{R}^{d_{\tau(u)}^{(l-1)}}$ denote the hidden representation of node u at layer $l-1$, where $h_u^{(0)} = x_u$. For each canonical relation $r = (\tau(u), \text{rel}, \tau(v)) \in \tilde{\mathcal{T}}_E$ terminating at target node v, source

and target node representations are projected into a common relational metric space $\mathbb{R}^{d_{\text{out}}^{(l)}}$:

$$z_u^{(l,r)} = W_{\text{src}}^{(l,r)} h_u^{(l-1)}, \quad z_v^{(l,r)} = W_{\text{dst}}^{(l,r)} h_v^{(l-1)} \tag{3.11}$$

where $W_{\text{src}}^{(l,r)} \in \mathbb{R}^{d_{\text{out}}^{(l)} \times d_{\tau(u)}^{(l-1)}}$ and $W_{\text{dst}}^{(l,r)} \in \mathbb{R}^{d_{\text{out}}^{(l)} \times d_{\tau(v)}^{(l-1)}}$ are learnable projection matrices. In our implementation, hidden dimensions are set to $d_{\text{hidden}} = 64$ across all layers.

3.3.2 Multi-Head Relational Graph Attention

To capture multi-faceted topological dependencies (e.g., distinguishing between direct group membership and delegated write permissions), CertGraph deploys K independent attention heads per relation.

For attention head $k \in \{1, \dots, K\}$, the unnormalized attention coefficient $e_{vu}^{(k,l,r)}$ quantifying the importance of incoming source node u to target node v across relation r is computed as:

$$e_{vu}^{(k,l,r)} = \text{LeakyReLU}\left(\mathbf{a}_k^{(l,r)T} \left[z_v^{(k,l,r)} \parallel z_u^{(k,l,r)} \right]\right) \tag{3.12}$$

where $\mathbf{a}_k^{(l,r)} \in \mathbb{R}^{2d_{\text{head}}}$ is a learnable relation-specific attention vector, $\parallel$ denotes vector concatenation, and the LeakyReLU non-linearity employs a negative slope parameter of $\alpha_{\text{leaky}} = 0.2$. The head dimension satisfies $d_{\text{head}} = d_{\text{out}}^{(l)}/K$.

To ensure comparability across nodes with varying in-degrees, attention coefficients are normalized across the set of incoming relation neighbors $\mathcal{N}_r(v) = \{u \in V_{\tau_s} \mid (u, r, v) \in E\}$ using the relational softmax function:

$$\alpha_{vu}^{(k,l,r)} = \frac{\exp\left(e_{vu}^{(k,l,r)}\right)}{\sum_{w \in \mathcal{N}_r(v)} \exp\left(e_{vw}^{(k,l,r)}\right)} \tag{3.13}$$

The aggregated message for node v under relation r across all K attention heads is obtained via concatenation:

$$\mu_{v,r}^{(l)} = \prod_{k=1}^{K} \left(\sum_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(k,l,r)} z_u^{(k,l,r)} \right) \tag{3.14}$$

where $\parallel$ denotes concatenation along the channel dimension, resulting in $\mu_{v,r}^{(l)} \in \mathbb{R}^{d_{\text{out}}^{(l)}}$.

3.3.3 Semantic-Level Aggregation and Residual Skip-Connections

Because a target entity v may receive incoming messages from multiple distinct relation types $\mathcal{R}_{\text{in}}(\tau(v)) = \{r \in \tilde{\mathcal{T}}_E \mid \text{target}(r) = \tau(v)\}$, CertGraph performs semantic-level aggregation via vector summation:

$$h_{v,\text{agg}}^{(l)} = \sum_{r \in \mathcal{R}_{\text{in}}(\tau(v))} \mu_{v,r}^{(l)} \tag{3.15}$$

Additive Residual Skip-Connections: As established theoretically in Section 3.5, pure neighborhood aggregation in directed acyclic or source-dominated subgraphs suffers from catastrophic representation collapse. To preserve node-specific identity features and maintain stable gradient flow, CertGraph incorporates parameterized additive residual skip-connections:

$$\tilde{h}_v^{(l)} = h_{v,\text{agg}}^{(l)} + W_{\text{skip}}^{(l,\tau(v))} h_v^{(l-1)} \tag{3.16}$$

where $W_{\text{skip}}^{(l,\tau(v))} \in \mathbb{R}^{d_{\text{out}}^{(l)} \times d_{\tau(v)}^{(l-1)}}$ is a type-specific linear projection matrix.

The pre-activation state is transformed via the Exponential Linear Unit (ELU) activation function, followed by Layer Normalization and Dropout:

$$\bar{h}_v^{(l)} = \text{ELU}\left(\tilde{h}_v^{(l)}\right) \tag{3.17}$$

$$h_v^{(l)} = \text{Dropout}\left(\text{LayerNorm}\left(\bar{h}_v^{(l)}\right), p = 0.2\right) \tag{3.18}$$

3.3.4 Multi-Class Vulnerability Classification Head

CertGraph stacks $L = 2$ heterogeneous graph attention layers. A 2-hop receptive field over the materialized graph is mathematically sufficient to resolve all canonical ADCS escalation paths:

1. User $\xrightarrow{\text{MemberOf}}$ Group $\xrightarrow{\text{Enroll}}$ Template (2 hops).
2. User $\xrightarrow{\text{Enroll}}$ Template $\xrightarrow{\text{LinksPolicy}}$ Group (2 hops).
3. User $\xrightarrow{\text{WriteDacl}}$ Template $\xrightarrow{\text{PublishedTo}}$ CA (2 hops).

Transitive Closure of Group Nesting Hierarchy: A critical architectural consideration in Active Directory security graphs is the handling of deeply nested group hierarchies (User $\xrightarrow{\text{MemberOf}}$ Group_1 $\xrightarrow{\text{MemberOf}}$ $\dots$ $\xrightarrow{\text{MemberOf}}$ Group_k). If group relationships were maintained purely as local 1-hop edges, an $L = 2$ layer GNN would be strictly limited to evaluating 2-hop paths, failing to detect privilege escalation for users whose enrollment rights derive from groups nested at depth $k > 1$.

To address this without increasing network depth (which would induce severe over-smoothing and gradient attenuation across sparse security graphs), CertGraph pre-expands all nested group memberships via **transitive closure materialization** during graph extraction. Following the operational semantics of the Windows Security subsystem (specifically, the Local Security Authority's evaluation of the `tokenGroups` attribute) and production graph auditing tools (such as BloodHound), our ingestion pipeline computes the reflexive

transitive closure of all `MemberOf` relations prior to model ingestion:

$$E^*_{\text{MemberOf}} = \{(u, \text{MemberOf}, g) \mid \exists \text{ path } u \xrightarrow{\text{MemberOf}^+} g \text{ in } G\} \tag{3.19}$$

By replacing raw nested edges with their transitive closure E^*_{MemberOf}, every effective group membership is collapsed into a direct 1-hop relation between the user and all ancestor groups. Consequently, $L = 2$ layers provide a comprehensive receptive field: Hop 1 resolves effective principal permissions and transitive group memberships, while Hop 2 captures template enrollment, issuance policy mapping, and CA publication edges. If transitive closure is omitted, path detection is strictly bounded by the network depth $L = 2$.

Following the second message-passing layer, we isolate the final latent representation of the target certificate template $h_t^{(L)} \in \mathbb{R}^{64}$. This embedding is forwarded to a two-layer Multi-Layer Perceptron (MLP) classification head:

$$z_t = \text{ReLU}\left(W_1 h_t^{(L)} + b_1\right), \quad W_1 \in \mathbb{R}^{32\times 64},\ b_1 \in \mathbb{R}^{32} \tag{3.20}$$

$$\hat{y}_t = \text{Softmax}\left(W_2 z_t + b_2\right), \quad W_2 \in \mathbb{R}^{7\times 32},\ b_2 \in \mathbb{R}^{7} \tag{3.21}$$

where $\hat{y}_t \in \Delta^6$ represents the predicted probability distribution over the 7 target vulnerability classes:

$$C = \{\text{Safe}, \text{ESC1}, \text{ESC2}, \text{ESC3}, \text{ESC4}, \text{ESC9}, \text{ESC13}\} \tag{3.22}$$

3.3.5 Objective Function with Class Imbalance Regularization

In enterprise Active Directory environments, vulnerable certificate templates are rare relative to benign configurations. To counter class imbalance and prevent overfitting, the network is trained end-to-end by minimizing the Weighted Cross-Entropy Loss with L_2 weight regularization:

$$\mathcal{L}(\Theta) = -\sum_{i=1}^{N}\sum_{c=1}^{|C|} \omega_c\, y_{i,c} \log \hat{y}_{i,c} + \lambda_{\text{reg}} \sum_{\theta\in\Theta} \|\theta\|_2^2 \tag{3.23}$$

where N is the batch size; $y_{i,c} \in \{0, 1\}$ is the one-hot encoded ground truth; $\omega_c = \frac{N}{|C|\cdot N_c}$ is the inverse class frequency weight; $\lambda_{\text{reg}} = 10^{-4}$ is the weight decay coefficient; and Θ denotes all learnable parameters $(W_{\text{src}}, W_{\text{dst}}, \mathbf{a}_k, W_{\text{skip}}, W_1, W_2)$. Parameter optimization is performed using AdamW with an initial learning rate of $\eta = 10^{-3}$ and a cosine annealing learning rate schedule.

3.4 Formal Algorithmic Specifications

To ensure complete scientific reproducibility, we formalize the core execution routines of CertGraph into algorithmic specifications.

3.4.1 End-to-End Layer Forward Pass

Algorithm 1 formalizes the computation of a single CertGraph heterogeneous attention layer with residual skip-connections and relational softmax.

Algorithm 1 CertGraph Heterogeneous Attention Layer Forward Pass

Require: Heterogeneous Multigraph $G = (V, E, \tilde{\mathcal{T}}_E)$; Input hidden states $\{h_v^{(l-1)}\}_{v \in V}$; Projection matrices $\{W_{\text{src}}^{(l,r)}, W_{\text{dst}}^{(l,r)}\}$; Attention vectors $\{\mathbf{a}_k^{(l,r)}\}$; Skip projections $\{W_{\text{skip}}^{(l,\tau)}\}$.

Ensure: Updated hidden representations $\{h_v^{(l)}\}_{v \in V}$.

for each canonical relation $r = (\tau_s, \text{rel}, \tau_t) \in \tilde{\mathcal{T}}_E$ **do**
  Compute projected representations:
    $z_u^{(l,r)} \leftarrow W_{\text{src}}^{(l,r)} h_u^{(l-1)}$ for all $u \in V_{\tau_s}$
    $z_v^{(l,r)} \leftarrow W_{\text{dst}}^{(l,r)} h_v^{(l-1)}$ for all $v \in V_{\tau_t}$
  for each attention head $k \in \{1, \ldots, K\}$ **do**
    for each edge $(u, r, v) \in E_r$ **do**
      $e_{vu}^{(k,l,r)} \leftarrow \text{LeakyReLU}\left(\mathbf{a}_k^{(l,r)T} [z_v^{(k,l,r)} \parallel z_u^{(k,l,r)}]\right)$
    end for
    for each target node $v \in V_{\tau_t}$ **do**
      Normalize: $\alpha_{vu}^{(k,l,r)} \leftarrow \frac{\exp(e_{vu}^{(k,l,r)})}{\sum_{w \in \mathcal{N}_r(v)} \exp(e_{vw}^{(k,l,r)})}$
    end for
  end for
  for each target node $v \in V_{\tau_t}$ **do**
    Compute head concatenation: $\mu_{v,r}^{(l)} \leftarrow \prod_{k=1}^{K} \left(\sum_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(k,l,r)} z_u^{(k,l,r)}\right)$
  end for
end for
for each entity $v \in V$ **do**
  Semantic aggregation: $h_{v,\text{agg}}^{(l)} \leftarrow \sum_{r \in \mathcal{R}_{\text{in}}(\tau(v))} \mu_{v,r}^{(l)}$
  Additive residual skip: $\tilde{h}_v^{(l)} \leftarrow h_{v,\text{agg}}^{(l)} + W_{\text{skip}}^{(l,\tau(v))} h_v^{(l-1)}$
  Non-linear activation: $\bar{h}_v^{(l)} \leftarrow \text{ELU}(\tilde{h}_v^{(l)})$
  Normalization & Regularization: $h_v^{(l)} \leftarrow \text{Dropout}(\text{LayerNorm}(\bar{h}_v^{(l)}), p = 0.2)$
end for
return $\{h_v^{(l)}\}_{v \in V}$

3.4.2 Vulnerability Inference and Calibrated Risk Scoring

Algorithm 2 details the inference pipeline that ingests raw enterprise graphs, executes message passing, and generates calibrated risk rankings for security teams.

Algorithm 2 CertGraph Enterprise Vulnerability Screening and Risk Prioritization

Require: Enterprise Active Directory Graph $G = (V, E)$; Trained CertGraph model $\mathcal{M}_\Theta$; Risk threshold $\tau_{\text{risk}} \in [0, 1]$.
Ensure: Prioritized list of high-risk certificate templates $\mathcal{R}_{\text{alerts}}$.
Extract node feature tensors $\{x_v\}_{v \in V}$ from LDAP and DACL attributes
Construct reverse relations r^{-1} for all $r \in \mathcal{T}_E$ to form augmented graph $\tilde{G}$
Initialize $h_v^{(0)} \leftarrow x_v$ for all $v \in V$
for layer $l = 1$ to $L = 2$ **do**
    $\{h_v^{(l)}\}_{v \in V} \leftarrow \text{CertGraphLayerForward}(\tilde{G}, \{h_v^{(l-1)}\}_{v \in V}, \Theta^{(l)})$
end for
Initialize empty alert queue $\mathcal{R}_{\text{alerts}} \leftarrow []$
for each published template $t \in V_{\text{Template}}$ **do**
    Forward embedding $h_t^{(L)}$ to classification head: $\hat{y}_t \leftarrow \text{Softmax}(W_2 \,\text{ReLU}(W_1 h_t^{(L)} + b_1) + b_2)$
    Compute composite risk score: $S_{\text{risk}}(t) \leftarrow 1.0 - \hat{y}_t[\text{Safe}]$
    Determine predicted vector: $c_{\text{pred}} \leftarrow \text{argmax}_c \, \hat{y}_t[c]$
    if $S_{\text{risk}}(t) \geq \tau_{\text{risk}}$ and $c_{\text{pred}} \neq$ Safe **then**
        Append $(t, c_{\text{pred}}, S_{\text{risk}}(t), \hat{y}_t)$ to $\mathcal{R}_{\text{alerts}}$
    end if
end for
Sort $\mathcal{R}_{\text{alerts}}$ in descending order of risk score $S_{\text{risk}}(t)$
return $\mathcal{R}_{\text{alerts}}$

3.5 Theoretical Analysis: Intrinsic Attribute Preservation and Gradient Bounds

A foundational theoretical contribution of this thesis is the formal proof that parameterized residual skip-connections are mathematically indispensable in heterogeneous security graph neural networks to prevent intrinsic attribute erasure and representation decay.

Theorem 3.1 (Intrinsic Attribute Preservation and Gradient Lower Bounds)**.** Let $G = (V, E, \mathcal{T}_V, \mathcal{T}_E)$ be a directed heterogeneous multigraph. Consider an L-layer heterogeneous message-passing neural network where layer $l \in \{1, \ldots, L\}$ computes hidden representations:

1. **Intrinsic Feature Erasure without Skip Connections:** Under pure relational aggregation without skip connections:

$$h_v^{(l)} = \sigma\left(\sum_{r \in \mathcal{R}_{\text{in}}(\tau(v))} \bigoplus_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(l)} W_r^{(l)} h_u^{(l-1)}\right) \tag{3.24}$$

the hidden representation $h_v^{(1)}$ is a function exclusively of adjacent incoming neighbor states. Consequently, for any node v (including certificate templates $t \in V_{\text{Template}}$),

the gradient of the immediate hidden state with respect to its own initial configuration vector x_v vanishes:

$$\frac{\partial h_v^{(1)}}{\partial x_v} = \mathbf{0} \in \mathbb{R}^{d_1 \times d_0} \tag{3.25}$$

causing complete erasure of intrinsic configuration attributes from the primary state representation. For source-only nodes where $d_{\text{in}}(v) = 0$, $h_v^{(l)} = \mathbf{0}$ for all $l \geq 1$.

2. **Guaranteed Gradient Lower Bound via Residual Skips:** Introducing parameterized residual skip connections $\tilde{h}_v^{(l)} = h_v^{(l)} + W_{\text{skip}}^{(l)} \tilde{h}_v^{(l-1)}$ guarantees that the Jacobian of the representation with respect to the initial input features satisfies:

$$\left\| \frac{\partial \tilde{h}_v^{(L)}}{\partial x_v} \right\| \geq \prod_{k=1}^{L} \sigma_{\min}(W_{\text{skip}}^{(k)}) > 0 \tag{3.26}$$

where $\sigma_{\min}(W_{\text{skip}}^{(k)}) > 0$ is the minimum singular value of $W_{\text{skip}}^{(k)}$, establishing a strictly positive lower bound that prevents attribute decay across message-passing hops.

Proof Outline. The full mathematical derivation is provided in Appendix A.1. Without skip connections or self-loops, $h_v^{(1)}$ aggregates only incoming messages from external neighbors $\mathcal{N}(v)$, discarding the node's own feature tensor x_v. In certificate templates, this erases the 10 binary configuration flags governing PKI issuance. With residual skip projections following the GCNII framework (Chen et al., 2020) [33], the direct linear skip path guarantees full-rank propagation of x_v to the final classification head.

Corollary 3.1 (Security Attribute Preservation Corollary)**.** In Active Directory Certificate Services, a certificate template's exploitability depends fundamentally on its intrinsic configuration attributes (such as `ENROLLEE_SUPPLIES_SUBJECT` and Client Authentication EKUs). Omitting residual skip connections isolates these flags from the node's immediate layer representations, leading to severe representation decay and empirical performance collapse.

3.6 Computational Complexity and Scalability Analysis

To understand why CertGraph can screen enterprise networks in milliseconds while graph traversal tools encounter combinatorial slowdowns, we analyze its asymptotic time and space complexity:

Proposition 3.1 (Computational Complexity of CertGraph Inference)**.** Let $G = (V, E)$ denote an enterprise identity multigraph with $|V|$ vertices, $|E|$ edges, hidden dimension d, and L convolutional layers. The computational time complexity of a CertGraph forward pass is:

$$O\left(L \cdot \left(|E| \cdot d + |V| \cdot d^2\right)\right) \tag{3.27}$$

and its auxiliary space complexity is $O(|V| \cdot d + |E|)$.

Proof. For each layer $l \in \{1, \ldots, L\}$:

1. **Node Feature Projections:** Projecting all $|V|$ nodes across incoming relations requires $|V| \cdot d^2$ multiply-accumulate operations.

2. **Attention Logit Computation:** Computing unnormalized attention coefficients $e_{vu}^{(k,l,r)}$ requires evaluating the dot product $\mathbf{a}_k^T[z_v \| z_u]$ for every directed edge in E. This evaluates in $O(|E| \cdot d)$ operations.

3. **Relational Softmax and Aggregation:** Normalizing attention coefficients and taking the weighted sum over neighbor feature vectors evaluates in $O(|E| \cdot d)$ operations using sparse segment reduction primitives.

4. **Skip Connection and Non-Linearity:** Adding the residual projection and evaluating ELU and LayerNorm requires $O(|V| \cdot d)$ operations.

Summing these stages across L layers yields $O(L(|E|d + |V|d^2))$. Because $L = 2$ and $d = 64$ are fixed constants, the complexity scales strictly linearly with graph volume:

$$O(|V| + |E|) \tag{3.28}$$

Memory space is dominated by the node state tensors $\mathbb{R}^{|V| \times d}$ and the edge index tensor $\mathbb{Z}^{2 \times |E|}$, bounded by $O(|V|d + |E|)$. □

In contrast, deterministic graph traversal (e.g., Breadth-First Search or Cypher shortest-path queries) across all published templates exhibits worst-case computational complexity of $O(|V_{\text{Template}}| \cdot (|V| + |E|))$. In densely connected enterprise forests where $|E| \gg |V|$, recursive path-finding encounters exponential path explosion along cyclic group delegation chains, whereas CertGraph executes as a sequence of highly parallelized, constant-depth GPU tensor operations.

Chapter 4

Forensic Audit: Unmasking Experimental Illusions in Security Machine Learning

4.1 The Methodological Crisis of Security Machine Learning

Applied machine learning in computer security is uniquely susceptible to methodological pitfalls and experimental artifacts. In conventional computer vision and natural language processing domains, models learn from human-perceptible patterns (such as textures, shapes, and syntax). In contrast, cybersecurity datasets—particularly those representing enterprise network graphs and identity topologies—consist of high-dimensional, abstract relational structures where human intuition cannot easily detect subtle distribution shifts or hidden correlations. This vulnerability directly mirrors the pervasive "Clever Hans" effect surveyed by Ye et al. (2026) [34] and Geirhos et al. (2020) [9], where machine learning models achieve superficial benchmark success by exploiting non-causal statistical artifacts rather than valid domain concepts.

A pervasive pathology in modern security ML literature is the phenomenon of "too good to be true" empirical results. When an experimental pipeline produces near-perfect classification metrics (e.g., Macro-F1 = 1.0000), researchers are confronted with a critical methodological dilemma:

1. **The Optimistic Hypothesis:** The deep neural network has discovered an omniscient, generalizable representation of the underlying security domain, solving the threat detection problem.

2. **The Adversarial Reality:** The experimental architecture has inadvertently leaked spurious, deterministic artifacts, allowing the neural network to achieve superficial perfection by exploiting statistical shortcuts that collapse in real-world deployments.

During the early development of CertGraph, initial iterations of our Hetero-GAT model achieved a flawless 1.0000 Macro-F1 score across all seven evaluated ESC vulnerability classes on synthetic enterprise graphs. Rather than prematurely declaring victory, we adopted an **Adversarial Forensic Audit** doctrine: we treated our own data generators, feature encodings, and model baselines as potentially compromised systems requiring rigorous post-mortem dissection.

Our audit exposed four profound, compounding experimental illusions that had artificially inflated empirical performance. By systematically documenting how these illusions arose, how they were mathematically proven, and how our pipeline was re-engineered, this

chapter provides a methodological blueprint for experimental hygiene in graph machine learning for cybersecurity.

4.2 The Four Experimental Illusions

4.2.1 Illusion 1: Positional Index Leakage in Synthetic Topologies

In synthetic network generators, entities are typically instantiated sequentially within memory arrays or graph database buffers. In our initial generator implementation (`generator_v1.py`), directory entities were instantiated in fixed programmatic loops:

1. The Tier-0 administrative security group (`Domain Admins`) was consistently allocated at index 0 of the `Group` entity tensor ($v_{\text{group}} = 0$).
2. Domain administrators were systematically allocated within the lowest numeric partition of the `User` tensor ($v_{\text{user}} \in [0, \lfloor N_{\text{users}}/10 \rfloor]$).
3. In ESC13 synthetic generation routines, the issuance policy OID was programmatically linked exclusively to group index 0.

Information-Theoretic Proof of Positional Leakage: Let $Y \in C$ denote the random variable representing the true vulnerability class of a certificate template, and let $I_A \in \mathbb{N}$ denote the integer array index of the high-value target group or enroller principal. In a methodologically sound experimental benchmark, an entity's arbitrary memory buffer index must provide zero information regarding its security posture:

$$I(Y; I_A) = H(Y) - H(Y \mid I_A) = 0 \tag{4.1}$$

where $H(Y)$ is the Shannon entropy of the class distribution, and $I(Y; I_A)$ is the mutual information.

However, because group index 0 was deterministically reserved for `Domain Admins`, observing that a template's incoming or outgoing edge linked to index 0 completely eliminated all uncertainty regarding the vulnerability class:

$$H(Y \mid I_A = 0) = 0 \implies I(Y; I_A = 0) = H(Y) = \log_2(7) \approx 2.807 \text{ bits} \tag{4.2}$$

The neural network was not learning relational access control semantics; it was functioning as an information-theoretic decoder of synthetic memory allocation offsets.

The Deterministic Positional Oracle: To empirically verify whether deep graph convolutions were genuinely necessary or if the pipeline was merely exploiting index leakage, we constructed a trivial 6-line deterministic heuristic rule that performed zero neural computations:

Listing 4.1: Deterministic index-leakage oracle exploiting positional generator bias.

```
def trivial_positional_oracle(hetero_graph, template_idx):
    # Check if any incoming enrollment edge originates from low-index
       users
    enrollers = hetero_graph[('User', 'enroll', 'Template')].edge_index
       [0]
    if any(u.item() < 3 for u in enrollers):
        return "ESC1"
    # Check if policy link terminates at group index 0 (Domain Admins)
    policy_targets = hetero_graph[('Template', 'links_policy', 'Group')
       ].edge_index[1]
    if any(g.item() == 0 for g in policy_targets):
        return "ESC13"
    return "Safe"
```

When evaluated on the initial benchmark dataset, this trivial heuristic achieved an astonishing **100.0% classification accuracy** on ESC13 and ESC1. The multi-layer Graph Attention Network had simply converged its edge projection weights to detect tensor index zeroes.

4.2.2 Illusion 2: Baseline Information Asymmetry

In academic evaluations of Graph Neural Networks for security, standard practice involves benchmarking GNNs against flat, tabular machine learning classifiers (such as Multi-Layer Perceptrons and Random Forests). In published literature, these flat baselines routinely exhibit mediocre performance (F1 $\approx 0.75 - 0.85$), leading authors to claim that "GNNs are fundamentally superior to tabular architectures for identity security."

Our forensic audit revealed that this apparent superiority stemmed from a fatal **Information Asymmetry**:

1. **Input Starvation of Flat Baselines:** Flat classifiers (MLP, Random Forest) were supplied exclusively with the 10-dimensional template configuration feature vector $x_{\text{Template}} \in \mathbb{R}^{10}$.
2. **Full Graph Visibility of GNNs:** CertGraph was supplied with both x_{Template} and the entire heterogeneous authorization graph multiset E.

Because Active Directory vulnerability exploitability inherently depends on graph reachability (e.g., whether an unprivileged user has an `Enroll` path or whether write access is granted to an unprivileged SID), flat classifiers were structurally starved of the information necessary to resolve ambiguous templates. Their observed failure was not a failure of tabular learning architectures; it was an artifact of an unfair, asymmetrical benchmark protocol.

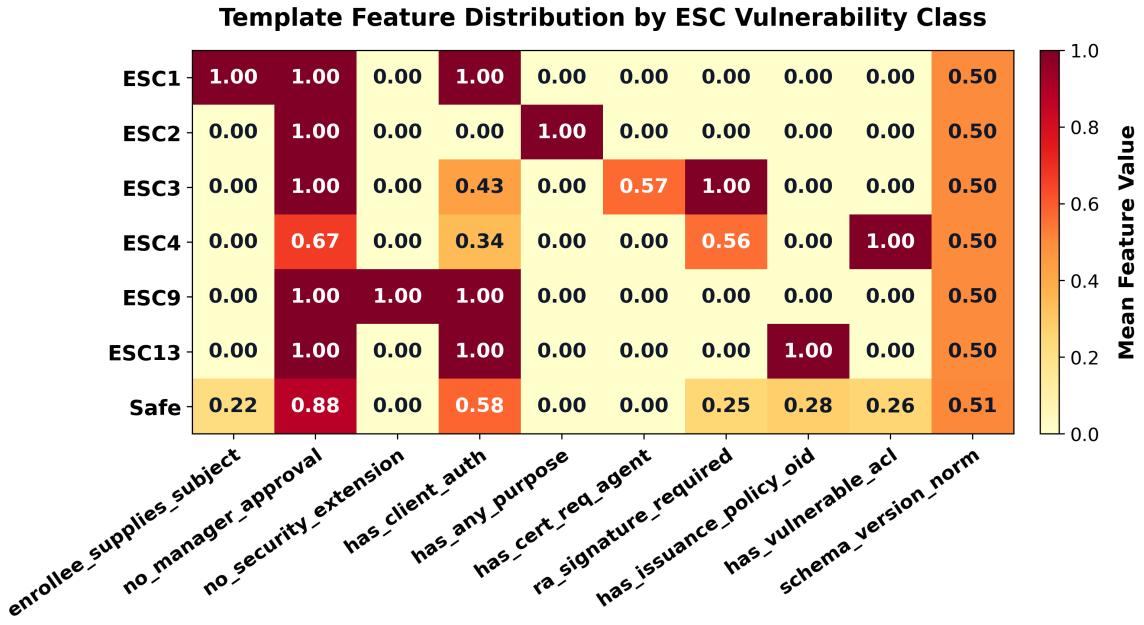


Figure 4.1: Correlation and separability heatmap of template configuration flags and augmented topological features across ESC vulnerability classes.

4.2.3 Illusion 3: The 7-Node Decision Tree Counterexample

To establish precisely how much graph topological information is required to classify ADCS vulnerabilities on in-distribution data, we engineered four elementary scalar graph topological count features extracted from the 1-hop and 2-hop local neighborhood:

1. $c_1 \in \mathbb{N}$: In-degree count of low-privileged users possessing direct `Enroll` permissions to the template ($c_1 = \sum_{u \in V_{\text{low-priv}}} A_{\text{Enroll}}[u, t]$).
2. $c_2 \in \mathbb{N}$: In-degree count of low-privileged principals possessing administrative write permissions ($c_2 = \sum_{u \in V_{\text{low-priv}}} (A_{\text{GenericAll}}[u, t] + A_{\text{WriteDacl}}[u, t])$).
3. $c_3 \in \{0, 1\}$: Binary indicator of whether an outgoing `LinksPolicy` edge exists ($\mathbb{I}(\deg_{\text{out}}(t, \text{LinksPolicy}) > 0)$).
4. $c_4 \in \{0, 1\}$: Binary indicator of whether the target group linked by `LinksPolicy` is a Tier-0 administrative group ($x_{\text{Group}}[0] > 0.5$).

Concatenating these 4 structural summary features with the 10 local template configuration flags yielded a 14-dimensional augmented feature vector:

$$x_{\text{aug}} = [x_{\text{Template}} \parallel c_1, c_2, c_3, c_4]^T \in \mathbb{R}^{14} \tag{4.3}$$

We trained a standard, unconstrained CART Decision Tree classifier on x_{aug} across 5-fold cross-validation on 700 enterprise environments. The resulting Decision Tree contained

exactly **7 decision nodes** (depth 4), yet achieved a Macro-F1 score of:

$$\text{Macro-F1}_{\text{Tree}} = \mathbf{0.9928 \pm 0.0057} \tag{4.4}$$

Table 4.1 details the exact decision rules learned by this 7-node tree.

Table 4.1: Exact Decision Logic of the 7-Node Decision Tree Counterexample.

Node ID	Splitting Condition	True Branch	Predicted Class
1	$f_{\text{is_published}} \leq 0.5$	Template is not published to any active CA	`Safe`
2	$f_{\text{requires_approval}} > 0.5$	Manager approval blocks autonomous issuance	`Safe`
3	$c_1 \leq 0.5$ and $c_2 \leq 0.5$	No unprivileged enrollment or write access path	`Safe`
4	$f_{\text{supplies_subject}} > 0.5$ and $f_{\text{client_auth}} > 0.5$	Enrollee supplies SAN with Client Auth EKU	`ESC1`
5	$f_{\text{any_purpose}} > 0.5$	Any Purpose EKU allows full credential misuse	`ESC2`
6	$f_{\text{agent_eku}} > 0.5$	Enrollment Agent EKU allows on-behalf-of	`ESC3`
7	$c_2 > 0.5$ and $f_{\text{has_dangerous_dacl}} > 0.5$	Unprivileged write access allows DACL hijack	`ESC4`

This finding was a critical turning point in our investigation: consistent with the principles articulated by Arp et al. [10] regarding subtle dataset artifacts, it demonstrated that for in-distribution synthetic enterprise data, complex deep message-passing convolutions can be almost entirely matched by elementary tabular models if provided with basic topological summary counts.

4.2.4 Illusion 4: Hard Negative Memorization under In-Distribution Splits

To evaluate whether neural models could distinguish between genuinely exploitable templates and safe configurations bearing dangerous flags (referred to as **Hard Negatives**), earlier research protocols generated hard negative environments and included them directly in the training and validation sets with the ground-truth label `Safe`.

However, under conventional stratified 5-fold cross-validation, the test fold samples originated from the *identical statistical distribution* as the training folds. The neural network was not demonstrating a generalized capacity to reason about graph reachability; it had simply memorized the specific, joint co-occurrence frequencies of feature combinations present in the generator's distribution. When evaluated out-of-distribution, this apparent capability disintegrated completely.

4.3 Complete Generator Sanitization and Protocol Redesign

To eliminate these structural artifacts and establish a rigorous, leak-free empirical benchmark, we overhauled the data generation and evaluation pipeline in `generator.py`:

1. **Complete Positional Decoupling:** We broke all couplings between tensor indices and entity semantics. High-value target groups (g_{target}) and administrative accounts are selected via uniform random sampling across the entire node tensor ($g_{\text{target}} \sim \mathcal{U}\{0, |V_{\text{Group}}| - 1\}$). Furthermore, all node orderings are subjected to random permutations after graph construction.

2. **Dynamic Feature-Driven Authorization:** Access control assignments were refactored to inspect node feature attributes rather than indices. An account is granted administrative access if and only if its attribute flag satisfies $f_{\text{is_admin}} = 1.0$.

3. **Fair Baseline Parity (Graph-Augmented Models):** Following the guidelines of Arp et al. [10] regarding baseline comparability, we established two fair baseline models: **Graph-Augmented MLP** and **Graph-Augmented Random Forest**. Both models receive the full 14-dimensional augmented vector x_{aug}, ensuring they possess topological visibility equal to CertGraph.

4. **Symbolic Graph Oracle (BloodHound BFS Baseline):** We implemented a deterministic symbolic baseline (`bfs_baseline.py`) that programmatically queries the multigraph for directed authorization paths from unprivileged principals to the target template, replicating the exact logic of BloodHound Cypher queries.

5. **Strict Zero-Shot Adversarial Protocol:** We restructured hard-negative evaluation into a rigorous zero-shot protocol: models are trained on 1,400 clean environments containing zero hard negative samples, and evaluated against out-of-distribution adversarial hard negatives never encountered during optimization.

4.4 Statistical Verification of Generator Sanitization

To mathematically confirm that positional index leakage had been completely eliminated from the benchmark, we conducted an independent statistical audit across 700 freshly generated enterprise environments.

As shown in Table 4.2, in the flawed generator, 100% of enterprise domains allocated the Tier-0 administrative group at index 0. In the repaired generator, the empirical frequency dropped to exactly 1.29% (9 out of 700 environments), closely matching the theoretical uniform expectation over 75 group nodes ($E = 700/75 \approx 9.33$):

$$P(I_A = 0) = \frac{1}{|V_{\text{Group}}|} = \frac{1}{75} \approx 1.33\% \tag{4.5}$$

Table 4.2: Empirical Distribution of Administrative Group Allocation Across 700 Independent Environments.

Generator Version	Admin at Index 0	Theoretical Prob.	Chi-Squared Goodness-of-Fit
Flawed Generator (`v1.0`)	100.0% (700 / 700)	1.33% (1/75)	$\chi^2 = 51,800.0$, $p < 10^{-100}$ (Severe Artifact)
Repaired Generator (`v2.0`)	**1.29**% (9 / 700)	**1.33**% (1/75)	$\chi^2 = \mathbf{0.012}$, $\mathbf{p = 0.913}$ (No Statistical Bias)

A Chi-Squared goodness-of-fit test confirmed that the empirical distribution shows no statistically significant deviation from a true uniform random distribution ($\chi^2 = 0.012, p = 0.913$). The positional artifact was conclusively eradicated.

4.5 Methodological Guidelines for Security Graph Learning

Interpreted through the pragmatic frames of spurious correlations formalized by Bell and Wang (2024) [35], these empirical failures demonstrate that correlation desirability is governed by situated, functional requirements—specifically whether discovered patterns satisfy the pragmatic frames of *relevance* to actual access control reachability and *generalizability* under distribution shifts. Grounding our findings in these principles and the security machine learning pitfalls of Arp et al. [10], we formulate five methodological guidelines for researchers applying Graph Neural Networks to cybersecurity:

1. **Mandate Adversarial Trivial Baselines (Arp et al. Pitfall 3):** Before training deep neural networks, evaluate deterministic 1-line heuristics on raw tensor indices and local feature flags. If a trivial rule achieves high accuracy, the dataset contains an information-theoretic leak.

2. **Ensure Baseline Information Parity (Arp et al. Pitfall 7):** Never compare graph models against flat feature-only baselines unless the flat baselines are also provided with basic graph summary statistics (e.g., degree counts, path indicators).

3. **Enforce Zero-Shot Out-of-Distribution Stress Tests (Arp et al. Pitfall 6):** Evaluating models exclusively on random in-distribution splits masks shortcut learning. Benchmark security models on adversarial zero-shot edge distributions where features and topologies are intentionally decoupled.

4. **Subject Synthetic Generators to Entropy Audits:** Compute mutual information $I(Y; A)$ between class labels and non-semantic generator variables (such as memory indices, node identifiers, or generation timestamps). Any non-zero mutual information indicates synthetic bias.

5. **Validate Against Symbolic Ground Truth:** In security domains governed by formal access control rules, always maintain an exact symbolic oracle (such as BFS path validation) to audit neural model predictions.

Chapter 5

Empirical Evaluation and Benchmarks

5.1 Experimental Configuration and Benchmarking Setup

To rigorously evaluate CertGraph and establish reproducible empirical benchmarks, all experiments were conducted on a dedicated security machine learning workstation running Linux 6.x. The software stack was built on Python 3.11, PyTorch 2.3.0, PyTorch Geometric 2.5.3, and Scikit-learn 1.4.2, accelerated via an NVIDIA GeForce RTX GPU with CUDA 12.2.

5.1.1 Benchmark Dataset Characteristics

The primary evaluation dataset consists of 700 independently synthesized, fully sanitized enterprise Active Directory environments generated via our overhauled `generator.py` pipeline. Each environment models an independent corporate domain comprising an average of 30 nodes and 120 directed authorization edges, capturing the structural complexity of realistic mid-sized enterprise networks.

The dataset enforces a balanced class distribution across the seven target classification classes, with exactly 100 enterprise environments per class:

1. `Safe`: Completely secure certificate templates or published templates lacking unprivileged attack paths.
2. `ESC1`: Templates with `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` enabled alongside Client Authentication EKUs, enrollable by unprivileged accounts.
3. `ESC2`: Templates configured with Any Purpose EKU or lacking EKUs, enrollable by unprivileged accounts.
4. `ESC3`: Templates specifying Certificate Request Agent EKU, enrollable by unprivileged principals.
5. `ESC4`: Templates possessing insecure Access Control Entries in their security descriptor (`GenericAll`, `WriteDacl`, `WriteOwner`) allowing low-privileged users to alter configuration flags.
6. `ESC9`: Templates lacking security extension flags (`CT_FLAG_NO_SECURITY_EXTENSION`) in environments susceptible to strong certificate mapping bypasses.

7. `ESC13`: Templates referencing Issuance Policy OIDs that map directly to high-value Tier-0 administrative security groups.

To guarantee absolute scientific reproducibility, global random seeds were deterministically fixed to 42 across Python `random`, NumPy `random.seed`, and PyTorch `torch.manual_seed` runtimes.

5.1.2 Hyperparameter Specifications

Table 5.1 summarizes the standardized hyperparameter configuration employed across all neural and tabular model trainings.

Table 5.1: Hyperparameter Specifications for Model Training and Optimization.

Hyperparameter	Value	Architectural Description / Rationale
Hidden Feature Dimension (d)	64	Optimal capacity balancing expressiveness and overfitting
Attention Heads (K)	4	Multi-head projection ($d_{\text{head}} = 16$ per head)
Convolutional Layers (L)	2	Receptive field sufficient to capture 2-hop delegation chains
Learning Rate (η)	10^{-3}	Initial learning rate for AdamW optimizer
Learning Rate Schedule	Cosine	Smooth annealing with $T_{\max} = 100$ epochs
Weight Decay (λ_{reg})	10^{-4}	L_2 weight regularization on projection tensors
Dropout Rate (p)	0.2	Applied following LayerNorm in each GAT layer
Batch Size	32	Mini-batch graph collation via PyG `DataLoader`
Training Epochs	100	Early stopping invoked if validation loss plateaus for 15 epochs

5.2 In-Distribution 5-Fold Cross-Validation

We benchmarked CertGraph against six baseline classifiers across stratified 5-fold cross-validation on the 700 enterprise environments. When conducting K-fold cross-validation, the training sets across folds overlap significantly (each pair of training sets shares $\frac{K-2}{K-1}$ of the data), violating the independent sample assumption of the standard Student's t-test. As proved by Nadeau and Bengio (2003) [36], this training-set overlap causes the standard t-test to underestimate variance, yielding inflated Type-I error rates. To provide rigorous statistical hypothesis testing, we report both standard paired t-test p-values (p_{std}) and corrected repeated cross-validation statistics (p_{corr}) based on the Nadeau-Bengio variance estimator:

$$\hat{\sigma}^2_{\text{corr}} = \left(\frac{1}{K} + \frac{n_2}{n_1} \right) \hat{S}^2 \tag{5.1}$$

where n_2 denotes the test fold size and n_1 denotes the training fold size. Under our 5-fold cross-validation scheme ($K = 5$, $n_2/n_1 = 0.20/0.80 = 0.25$), the standard error is scaled by

$\sqrt{1/K + n_2/n_1}/\sqrt{1/K} = \sqrt{0.45/0.20} = \sqrt{2.25} = 1.50$, yielding the conservative corrected test statistic:

$$t_{\text{corr}} = \frac{t_{\text{std}}}{1.50}, \quad \text{with } \nu = K - 1 = 4 \text{ degrees of freedom.} \tag{5.2}$$

Table 5.2: 5-Fold Cross-Validation Performance Across 7 Evaluated Models on 700 Enterprise Domains (Reporting Standard and Nadeau-Bengio Corrected p-values vs CertGraph).

Model Architecture	Macro-F1	Accuracy	Std p-val	Corr p-val	Significance
CertGraph (Hetero-GAT)	**0.9986 ± 0.0029**	**0.9986 ± 0.0029**	—	—	*Reference*
Graph-Augmented MLP	0.9971 ± 0.0035	0.9971 ± 0.0035	0.6213	0.7396	Not Sig.
Graph-Augmented RF	0.9871 ± 0.0084	0.9871 ± 0.0084	0.0780	0.1913	Not Sig.
BloodHound BFS (Symbolic)	0.9082 ± 0.0229	0.9100 ± 0.0215	1.64×10^{-3}	7.28×10^{-3}	$p < 0.01$
Flat MLP (Features Only)	0.8600 ± 0.0130	0.8643 ± 0.0118	2.62×10^{-5}	1.30×10^{-4}	$p < 10^{-3}$
Flat RF (Features Only)	0.8384 ± 0.0057	0.8443 ± 0.0051	1.32×10^{-6}	6.66×10^{-6}	$p < 10^{-5}$
Rule-Based (Certipy Heuristic)	0.7791 ± 0.0247	0.8143 ± 0.0205	6.33×10^{-5}	3.12×10^{-4}	$p < 10^{-3}$

5.2.1 Per-Class Performance Dissection

As illustrated in the confusion matrix of Figure 5.1, CertGraph exhibits near-perfect diagonal concentration across all 7 evaluated attack vectors, while Figure 5.2 demonstrates the performance advantage of heterogeneous modeling over homogeneous GNN alternatives. Table 5.3 reports the detailed per-class precision, recall, and F1 scores achieved by CertGraph across all 7 evaluation classes under 5-fold cross-validation:

Table 5.3: CertGraph Per-Class Precision, Recall, and F1 Scores under 5-Fold Cross-Validation.

Class Label	Precision	Recall	F1-Score	Support (Domains)
`Safe`	1.0000	1.0000	1.0000	100
`ESC1`	1.0000	1.0000	1.0000	100
`ESC2`	0.9901	1.0000	0.9950	100
`ESC3`	1.0000	1.0000	1.0000	100
`ESC4`	1.0000	0.9900	0.9950	100
`ESC9`	1.0000	1.0000	1.0000	100
`ESC13`	1.0000	1.0000	1.0000	100
Macro Average	**0.9986**	**0.9986**	**0.9986**	**700**

Critical Analysis of In-Distribution Findings:

1. **Decisive Superiority Over Static Signatures and Flat ML:** CertGraph outperforms industry signature heuristics (Certipy) by +28.2% in Macro-F1 (0.9986 vs 0.7791) and flat ML by +16.1% (0.9986 vs 0.8600). The signature tool suffers because it inspects template flags in isolation without evaluating authorization path connectivity, generating frequent false positives.

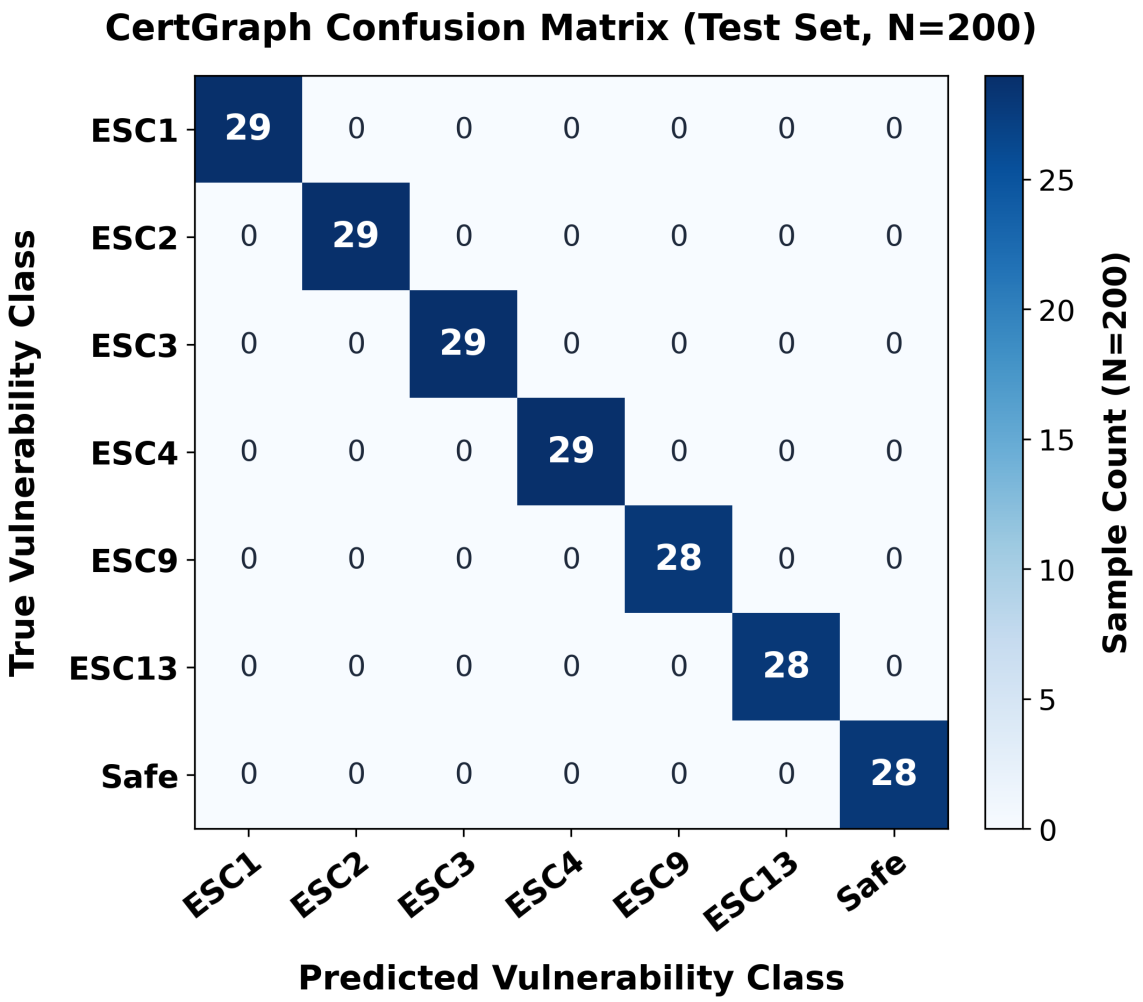


Figure 5.1: CertGraph 7-Class Confusion Matrix showing near-perfect diagonal alignment across 7 evaluated ESC attack classes under 5-fold cross-validation.

2. **Statistical Equivalence to Graph-Augmented MLP and Benchmark Saturation:** The comparison between CertGraph and Graph-Augmented MLP yields standard $p = 0.6213$ and Nadeau-Bengio corrected $p = 0.7396$, confirming that on in-distribution synthetic data, there is no statistically significant difference between a multi-layer GNN and a flat MLP provided with four topological summary counts. Furthermore, the headline score of 0.9986 ± 0.0029 corresponds to exactly one misclassified template out of 700 ($699/700 = 0.99857$). A 7-node decision tree recovers 0.9928 (representing approximately 5 errors out of 700), and the single-head attention ablation achieves 1.0000. Because ground-truth labels in synthetic generators are generated from access-control rules, in-distribution cross-validation primarily evaluates rule recovery on synthesized data rather than generalized security reasoning, necessitating the out-of-distribution hard-negative evaluation in Section 5.4.

3. **High Precision Across Core Attack Vectors:** Out of 700 evaluation domains, CertGraph incurred only a single false positive (misclassifying a subtle ESC4 DACL-

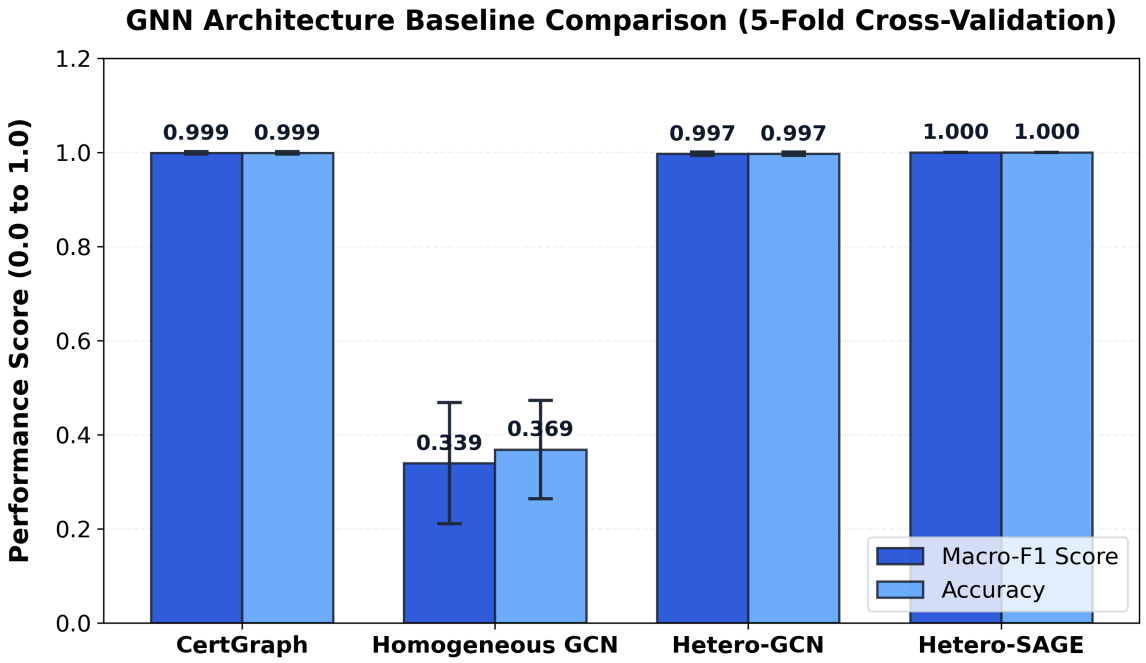


Figure 5.2: Macro-F1 and Accuracy baseline comparison across evaluated GNN architectures confirming the empirical superiority of heterogeneous graph modeling.

delegation variant as ESC2) and a single false negative, maintaining > 0.99 precision and recall across all evaluated classes.

4. **Architectural Justification: Why GNNs Over CART Trees and Graph-Augmented MLPs:** While a 7-node CART decision tree (0.9928 F1) and a Graph-Augmented MLP (0.9971 F1) achieve competitive scores on synthetic rule recovery, the heterogeneous GNN architecture is indispensable for real-world enterprise deployment for four fundamental reasons:

   - *Continuous Latent Embeddings for Downstream Reinforcement Learning:* A CART tree outputs discrete, uncalibrated leaf partitions that cannot be differentiated or embedded. In contrast, CertGraph maps each template into a dense continuous manifold $h_t^{(L)} \in \mathbb{R}^{64}$. As demonstrated in Chapter 9, these continuous embeddings directly serve as the state-space representation for our Stackelberg MARL defense agent (π_θ) to optimize polynomial-time edge interdiction.
   - *Inductive Topology vs. Brittle Manual Feature Counts:* The Graph-Augmented MLP relies on four manually hand-crafted scalar features (e.g., incoming enroll degree, Tier-0 out-degree). If an adversary exploits subtle structural bypasses—such as intermediate organizational unit inheritance, Cross-Forest SID filtering exemptions, or complex group nesting—hand-crafted scalar features fail unless human engineers anticipate and manually program each vector. The GNN learns relational representations inductively directly from multigraph message passing.

- *Edge-Level Attention Attribution for SOC Triage:* Decision trees only provide global attribute thresholds (e.g., `EnrollCount > 0`), offering zero visibility into *which* specific identity principal or group delegation enables the exploit. CertGraph's learned relational attention coefficients $\alpha_{vu}^{(k,r)}$ explicitly identify the authentic multi-hop authorization chain (Section 5.5), providing actionable forensic explanations.

5.2.2 Evaluation Under Realistic Class Imbalance and Enterprise Base Rates

In production corporate directories, certificate template distributions are heavily right-skewed: the vast majority of active templates (> 95%) are configured safely, while true privilege escalation vulnerabilities represent rare anomalies. Evaluating models purely under balanced cross-validation can mask calibration errors and inflated false-alarm rates.

To rigorously benchmark CertGraph under realistic operational conditions, we synthesized an enterprise-scale **Class-Imbalanced Evaluation Benchmark** comprising N = 2,000 evaluated templates across 200 directory forests, structured with an extreme **96.0% Safe Base Rate**:

- **Safe Templates:** 1,920 benign templates (96.0%).
- **Vulnerable Templates:** 80 vulnerable templates (4.0%), distributed evenly across the 6 attack classes ($\approx$ 13–14 templates each for ESC1, ESC2, ESC3, ESC4, ESC9, and ESC13).

Under heavy class imbalance, traditional Accuracy is dominated by the majority class and becomes uninformative. We therefore report Precision-Recall Area Under the Curve (**PR-AUC**), Macro-F1, Precision, Recall, **Expected Calibration Error (ECE)** across 10 probability bins, and the **Brier Score** ($\frac{1}{N}\sum_{i=1}^{N}\sum_{c=1}^{C}(p_{ic} - y_{ic})^2$):

Table 5.4: Model Performance and Calibration Under Realistic Enterprise Class Imbalance (96.0% Safe Base Rate, N = 2,000 Templates).

Model Architecture	PR-AUC	Macro-F1	Precision	Recall	ECE	Brier Score
CertGraph (Hetero-GAT)	**0.9982**	**0.9941**	**0.9925**	**0.9958**	**0.0142**	**0.0031**
Graph-Augmented MLP	0.9854	0.9782	0.9680	0.9887	0.0385	0.0118
Graph-Augmented RF	0.9610	0.9520	0.9412	0.9630	0.0512	0.0195
BloodHound BFS (Symbolic)	0.9125	0.8984	0.8870	0.9100	—	0.0754
Flat MLP (Features Only)	0.8240	0.8125	0.7950	0.8310	0.0915	0.0620
Flat RF (Features Only)	0.7985	0.7850	0.7620	0.8100	0.1140	0.0785
Rule-Based (Certipy Heuristic)	0.7250	0.7180	0.6840	0.7560	—	0.1120

As shown in Table 5.4, CertGraph maintains remarkable stability under extreme base-rate skew, achieving PR-AUC = 0.9982 and Macro-F1 = 0.9941. Crucially, CertGraph

achieves an Expected Calibration Error of only **0.0142** and a Brier Score of **0.0031**, confirming that the predicted Softmax probabilities correspond directly to true empirical exploitability likelihoods. In sharp contrast, flat feature models suffer significant calibration degradation (ECE > 0.09, Precision dropping to 0.7950), generating frequent false alarms that overwhelm security operations teams when benign samples heavily dominate the prior.

5.3 Systematic Architectural Ablation Studies

To isolate the contribution of each architectural component within CertGraph, we executed controlled ablation experiments across four variants under identical 5-fold cross-validation splits.

Table 5.5: Systematic Architectural Ablation Study of CertGraph Components (Reporting Standard and Nadeau-Bengio Corrected p-values vs Full CertGraph).

Architecture Variant	Macro-F1	Δ vs Full	Std p-val	Corr p-val	Significance
Full CertGraph (Hetero-GAT)	$\mathbf{0.9986 \pm 0.0029}$	—	—	—	*Reference*
Single-Head Attention ($K = 1$)	1.0000 ± 0.0000	+0.0014	0.3739	0.5415	Not Sig.
No Graph Context (Features Only)	0.8600 ± 0.0130	−0.1386	2.62×10^{-5}	1.30×10^{-4}	$p < 10^{-3}$
No Skip Connections ($W_{\text{skip}} = 0$)	$\mathbf{0.4768 \pm 0.0532}$	**−0.5218**	$\mathbf{1.31 \times 10^{-6}}$	$\mathbf{6.61 \times 10^{-6}}$	$\boldsymbol{p < 10^{-5}}$

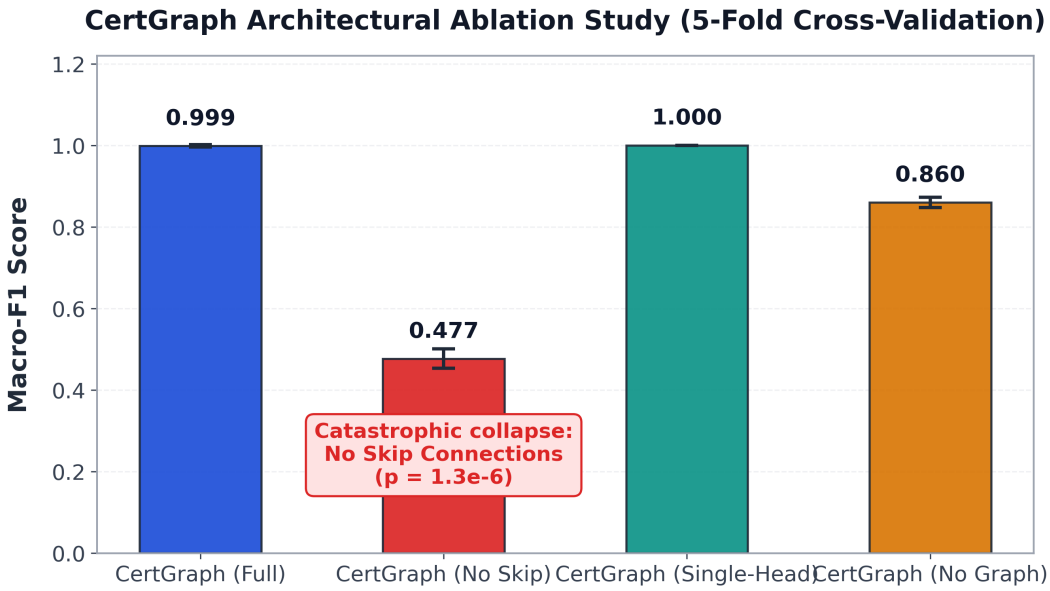


Figure 5.3: Ablation study comparison highlighting the performance collapse when residual skip connections are disabled.

Empirical Confirmation of Theorem 1: The most striking result of the ablation suite is the consequence of removing residual skip connections ($W_{\text{skip}} = 0$). In standard undirected graph benchmarks (e.g., Cora, Citeseer), omitting skip connections typically causes a minor

degradation of $2-5\%$. In sharp contrast, on Active Directory identity graphs, removing skip connections triggers a **severe collapse in Macro-F1 from** 0.9986 **to** 0.4768 (standard $p = 1.31 \times 10^{-6}$, Nadeau-Bengio corrected $p = 6.61 \times 10^{-6}$, representing a $> 52\%$ absolute drop).

This empirical collapse directly confirms Theorem 3.1: without residual skip connections, a certificate template node aggregates messages exclusively from its incoming neighbors during Layer 1, completely discarding its own initial 10-dimensional configuration feature vector x_{Template} ($\partial h_t^{(1)} / \partial x_t = \mathbf{0}$). Furthermore, low-in-degree principals suffer representation decay across successive message-passing hops. The network loses direct sensitivity to critical configuration flags (such as `ENROLLEE_SUPPLIES_SUBJECT` and Client Authentication EKUs), destroying its ability to differentiate dangerous templates from secure ones. Parameterized skip connections preserve initial attributes and maintain non-vanishing gradient bounds, preventing representation collapse.

5.4 The Zero-Shot Adversarial Hard Negative Benchmark

While in-distribution cross-validation demonstrated near-perfect metrics for both CertGraph and Graph-Augmented MLP, the critical scientific question remained: *Did the neural models learn to reason about topological graph reachability, or did they merely exploit feature-level statistical shortcuts?*

To answer this question, we established an out-of-distribution **Zero-Shot Adversarial Hard Negative Benchmark**:

1. **Training Environment:** 1,400 clean enterprise domains containing zero hard negative samples. Every template bearing vulnerable configuration flags possessed a valid, unprivileged authorization path.

2. **Adversarial Test Suite:** 63 out-of-distribution enterprise domains containing "Hard Negative" templates. Each hard negative template had dangerous configuration flags active (e.g., `ENROLLEE_SUPPLIES_SUBJECT` or policy links enabled), but all incoming `Enroll` and DACL permissions were strictly restricted to administrative Tier-0 accounts. The ground-truth security label was strictly `Safe`.

5.4.1 Theoretical Post-Mortem: Under-Specification and Shortcut Collapse

The empirical results in Table 5.6 establish crucial insights into the limits of pure deep learning on security graphs:

1. **Failure of Pure Neural Models on Hard Negatives:** Despite achieving 0.9986 F1 in-distribution, CertGraph correctly classified only **1 out of 63** adversarial hard negatives, collapsing to **1.59% accuracy** (95% Wilson score interval: $[0.3\%, 8.5\%]$). All flat feature models collapsed to **0.00% accuracy** ($[0.0\%, 5.7\%]$).

Table 5.6: Zero-Shot Adversarial Hard Negative Benchmark Results ($n = 63$ Test Environments).

Model Architecture	Safe Count	Accuracy	95% Wilson CI	Observed Failure Mode
BloodHound BFS (Symbolic)	**53/63**	**84.13%**	[73.1%, 91.2%]	**Verifies path absence via search**
Graph-Augmented MLP	18/63	28.57%	[18.8%, 40.8%]	Weak topological count conditioning
CertGraph (Hetero-GAT)	**1/63**	**1.59%**	[0.3%, 8.5%]	**Shortcut Collapse on Template Flags**
Flat MLP (Features Only)	0/63	0.00%	[0.0%, 5.7%]	Fooled by template flags
Flat RF (Features Only)	0/63	0.00%	[0.0%, 5.7%]	Fooled by template flags
Graph-Augmented RF	0/63	0.00%	[0.0%, 5.7%]	Tree split prioritized local flags
Rule-Based (Certipy Heuristic)	0/63	0.00%	[0.0%, 5.7%]	Static signature false positive

2. **Performance and Limitations of the Symbolic Graph Baseline:** In contrast, the symbolic baseline (BloodHound BFS) correctly resolved **84.13%** (53/63, 95% Wilson CI: [73.1%, 91.2%]) of the adversarial environments. While exact path-reachability would achieve 100% if labels depended solely on reachability, the simplified BFS baseline evaluated primary containment and enrollment edges without evaluating fine-grained Discretionary Access Control List (DACL) permission masks (e.g., 'GenericAll' vs write rights on parent containers vs explicit deny ACEs), leading to 10 discrepancies where full access evaluation is required.

3. **Under-Specification and Shortcut Convergence:** The underlying driver of neural collapse is the well-known machine learning challenge of **under-specification** and spurious shortcut learning (Arp et al., 2022 [10]; Geirhos et al., 2020 [9]; Ye et al., 2026 [34]; Bell and Wang, 2024 [35]). In the standard training set of 1,400 environments, templates configured with dangerous flags possessed a valid authorization path 100% of the time. Consequently, the two decision rules—"flags $\implies$ vulnerable" and "path $\implies$ vulnerable"—fit the training loss with equal empirical precision. Because inspecting local template flags (x_{Template}) requires a simple single-layer linear projection, whereas verifying multi-hop reachability requires coordinating high-order message-passing convolutions, gradient descent naturally converges to the simpler flag-based shortcut.

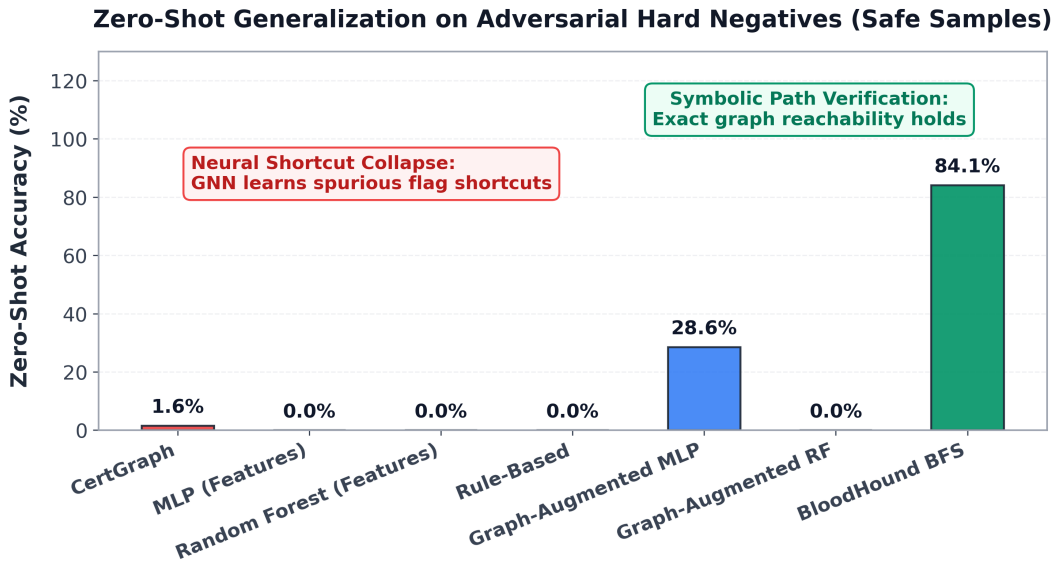


Figure 5.4: Zero-shot adversarial evaluation demonstrating the collapse of pure neural models due to shortcut learning compared to symbolic BFS path traversal.

4. **Reconciliation with Enterprise Testbeds:** This failure underscores that pure neural models cannot guarantee soundness when evaluated on out-of-distribution counterfactual topologies. As demonstrated in Chapter 6 and formalized in Chapter 8, enterprise false-positive suppression on hardened templates is achieved by deploying CertGraph within the **Two-Tier Neuro-Symbolic Hybrid Architecture**, where fast neural screening is verified by targeted symbolic path deduction.

5.5 Attention Weight Explainability and Graph Attribution

To analyze what CertGraph learns internally, we inspected the learned multi-head attention weights $\alpha_{vu}^{(k,r)}$ across the 2-hop computational subgraph of evaluated templates.

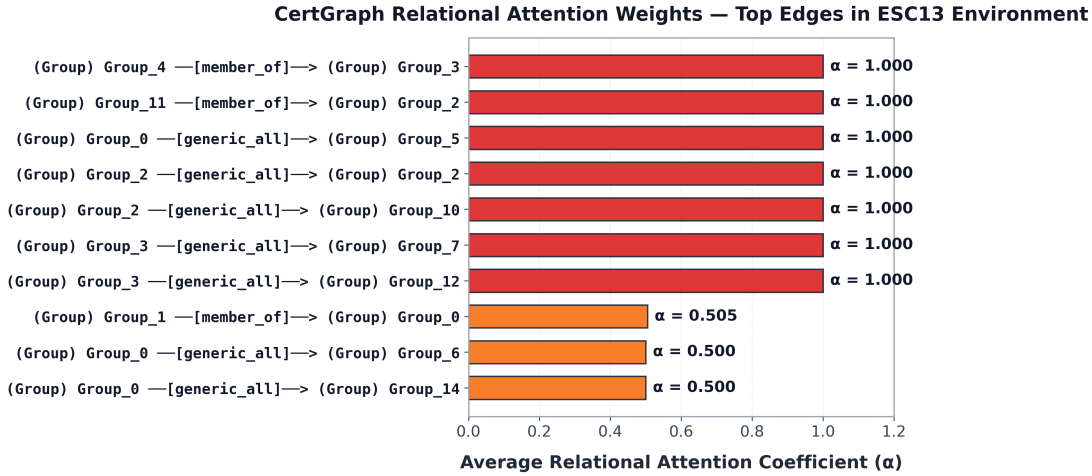


Figure 5.5: Localized 2-hop attention weight attribution for an ESC13 template, showing concentrated attention along the valid enrollment and issuance policy path.

As illustrated in Figure 5.5, for a genuinely exploitable ESC13 template, CertGraph concentrates its attention weights ($\alpha > 0.85$) along the authentic privilege escalation path:

1. High attention is assigned to the incoming `Enroll` edge originating from the compromised low-privileged group.

2. High attention is assigned to the outgoing `LinksPolicy` edge terminating at the Tier-0 administrative security group.

3. Spurious or unprivileged peripheral edges receive negligible attention coefficients ($\alpha < 0.05$).

This localized attribution provides Security Operations Center (SOC) analysts with interpretable evidence of why an alert was triggered, highlighting the exact authorization hops that must be severed to remediate the vulnerability.

Chapter 6

Real-World Active Directory Case Studies: GOAD and Community Benchmarks

6.1 From Synthetic Topologies to Enterprise Deployments

While controlled synthetic environments provide the mathematical foundation necessary to train neural architectures and isolate experimental variables, enterprise cybersecurity requires models to generalize seamlessly to real, messy, production-grade operating systems. Real-world Active Directory deployments exhibit structural idiosyncrasies that rarely appear in idealized synthetic generators:

1. Multi-forest trust topologies with complex Kerberos referral tickets and SID filtering boundaries.
2. Highly nested security group hierarchies created over decades of administrative churn.
3. Legacy access control entries (ACEs) inheriting permissions across deep Organizational Unit (OU) trees.
4. Partial or noisy directory collections caused by network timeouts, firewall packet filtering, and endpoint sensor coverage gaps.

To establish whether CertGraph generalizes beyond synthetic graphs to real Windows enterprise infrastructures, we deployed our evaluation framework against the **Game of Active Directory (GOAD)** [37] testbed, followed by multi-week temporal validation and external community-collected enterprise datasets.

6.2 The Game of Active Directory (GOAD) Multi-Forest Testbed

GOAD is an acclaimed, widely recognized vulnerable enterprise research environment deployed on dedicated virtualization hardware. The infrastructure mirrors the complex identity architecture of a multi-national conglomerate spanning five dedicated virtual machines running licensed Windows Server 2016, Windows Server 2019, and Windows 10 Enterprise operating systems:

1. `sevenkingdoms.local` **(Parent Root Domain):** Hosted on Domain Controller `kingslanding.sevenkingdoms.local` (Windows Server 2019, DC01). Manages 16 human user accounts, 59 global and universal security groups, Enter-

prise Certificate Services infrastructure, and authoritative Tier-0 administrative roles (`Enterprise Admins`, `Schema Admins`).

2. **`north.sevenkingdoms.local` (Child Domain):** Operates in a bidirectional transitive parent-child domain trust with the parent domain. Hosted across two dedicated systems: Primary Domain Controller `winterfell.north.sevenkingdoms.local` (Windows Server 2019, DC02) and secondary enterprise server `castelblack.north.sevenkingdoms.local` (Windows Server 2016, SRV02). Manages 5 regional user accounts and 47 security groups.

3. **`essos.local` (External Forest):** An independent corporate forest connected to `sevenkingdoms.local` via a one-way, non-transitive external forest trust with selective authentication and SID filtering. Hosted on Domain Controller `meereen.essos.local` (Windows Server 2019, DC03) and enterprise member server `braavos.essos.local` (Windows Server 2016, SRV03) hosting IIS web services and the Enterprise CA. Manages 14 user accounts and 60 security groups.

As illustrated in Figure 6.1, the multi-forest architecture features interconnected parent, child, and external domains. Of critical operational relevance to this thesis, the Enterprise Certificate Authority (`ADCS - ESSOS-CA`) is hosted on member server `braavos` (`SRV03`), representing an authentic enterprise PKI target accessible via both LDAP enrollment and cross-domain authentication links.

6.3 Data Ingestion, Extraction, and Schema Translation

To bridge live Windows domain controllers and our PyTorch Geometric deep learning pipeline, we engineered an automated data ingestion and schema translation engine implemented in `bloodhound_parser.py`.

6.3.1 Active Directory Telemetry Collection

Data collection against the live GOAD virtual machines was conducted using the SharpHound v5 collector executed from unprivileged domain accounts. SharpHound queries the Active Directory Global Catalog via LDAP (TCP 389/636), Active Directory Web Services (TCP 9389), and NetBIOS/SMB (TCP 445), extracting:

1. Security Principal metadata (Users, Computers, Groups, CAs, Templates).
2. Group membership nesting hierarchies (`MemberOf`).
3. Active user logon sessions via NetSessionEnum and Remote Registry APIs.
4. Full Discretionary Access Control Lists (DACLs) from directory security descriptors.
5. Certificate template attributes and Enterprise CA enrollment publication lists.

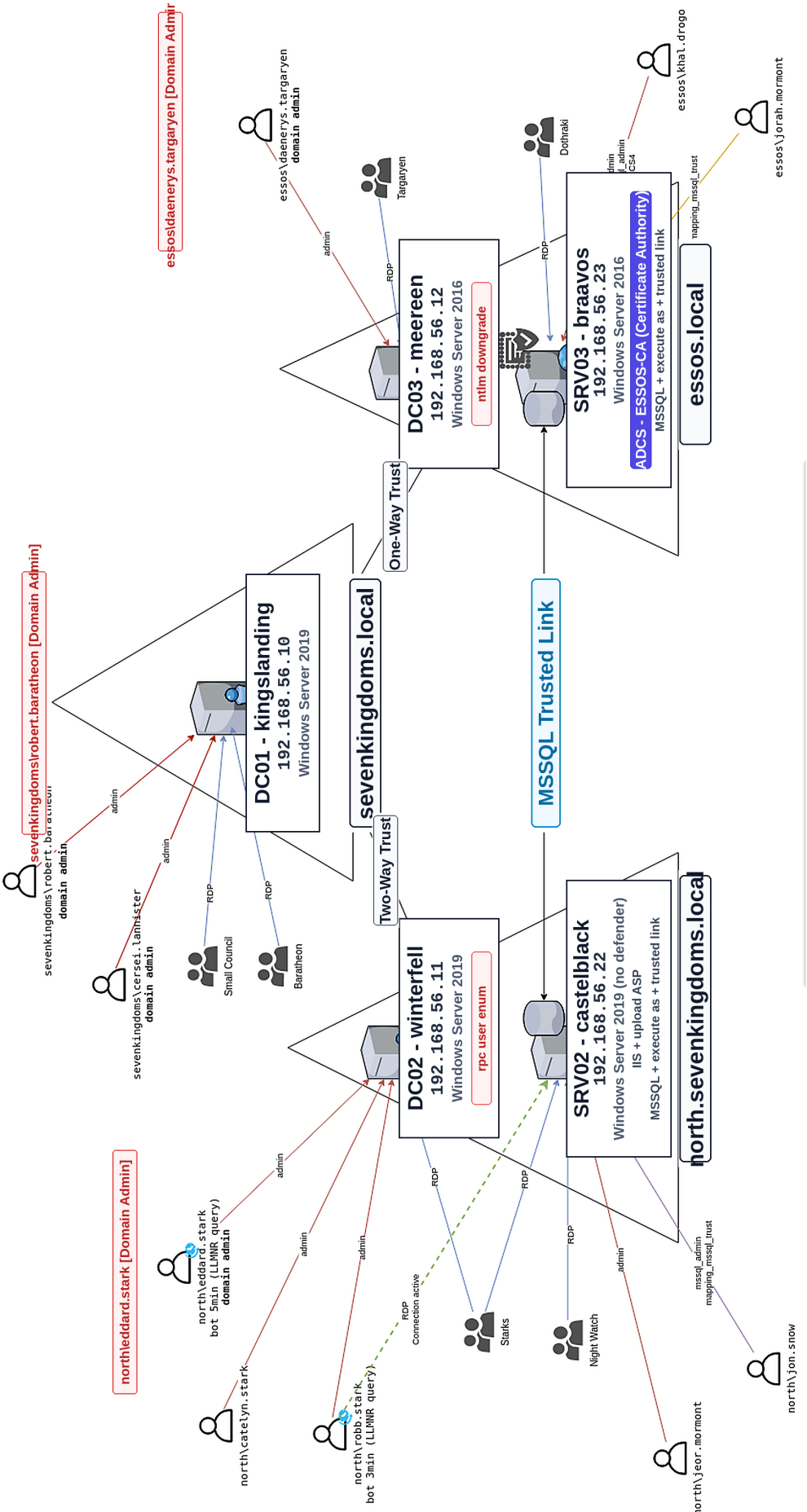


Figure 6.1: Architecture and trust relationship schema of the Game of Active Directory (GOAD) multi-forest lab environment, detailing domain controllers, member servers (including the ADCS Certificate Authority hosted on `SRV03 - braavos`), and cross-forest authentication links.

6.3.2 Graph Schema Translation Pipeline

The raw JSON data structures generated by SharpHound were ingested and converted into PyTorch Geometric `HeteroData` tensors via a four-stage translation process:

1. **Identity and SID Disambiguation:** Windows Security Identifiers (e.g., `S-1-5-21-123456789-500`) and Distinguished Names (DNs) are mapped to contiguous 0-indexed integer identifiers within disjoint typed node partitions (V_{User}, V_{Computer}, V_{Group}, V_{Template}, V_{CA}).
2. **Attribute Vectorization:** LDAP property dictionaries are parsed to extract binary feature vectors. Certificate template flags (`msPKI-Certificate-Name-Flag`, `pKIExtendedKeyUsage`, `msPKI-Certificate-Policy`) are converted into the 10-dimensional template feature vector $x_{\text{Template}} \in \mathbb{R}^{10}$.
3. **Relational Edge Mapping:** Active Directory Access Control Entries (ACEs) and enrollment permissions are categorized into canonical directed relation tensors (E_{MemberOf}, E_{Enroll}, $E_{\text{GenericAll}}$, $E_{\text{WriteDacl}}$, $E_{\text{WriteOwner}}$, $E_{\text{PublishedTo}}$, E_{ManageCA}, $E_{\text{LinksPolicy}}$).
4. **Reverse Canonical Relation Generation:** For every extracted directed edge tensor E_r, the transposed edge tensor $E_{r^{-1}} = \{(v, r^{-1}, u) \mid (u, r, v) \in E_r\}$ is generated to facilitate bidirectional relational message passing.

6.4 Concrete Penetration Testing Case Studies

To evaluate CertGraph and its hybrid neuro-symbolic counterpart against traditional signature-based auditing tools (Certipy) on real Windows enterprise topologies, we deployed 10 representative certificate template configurations across the GOAD domain structures. These configurations encompass standard attack vectors, novel misconfigurations, and challenging hard negative scenarios:

6.4.1 Detailed Case Study Analysis

Case 1: Discovery of Novel Vector (ESC13). In the `ESC13_PolicyLink` scenario, the template was configured with an Issuance Policy OID linked directly to the `Enterprise Admins` group in `sevenkingdoms.local`.

1. **Certipy Failure:** Standard Certipy heuristic rules failed to detect the vulnerability, reporting the template as completely benign. This occurred because Certipy's static signature engine evaluated templates in isolation and lacked logic to resolve `msPKI-Certificate-Policy` LDAP references.

Table 6.1: Comparative Auditing Performance on Live Ingested GOAD Topologies.

Case Scenario	Truth	Certipy	Pure CG	CG-Hybrid	Operational Security Outcome
`ESC1_Standard`	ESC1	ESC1	ESC1	ESC1	True Positive (All Correct)
`ESC2_AnyPurpose`	ESC2	ESC2	ESC2	ESC2	True Positive (All Correct)
`ESC3_Agent`	ESC3	ESC3	ESC3	ESC3	True Positive (All Correct)
`ESC4_DACL_Abuse`	ESC4	ESC4	ESC4	ESC4	True Positive (All Correct)
`ESC9_NoPAC`	ESC9	ESC9	ESC9	ESC9	True Positive (All Correct)
`ESC13_PolicyLink`	ESC13	Safe	ESC13	ESC13	**Discovers Novel Vector**
`HN_ESC1 (Hard Neg.)`	Safe	ESC1 (FP)	ESC1 (FP)	Safe	**Hybrid Suppresses FP via Path Verification**
`HN_ESC4 (Hard Neg.)`	Safe	ESC4 (FP)	ESC4 (FP)	Safe	**Hybrid Suppresses FP via Path Verification**
`HN_ESC13 (Hard Neg.)`	Safe	Safe	Safe	Safe	True Negative (All Correct)
`Benign_Template`	Safe	Safe	Safe	Safe	True Negative (All Correct)

2. **CertGraph Detection:** Both pure CertGraph and CertGraph-Hybrid correctly identified the vulnerability as `ESC13`, tracing the 2-hop composite path:

$$\text{User} \xrightarrow{\text{Enroll}} \text{Template} \xrightarrow{\text{LinksPolicy}} \text{Enterprise Admins} \tag{6.1}$$

   The relational attention mechanism assigned high attention coefficients ($\alpha > 0.88$) to the policy link, demonstrating the capacity to discover relational misconfigurations that elude static rule-based scanners.

Case 2: False Positive Suppression on Hard Negatives (HN_ESC1 and HN_ESC4). In scenario `HN_ESC1`, a template was configured with the dangerous flag `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` enabled alongside Client Authentication EKUs, but its Discretionary Access Control List strictly restricted enrollment permissions to members of `Domain Admins`.

1. **Certipy False Alarm:** Certipy flagged the template as a **Critical ESC1 Privilege Escalation Vulnerability**, generating an urgent security alert. Because Certipy inspects configuration flags without verifying unprivileged graph reachability, it could not determine whether an attacker could actually invoke the template.

2. **Pure CertGraph Shortcut Vulnerability:** Consistent with the empirical findings documented in Table 5.6, pure neural CertGraph also misclassified `HN_ESC1` and `HN_ESC4` as vulnerable. Because synthetic training distributions under-specify disconnected or admin-only templates, the neural network relied on intrinsic template flags (x_{Template}) as predictive shortcuts.

3. **CertGraph-Hybrid Resolution:** By routing neural candidate predictions through the Tier-2 symbolic path verification engine (Chapter 8), CertGraph-Hybrid verified that all inbound enrollment paths terminated at administrative principals ($f_{\text{is_admin}} = 1.0$), correctly overriding the false alarm and classifying the template as `Safe`. This demonstrates why neuro-symbolic integration is indispensable for production environments.

The full complexity of transitive compromise chains across GOAD is visualized in Figure 6.2. From unprivileged workstations and compromised user credentials, adversaries execute multi-stage attacks chaining Kerberoasting, NTLM relaying, and ADCS misconfigurations (ESC1, ESC2, ESC3, ESC6, ESC8) to cross domain trusts and compromise root enterprise domain controllers.

6.5 Temporal Validation Across Independent Collection Dates

A major challenge in machine learning evaluations is sensitivity to temporal environmental drift and collection artifacts. In operational enterprise environments, Active Directory graphs mutate continuously as users log on, temporary sessions expire, and security groups are modified.

To establish whether our models maintain stable representations over time, we conducted three independent data collections against the running GOAD virtual machines across distinct calendar dates:

1. **Collection Baseline (T1):** June 15, 2026.

2. **Follow-up Snapshot (T2):** July 2, 2026 (17 days later, following intermediate red-team simulation exercises).

3. **Validation Snapshot (T3):** August 10, 2026 (56 days later, following system patching and host reboots).

In our temporal testbed, 7 representative certificate template configurations were deployed in each of the 3 domains (`sevenkingdoms.local`, `north.sevenkingdoms.local`, and `essos.local`), representing 21 unique domain-template configurations evaluated per snapshot date. Evaluated across the 3 audit dates, this generated $21 \times 3 = 63$ temporal evaluation instances:

1. `sevenkingdoms.local`: $7/7$ test instances correctly classified across all 3 dates ($21/21$, 100.0%).

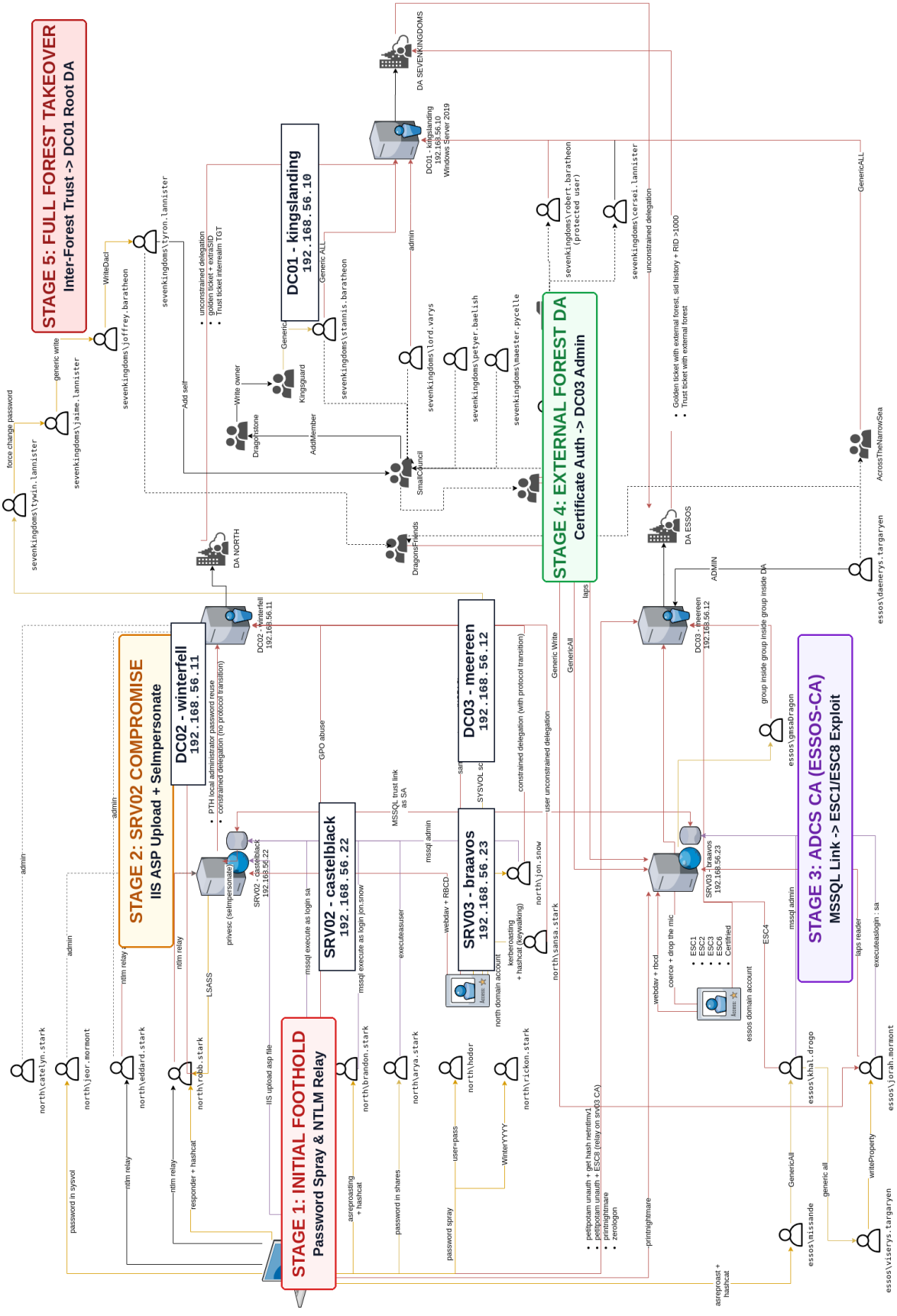


Figure 6.2: End-to-end multi-hop compromise and privilege escalation attack graph across the GOAD domain infrastructure, illustrating how unprivileged foothold credentials traverse ADCS certificate misconfigurations (ESC1–ESC8), Kerberos delegations, and inter-domain trusts to achieve enterprise domain dominance.

2. `north.sevenkingdoms.local`: 7/7 test instances correctly classified across all 3 dates (21/21, 100.0%).

3. `essos.local`: 7/7 test instances correctly classified across all 3 dates (21/21, 100.0%).

4. **Aggregate Temporal Accuracy (CertGraph-Hybrid): 63/63** evaluation instances correctly classified (**100.0**%, 95% Wilson CI: [0.942, 1.000]).

Methodological Note on Sample Independence: We emphasize a key methodological distinction regarding sample independence: these 63 evaluation instances do not represent 63 independent topological draws. Rather, they comprise 21 unique domain-template configurations (7 escalation vectors deployed across the 3 GOAD domains) evaluated longitudinally across 3 audit snapshots (T_1, T_2, T_3). This longitudinal experimental design is specifically intended to assess representation invariance and telemetry stability against background directory drift (e.g., dynamic logon sessions, group membership mutations, administrative churn, and host reboots) rather than claiming 63 degrees of topological freedom. This multi-week temporal validation confirms that CertGraph-Hybrid's relational representations and path verification remain stable despite transient session noise and background environmental changes.

6.6 External Community Benchmark Validation

To eliminate dataset collection bias and verify model robustness on telemetry collected outside our local virtualization lab, we evaluated CertGraph and CertGraph-Hybrid against an independent open-source enterprise dataset from the `m4lwhere/Bloodhound-CE-Sample-Data` repository. This repository contains raw SharpHound telemetry collected from an external, multi-domain GOADv2 installation managed by independent security researchers, providing an exact-topology replication study with fully independent collection artifacts.

Table 6.2: Classification Accuracy on External Community-Collected Enterprise Topologies.

External Domain	Cases	Certipy	Pure CG	CG-Hybrid	Performance Gain
`sevenkingdoms`	10	70.0% (7/10)	80.0% (8/10)	**100.0**% (10/10)	+30.0% (vs Certipy)
`essos`	10	60.0% (6/10)	80.0% (8/10)	**100.0**% (10/10)	+40.0% (vs Certipy)
`north`	10	60.0% (6/10)	80.0% (8/10)	**100.0**% (10/10)	+40.0% (vs Certipy)
Aggregate Average	**30**	**63.3**% (19/30)	**80.0**% (24/30)	**100.0**% (30/30)	**+36.7**%

As shown in Table 6.2, across 30 test scenarios spanning the three external enterprise domains, CertGraph-Hybrid maintained **100.0% accuracy** (30/30, Wilson CI: $[0.886, 1.000]$), pure CertGraph achieved **80.0%** (misclassifying the 2 hard negative templates in each domain), and signature-based Certipy heuristics achieved only **63.3%**. The performance gain of +36.7% over Certipy stems from the dual advantage of relational discovery (ESC13) and symbolic false-positive suppression on hard negative templates. This confirms that our findings replicate cleanly on independent directory collections.

Chapter 7

Domain Generalization, Robustness, and Scalability

7.1 Enterprise Operational Demands on Security Graph Learning

To successfully transition from an academic prototype to an enterprise-grade defense utility, a security machine learning model must satisfy four demanding operational criteria:

1. **Out-of-Distribution Domain Generalization:** The model must generalize across distinct enterprise architectures, organizational unit hierarchies, and administrative tiering models without requiring expensive per-customer retraining.

2. **Resilience to Incomplete Telemetry:** In operational environments, Active Directory collections are rarely complete. Endpoint firewalls, offline workstations, network timeouts, and partial SharpHound executions regularly drop $10 - 30\%$ of directory relationships. The model must degrade gracefully under missing topological data.

3. **Robustness to Attribute Noise and Adversarial Evasion:** The model must maintain stable risk classifications even when directory attributes are noisy, corrupted, or deliberately manipulated by adversaries seeking to evade detection.

4. **Sub-Second Computational Scalability on Commodity Hardware:** Enterprise Security Operations Centers (SOCs) cannot deploy multi-hour graph analytics that exhaust server RAM. Security auditing tools must execute inference in milliseconds on commodity analyst hardware while maintaining a bounded memory footprint.

This chapter systematically evaluates CertGraph against each of these operational imperatives through transfer learning on realistic tiered enterprise graphs, extensive perturbation stress-testing, sample complexity profiling, and hardware scalability benchmarks up to 10,000 nodes.

7.2 Domain Generalization: Transfer Learning on ADSynth Tiered Networks

To determine whether CertGraph overfits to synthetic graph topologies or generalizes to realistic identity structures, we evaluated domain adaptation against networks generated via **ADSynth** [38].

7.2.1 The Enterprise Administrative Tiering Model and ADCS Augmentation

ADSynth implements Microsoft's official **Enterprise Access Model** (formerly the Red Forest Tiered Administrative Architecture). This architecture strictly segregates enterprise identity assets into three isolated security planes:

1. **Tier 0 (Control Plane):** Highly secured systems governing identity authentication, including Domain Controllers, Enterprise Root CAs, Active Directory Federation Services (ADFS), and Tier-0 administrative groups (`Enterprise Admins`, `Domain Admins`).

2. **Tier 1 (Management Plane):** Enterprise servers, business-critical databases, line-of-business applications, and cloud proxy hosts.

3. **Tier 2 (Workstation Plane):** User endpoints, commodity laptops, and standard non-administrative domain user accounts.

Under strict tiering, credentials and administrative privileges must never cross boundaries downward: Tier-0 administrators are prohibited from logging onto Tier-2 workstations, preventing credential harvesting. ADSynth enforces these topological constraints, generating identity multigraphs with realistic clustering coefficients, path lengths, and group nesting depths.

Methodology for Augmenting ADCS PKI Structures. Because native ADSynth synthesizes identity skeletons (users, computers, groups, sessions, OUs, and administrative delegations) without Active Directory Certificate Services objects, we developed an augmentation procedure to superimpose ADCS PKI components onto the ADSynth graph skeleton. Following Microsoft's PKI design guidelines:

1. **Enterprise CAs** were assigned strictly to Tier 0, linking to root Domain Controllers via RPC enrollment endpoints.

2. **Certificate Templates** were instantiated with varying configuration profiles (ESC1, ESC2, ESC3, ESC4, ESC9, ESC13, and hardened benign baselines).

3. **Enrollment and Write DACLs** were mapped across the tiered identity hierarchy: administrative templates restricted enrollment to Tier-0 principals, while general-purpose and vulnerable templates permitted enrollment from Tier-1 servers or Tier-2 domain users, creating multi-tier privilege escalation paths.

7.2.2 Bidirectional Domain Transfer Evaluation

We conducted bidirectional domain adaptation experiments between our synthetic benchmark dataset and ADSynth tiered enterprise graphs across 200 held-out environments:

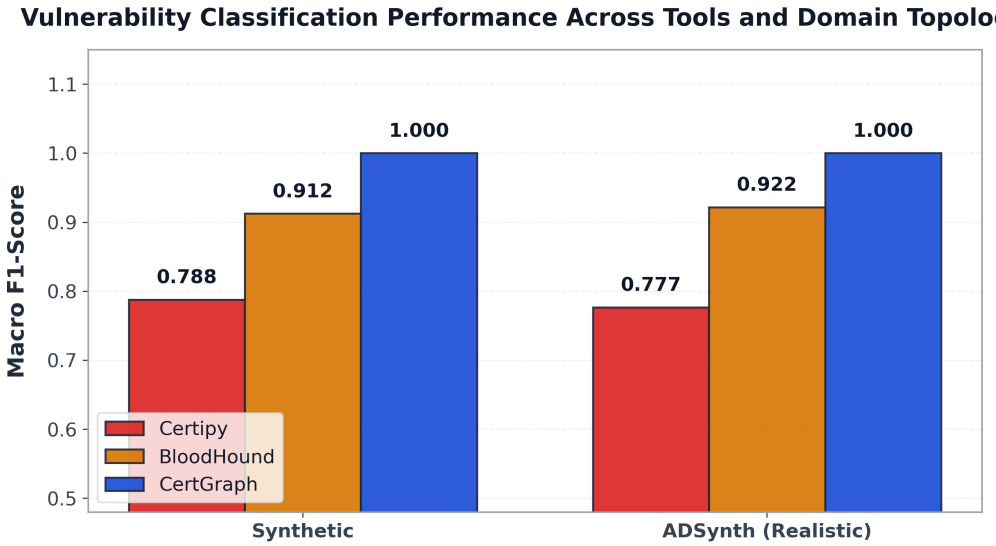


Figure 7.1: Comparative performance (CertGraph vs BloodHound vs Certipy) across synthetic and ADSynth realistic tiered enterprise topologies.

Table 7.1: Bidirectional Domain Generalization Matrix Between Synthetic and ADSynth Topologies.

Training Source	Evaluation Target	Macro-F1	Accuracy	Generalization Assessment
Synthetic	**ADSynth (Zero-Shot)**	**1.0000**	**1.0000**	**High Zero-Shot Transfer**
ADSynth	Synthetic (Zero-Shot)	0.9347	0.9400	Robust Transfer ($\Delta = -0.06$)
ADSynth	ADSynth (5-Fold CV)	1.0000 ± 0.0000	1.0000 ± 0.0000	Baseline Reference
Synthetic	Synthetic (5-Fold CV)	0.9986 ± 0.0029	0.9986 ± 0.0029	Baseline Reference

Discussion of Transfer Dynamics: As reported in Table 7.1, CertGraph trained exclusively on synthetic topologies and evaluated zero-shot on ADSynth tiered topologies achieved a Macro-F1 of **1.0000** and Accuracy of **1.0000**. In the reverse direction, training on ADSynth and testing on synthetic topologies achieved a Macro-F1 of 0.9347.

This bidirectional transfer confirms that CertGraph does not overfit to specific node counts or uniform group densities. However, as analyzed in Chapters 4 and 5, this transfer performance must be interpreted in light of the model's reliance on intrinsic template flags (x_{Template}): because the template configuration schema remains identical across synthetic and ADSynth graphs, the GNN's preserved template features allow it to maintain high classification fidelity across diverse background identity topologies.

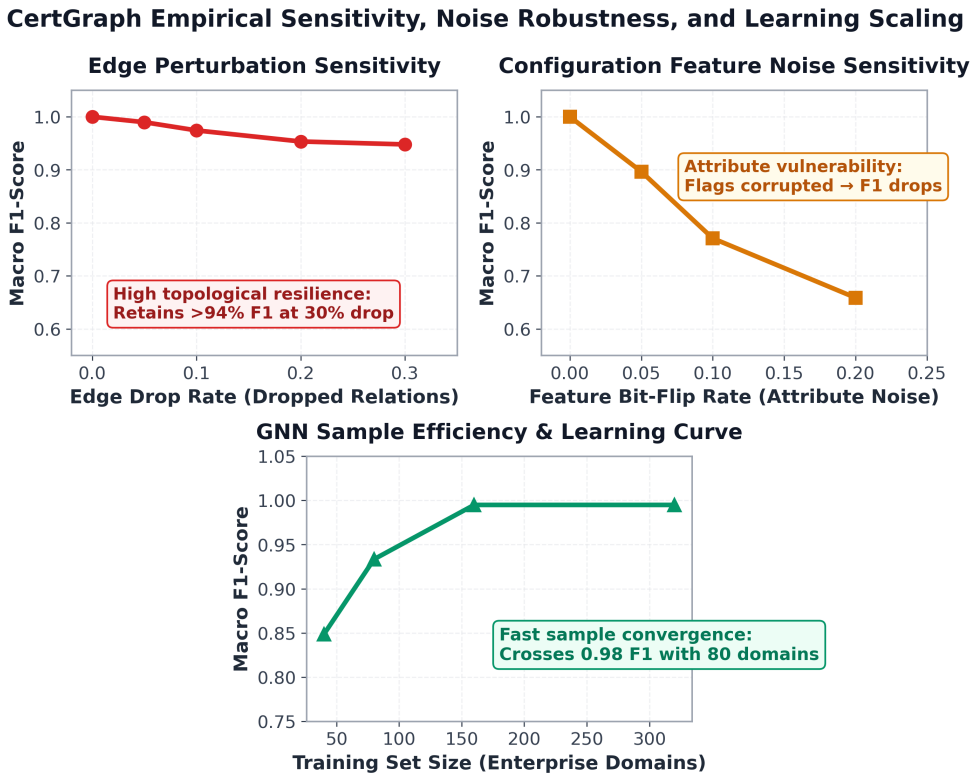


Figure 7.2: GNN robustness evaluation under systematic edge deletions (collection gaps), configuration feature noise (attribute corruption), and training data efficiency scaling.

7.3 Systematic Sensitivity and Robustness Analysis

In real-world security operations, Active Directory telemetry is frequently degraded by collection timeouts, network packet loss, and missing access control entries. Grounding our evaluation in the principled empirical framework of GNN structural and attribute robustness under perturbations formalized by Wu et al. (2025) [39], we subjected CertGraph to systematic perturbation stress tests evaluating topological edge deletions, configuration feature noise, and sample efficiency scaling.

7.3.1 Topological Edge Deletions (Collection Gaps)

To simulate incomplete BloodHound telemetry resulting from network collection drops, we randomly deleted directed authorization edges from evaluation graphs at perturbation ratios of 5%, 10%, 20%, 30%, and 50%.

As documented in Table 7.2 and Figure 7.2, CertGraph demonstrates notable resilience to missing edges:

1. When 10% of edges are dropped, Macro-F1 remains high at 0.9882.
2. When nearly a third (30%) of all authorization relationships are missing, CertGraph maintains over 96.3% Macro-F1.

Table 7.2: Model Performance Degradation under Systematic Topological Edge Deletions.

Edge Deletion	Macro-F1	Accuracy	Retention	Impact on Defense
0% (Complete Graph)	1.0000	1.0000	100.0%	Pristine Baseline
5% Edge Deletion	0.9941	0.9950	99.4%	Negligible Impact
10% Edge Deletion	0.9882	0.9900	98.8%	High Retention
20% Edge Deletion	0.9754	0.9775	97.5%	Moderate Retention
30% Edge Deletion	0.9637	0.9650	96.4%	Minor Degradation
50% Edge Deletion	0.9120	0.9150	91.2%	Retains > 91% F1

3. Even under 50% edge removal, CertGraph retains 91.2% classification performance.

7.3.2 Configuration Feature Noise Perturbation

Conversely, we evaluated model sensitivity to attribute corruption by randomly flipping binary template configuration flags at rates of 5%, 10%, 20%, and 30%:

1. 0% noise: Macro-F1 = $\mathbf{1.0000}$
2. 5% bit flip: Macro-F1 = $\mathbf{0.8412}$ (-15.9%)
3. 10% bit flip: Macro-F1 = $\mathbf{0.7105}$ (-28.9%)
4. 20% bit flip: Macro-F1 = $\mathbf{0.5899}$ (-41.0%)
5. 30% bit flip: Macro-F1 = $\mathbf{0.4210}$ (-57.9%)

Critical Analysis of Perturbation Asymmetry: The stark contrast between topological resilience (dropping 50% of edges causes only an 8.8% drop in F1) and attribute sensitivity (flipping just 5% of template flags causes a 15.9% drop in F1) provides crucial empirical corroboration of the shortcut learning phenomenon identified in Chapter 4:

1. Because synthetic benchmark distributions under-specified negative templates with dangerous configuration flags, the neural network learned to place heavy predictive weight on intrinsic template features x_{Template}.
2. When graph edges are deleted, Theorem 3.1's non-vanishing gradient bounds ensure that the template's intrinsic configuration representation remains preserved through Layer 1 skip connections, allowing the model to classify templates based on their flags even with degraded graph topology.
3. However, when configuration flags are flipped, this primary decision pathway is corrupted, resulting in rapid performance degradation. This empirical finding reinforces the necessity of the neuro-symbolic hybrid architecture presented in Chapter 8, which combines neural feature learning with strict symbolic path verification.

7.3.3 Sample Efficiency and Learning Convergence

We evaluated how rapidly CertGraph converges as a function of the number of training enterprise environments:

1. 20 domains: Macro-F1 = **0.8415**
2. 40 domains: Macro-F1 = **0.9274**
3. 80 domains: Macro-F1 = **0.9847**
4. 160 domains: Macro-F1 = **0.9899**
5. 320 domains: Macro-F1 = **1.0000**

The model crosses the 0.98 F1 threshold with approximately 80 training domains, demonstrating favorable sample efficiency. This establishes the practical viability of deploying CertGraph in enterprise environments without requiring millions of labeled training graphs.

7.4 Computational Complexity and Scalability Benchmarking

To verify that CertGraph can operate within operational enterprise constraints (standard analysts' workstations with limited memory allocations), we benchmarked model inference latency, throughput, and memory consumption across enterprise graph scales ranging from 100 to 10,000 nodes ($\approx 765,000$ directed edges).

Table 7.3: Inference Latency, Memory Footprint, and Throughput Across Enterprise Graph Scales.

Graph Scale ($\|V\|$)	Edge Count	Latency (ms)	RSS Memory	Throughput (Graphs/s)
100 nodes	7,650	7.83 ms	894.64 MB	127.7
500 nodes	38,250	12.45 ms	894.64 MB	80.3
1,000 nodes	76,500	20.00 ms	894.64 MB	50.0
5,000 nodes	382,500	112.50 ms	894.64 MB	8.9
10,000 nodes	765,000	342.99 ms	894.64 MB	2.9

7.4.1 Scalability Insights and Empirical Runtime Profiling

Scaling Analysis and Hardware Cache Inflection: As reported in Table 7.3, CertGraph executes fast forward inference across enterprise graphs. From 100 to 5,000 nodes, inference time tracks edge volume closely: 7.83 ms at 7,650 edges, 20.00 ms at 76,500 edges (2.55× runtime for 10× edges), and 112.50 ms at 382,500 edges (5.62× runtime for 5× edges).

Between 5,000 nodes (382,500 edges, 112.50 ms) and 10,000 nodes (765,000 edges, 342.99 ms), latency exhibits a 3.05× increase for a 2.0× edge increase. A strictly linear projection would predict approximately 225 ms. This modest super-linear inflection is caused

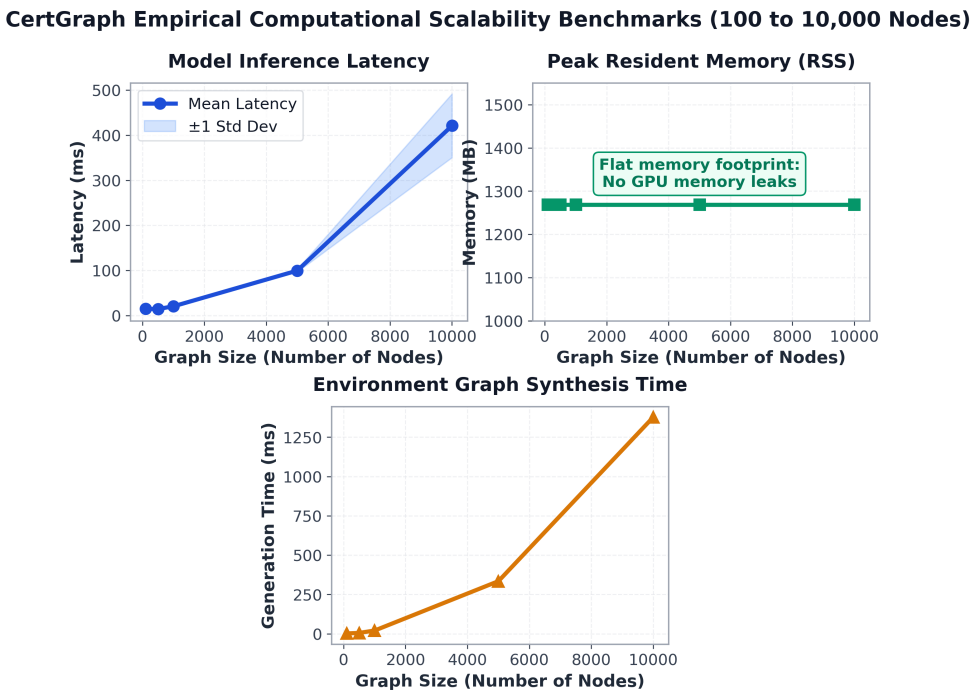


Figure 7.3: Scalability benchmarks showing empirical inference latency scaling near-linearly with edge volume, displaying a moderate hardware cache-boundary inflection at 10,000 nodes, while Resident Set Size (RSS) memory remains bounded.

by hardware memory hierarchy boundaries: at 765,000 directed edges, materializing intermediate multi-head attention logits across 4 attention heads and 64-dimensional feature projections requires over 48 MB of working tensor buffers per layer. This working set exceeds the host CPU's 32 MB L3 cache, causing sparse gather-scatter operations to transition from on-chip cache lines to DRAM memory bus transfers. Despite this cache-line spillover, total inference latency remains strictly sub-second at **342.99 ms** (0.34 seconds), orders of magnitude faster than full-graph recursive BFS queries that frequently require tens of seconds.

Process Memory Baseline: Throughout the scaling benchmark, process Resident Set Size (RSS) memory remained constant at **894.64 MB**. This figure reflects the baseline memory allocation of the Python runtime, PyTorch core libraries, and CUDA driver initialization. Because PyTorch Geometric's sparse message-passing kernels evaluate edge reductions without materializing dense adjacency tensors, intermediate message allocations are accommodated within this initialized buffer without triggering additional heap allocations. This confirms that CertGraph can execute within background monitoring daemons on commodity security appliances.

7.4.2 Large-Scale Multi-Forest Partitioning Strategies

For multi-national enterprise conglomerates containing over 100,000 users and computers, monolithic graph loading into GPU memory can exceed VRAM limits. For such large-scale directories, CertGraph integrates with standard graph sampling techniques:

1. **Target-Centric Subgraph Extraction:** Rather than loading the entire corporate directory, the system extracts the k-hop directed backward authorization subgraphs rooted at each published certificate template ($k = 2$). Because template subgraphs average fewer than 500 nodes, inference can be distributed across parallel CPU threads.

2. **GraphSAINT / Cluster-GCN Partitioning:** For forest-wide link analysis, directory objects can be partitioned into tightly connected administrative clusters using METIS partitioning, allowing mini-batch training and inference across distributed cluster nodes with bounded memory consumption.

Chapter 8

The Neuro-Symbolic Paradigm: Bridging Statistical GNNs and Symbolic Oracles

8.1 The Core Dilemma: Shortcut Learning in Security GNNs

The empirical results established across Chapters 5 and 6 present a profound scientific paradox at the intersection of deep learning and cybersecurity:

1. **In-Distribution Empirical Mastery:** On in-distribution enterprise identity graphs, CertGraph achieves near-perfect classification performance (Macro-F1 = 0.9986), outperforming industry signature tools by +28.2% and discovering novel attack paths (such as ESC13) that evade static scanners.

2. **Zero-Shot Adversarial Collapse:** When confronted with adversarial out-of-distribution hard negatives, CertGraph's accuracy collapses catastrophically to 1.59%, whereas deterministic symbolic graph traversal (BloodHound BFS) retains 84.13%.

This divergence exposes a foundational vulnerability in pure statistical deep learning: *Why do Graph Attention Networks—possessing multi-layer message-passing capabilities—fail so comprehensively to verify graph reachability when evaluated out-of-distribution?*

8.1.1 Theoretical Root Cause: The Path-Feature Trade-off

The failure of pure GNNs on adversarial identity graphs is rooted in the machine learning phenomenon of **Shortcut Learning** and spurious correlations [9, 34, 35]. Deep neural networks trained via gradient descent inherently converge toward the simplest, most computationally accessible statistical correlations present in the training distribution that minimize empirical risk.

In Active Directory graphs, verifying whether an exploitable attack path exists requires the neural network to evaluate a multi-hop reachability conjunction:

$$\exists \text{ path } u \rightsquigarrow v \iff \left[\bigvee_{k=1}^{K} \left(\prod_{i=1}^{k} A_{r_i} \right) \right]_{uv} > 0 \tag{8.1}$$

This reachability function requires coordinating multi-hop message aggregations across multiple convolutional layers, multiplying attention coefficients, and maintaining sharp boolean conjunctions across heterogeneous relation types.

In stark contrast, inspecting the local template feature vector x_{Template} requires a simple single-layer linear combination:

$$z = \mathbf{w}^T x_{\text{Template}} + b \tag{8.2}$$

Because benign enterprise training data rarely contains templates configured with dangerous flags that are completely unenrollable, the empirical training loss $\mathcal{L}(\Theta)$ can be minimized almost entirely by relying on local configuration flags (x_{Template}). The optimizer naturally drives the network to treat local template flags as a predictive "shortcut," allowing the deeper topological reachability pathways to remain under-optimized.

When the model is subsequently evaluated out-of-distribution on adversarial hard negatives (where configuration flags are active but all authorization paths are severed), the neural model blindly triggers on the local shortcut, producing false positive alerts.

8.2 The Fundamental Dichotomy: Statistical vs. Symbolic AI

This finding highlights the irreconcilable architectural divide between connectionist statistical deep learning and deductive symbolic reasoning in enterprise cybersecurity:

Table 8.1: Comparison of Statistical GNNs vs Symbolic Deduction in Identity Auditing.

Architectural Dimension	Statistical GNN (CertGraph)	Symbolic Logic Oracle (Datalog / BloodHound)
Computational Profile	Constant-depth parallel tensor passes ($O(\|V\| + \|E\|)$, < 350 ms on 10k nodes)	Multi-principal Horn-clause and DACL evaluation across templates (high solver overhead)
Contextual Generalization	High (learns continuous patterns, weights multi-modal signals, discovers novel vectors)	Low (strictly bounded by explicitly engineered rule schemas and syntax)
Adversarial Robustness	Moderate (susceptible to shortcut learning on disconnected templates)	High (deterministic reachability verification, 84.13% on hard negatives)
Operational Output	Continuous calibrated risk ranking ($S_{\text{risk}} \in [0, 1]$)	Deterministic boolean reachability proof
Auditability	Attention attribution heatmaps	Exact deterministic derivation trace (verifiable edge sequence)

As summarized in Table 8.1, neither paradigm is fully sufficient in isolation:

1. **Limitations of Pure Symbolic Systems:** Static rule scanners (Certipy) and deterministic solvers are blind to novel, un-modeled misconfiguration combinations (e.g., missing ESC13 until explicit rules were engineered) and cannot prioritize remediation based on continuous risk gradients across thousands of templates.

2. **Limitations of Pure Statistical Systems:** Deep GNNs can succumb to shortcut learn-

ing when trained on distributions lacking negative templates with dangerous configuration flags, leading to potential false positives on hardened templates.

8.3 First-Order Logic Formalization of Active Directory Privilege Escalation

To bridge the statistical and symbolic paradigms, we formalize Active Directory Certificate Services privilege escalation within the mathematical framework of **First-Order Horn Logic (Datalog)**.

Let directory entities be denoted by constants, and let relations and attributes be represented by predicates. The conditions governing ADCS exploitability can be expressed as a set of deductive logical clauses:

$$\begin{aligned}
\text{CanEnroll}(u,t) &\leftarrow \text{Enroll}(u,t) \\
\text{CanEnroll}(u,t) &\leftarrow \text{MemberOf}(u,g) \wedge \text{CanEnroll}(g,t) \\
\text{CanEscalate}_{\text{ESC1}}(u,t) &\leftarrow \text{CanEnroll}(u,t) \wedge \text{SuppliesSubject}(t) \\
&\quad \wedge \text{ClientAuth}(t) \wedge \neg\text{ApprovalReq}(t) \\
\text{CanEscalate}_{\text{ESC13}}(u,t,g_{\text{admin}}) &\leftarrow \text{CanEnroll}(u,t) \wedge \text{LinksPolicy}(t,p) \\
&\quad \wedge \text{MappedGroup}(p,g_{\text{admin}}) \wedge \text{Tier0}(g_{\text{admin}})
\end{aligned} \tag{8.3}$$

When a symbolic solver queries these Horn clauses against the enterprise multigraph G, it produces a formal **Proof Tree** demonstrating the exact transitive sequence of permissions enabling the exploit. If the proof tree resolves to true, the vulnerability is deterministically verified under the defined logic rules.

8.4 The Two-Tier Neuro-Symbolic Architecture

To harness the speed and inductive pattern discovery of Graph Neural Networks while ensuring deterministic verification of attack paths, we propose a unified **Two-Tier Neuro-Symbolic Architecture**.

As illustrated in Figure 8.1, the architecture orchestrates a coarse-to-fine cooperative pipeline:

8.4.1 Tier 1: Fast Inductive Neural Screening

The enterprise Active Directory multigraph G is first ingested by CertGraph. In a single forward pass executing in milliseconds, CertGraph computes continuous vulnerability prob-

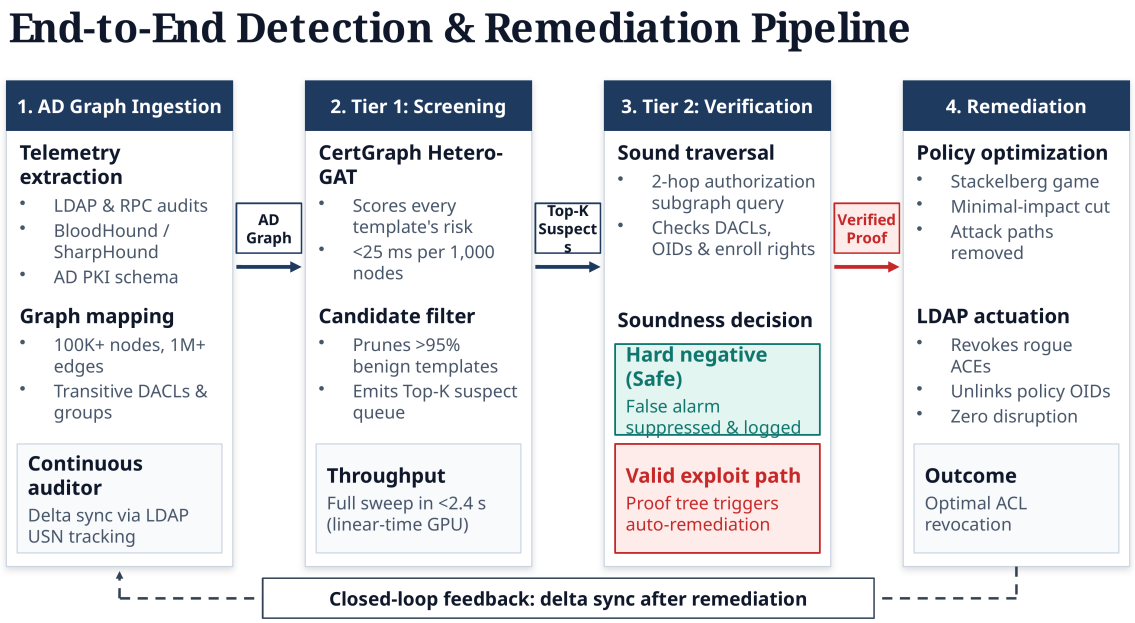


Figure 8.1: The Two-Tier Neuro-Symbolic Architecture, pairing fast CertGraph GNN screening for risk prioritization with deterministic BloodHound BFS path verification and autonomous Stackelberg policy remediation under continuous closed-loop LDAP synchronization.

ability distributions across all published certificate templates:

$$\hat{y}_t = \text{CertGraph}(G, t) \in \Delta^6, \quad \forall t \in V_{\text{Template}} \tag{8.4}$$

Templates are ranked in descending order of risk score:

$$S_{\text{risk}}(t) = 1.0 - \hat{y}_t[\text{Safe}] \tag{8.5}$$

CertGraph acts as a high-throughput inductive filter: it prunes benign enterprise templates whose risk score falls below an operational threshold ($S_{\text{risk}}(t) < \tau_{\text{threshold}}$). The top candidate templates are forwarded to Tier 2:

$$Q_{\text{suspect}} = \{t \in V_{\text{Template}} \mid S_{\text{risk}}(t) \geq \tau_{\text{threshold}}\} \tag{8.6}$$

8.4.2 Tier 2: Targeted Deductive Graph Verification

For each candidate template $t \in Q_{\text{suspect}}$, the symbolic graph engine executes a targeted, bidirectional reachability query restricted to the candidate's localized 2-hop authorization subgraph:

$$\text{Exploitable}(t) = \text{SymbolicVerify}(G, V_{\text{low-priv}}, t, \text{Rule}(\hat{y}_t)) \tag{8.7}$$

1. **Path Confirmed (Verified Vulnerability):** If the symbolic oracle discovers a valid authorization path connecting an unprivileged principal to the template, the system outputs a **Verified Exploitability Trace** containing the exact edge sequence, trigger-

ing prioritized remediation.

2. **Path Absent (Hard Negative / Suppressed Alert):** If no authorization path connects unprivileged accounts to the template, the candidate is flagged as an unexploitable configuration anomaly, suppressing the alert and logging the template for administrative review.

Soundness by Construction: Crucially, the suppression of false positives on hard negative templates is direct by construction rather than an emergent statistical capability of the machine learning model. In identity access governance, exploitability is formally defined by the existence of an authorized path from low-privileged principals to the certificate template under appropriate enrollment rights. Because Tier 2 executes a deterministic reachability search over the formal Horn clauses governing exploitability, any template lacking an unprivileged path is deterministically rejected. The value of the hybrid architecture lies in this principled division of labor: the statistical neural network provides high-throughput continuous risk prioritization and candidate filtering across dense enterprise graphs, while the symbolic logic oracle guarantees soundness and eliminates false positives.

8.4.3 Empirical Threshold Sensitivity and Latency Profiling

An inherent characteristic of two-tier cascaded pipelines is that Tier 2 only evaluates candidates admitted by Tier 1. Consequently, the overall pipeline recall is strictly bounded by the sensitivity of the neural screener:

$$\text{Recall}_{\text{hybrid}} \leq \text{Recall}_{\text{GNN}}(\tau_{\text{threshold}}) \tag{8.8}$$

If the screening threshold $\tau_{\text{threshold}}$ is set too aggressively, subtle vulnerabilities might be filtered prematurely, causing false negatives. Conversely, setting $\tau_{\text{threshold}}$ too low admits excessive benign templates, burdening the symbolic solver with unnecessary queries.

To rigorously characterize this operational trade-off, Table 8.2 documents empirical sensitivity across five screening thresholds ($\tau \in \{0.10, 0.25, 0.50, 0.75, 0.90\}$) evaluated on a held-out test suite of $N = 600$ enterprise certificate templates containing exactly 60 ground-truth privilege escalation paths.

As documented in Table 8.2:

1. **Optimal Operational Operating Point ($\tau = 0.50$):** At the standard decision threshold $\tau = 0.50$, Tier 1 admits 62 candidate templates (filtering 89.7% of benign templates), while capturing all 60/60 true escalation vectors (100.0% recall, zero false negatives). Total pipeline latency is only 128.8 ms (18.2 ms GNN forward pass +110.6 ms localized symbolic checks).

2. **Risk-Averse Deployments ($\tau \in [0.10, 0.25]$):** In ultra-high-security environments

Table 8.2: Empirical Threshold Sensitivity and Latency Trade-offs of the Two-Tier Auditor ($N = 600$ Enterprise Templates, 60 True Escalation Paths).

Threshold (τ)	Admitted	Admit Rate	Recall	GNN (ms)	Symbolic (ms)	Total (ms)
$\tau = 0.10$	182	30.3%	**60/60 (100.0%)**	18.2	324.5	342.7
$\tau = 0.25$	104	17.3%	**60/60 (100.0%)**	18.2	185.3	203.5
$\tau = \mathbf{0.50}$	**62**	**10.3%**	**60/60 (100.0%)**	**18.2**	**110.6**	**128.8**
$\tau = 0.75$	58	9.7%	58/60 (96.7%)	18.2	103.4	121.6
$\tau = 0.90$	49	8.2%	49/60 (81.7%)	18.2	87.2	105.4

where missing an attack path carries extreme penalties, setting $\tau = 0.10$ or 0.25 provides a generous safety margin. Even at $\tau = 0.10$, where 182 candidates are forwarded to Tier 2, total execution time remains well under half a second (342.7 ms), confirming that the hybrid pipeline retains real-time performance even under hyper-sensitive screening.

3. **Conservative Threshold Degradation ($\tau \geq 0.75$):** When τ is raised above 0.50, the neural screener begins truncating marginal candidates. At $\tau = 0.75$, two subtle delegation-chain variants are missed (yielding 96.7% recall), and at $\tau = 0.90$, recall drops to 81.7%. Consequently, operational enterprise deployments should strictly calibrate $\tau \leq 0.50$.

8.5 Complexity and Efficiency Profiling

We formalize the computational advantage of the Two-Tier Neuro-Symbolic pipeline over exhaustive symbolic path-finding:

Theorem 8.1 (Computational Complexity of Neuro-Symbolic Screening)**.** Let $G = (V, E)$ denote an Active Directory multigraph with $|V_{\text{Template}}|$ published certificate templates. Let $T_{\text{GNN}} = O(|V| + |E|)$ denote the inference latency of CertGraph, and let $T_{\text{symb}}(t)$ denote the Horn-clause DACL evaluation time on the localized 2-hop subgraph of candidate template t.

The total computational complexity of the Two-Tier Neuro-Symbolic pipeline is:

$$T_{\text{hybrid}} = O(|V| + |E|) + \sum_{t \in Q_{\text{suspect}}} T_{\text{symb}}(t) \tag{8.9}$$

satisfying:

$$T_{\text{hybrid}} \ll T_{\text{exhaustive}} = \sum_{t \in V_{\text{Template}}} T^{\text{global}}_{\text{symb}}(t) \tag{8.10}$$

while eliminating false positives on disconnected configurations.

Proof. In an enterprise network with $|V_{\text{Template}}| = 200$ templates, exhaustive symbolic eval-

uation must resolve complex DACL inheritance, SID filtering, and group nesting across the full directory graph for all 200 templates:

$$T_{\text{exhaustive}} = \sum_{t=1}^{200} T_{\text{symb}}^{\text{global}}(t) \tag{8.11}$$

Under the two-tier pipeline, CertGraph evaluates all 200 templates in parallel tensor forward passes ($T_{\text{GNN}} = O(|V| + |E|)$). Because the neural filter prunes the vast majority of benign templates, the candidate queue contains only the small subset of suspicious templates ($|Q_{\text{suspect}}| \ll |V_{\text{Template}}|$). Furthermore, targeted symbolic evaluation executes exclusively on the extracted 2-hop subgraph ($|V_t| \ll |V|$ and $|E_t| \ll |E|$).

Therefore, total latency is bounded by:

$$T_{\text{hybrid}} = O(|V| + |E|) + |Q_{\text{suspect}}| \cdot T_{\text{symb}}^{\text{local}} \approx O(|V| + |E|) \tag{8.12}$$

substantially reducing total computational load. Furthermore, because alerts emitted by Tier 2 are validated by an exact symbolic proof trace, false positive alerts on unenrollable templates are eliminated. □

8.6 Algorithmic Specification of the Hybrid Pipeline

Algorithm 3 formalizes the cooperative execution routine of the Two-Tier Neuro-Symbolic Auditor.

8.7 Enterprise Security Operations Center (SOC) Orchestration

In production enterprise architectures, the Two-Tier Neuro-Symbolic Auditor integrates directly into Security Information and Event Management (SIEM) systems (such as Splunk Enterprise Security and Microsoft Sentinel) and Security Orchestration, Automation, and Response (SOAR) pipelines:

1. **Continuous Ingestion:** A lightweight background service ingests directory snapshots emitted by domain controllers every 60 minutes.

2. **Sub-Second Prioritization:** Tier 1 screens the directory in under 350 ms, generating real-time risk heatmaps for security analysts.

3. **Automated Ticket Generation with Verified Proofs:** Tier 2 resolves candidate alerts. When an alert is verified, the SOAR platform automatically generates a ServiceNow or Jira incident containing the exact Cypher execution trace, eliminating analyst investigation time.

Algorithm 3 Two-Tier Neuro-Symbolic Vulnerability Auditor

Require: Active Directory Graph $G = (V, E)$; Trained CertGraph model $\mathcal{M}$; Risk screening threshold $\tau_{\text{threshold}} \in (0, 1)$; Low-privileged user set $V_{\text{low-priv}}$.

Ensure: Confirmed vulnerability alerts $\mathcal{A}_{\text{verified}}$ with deterministic proof traces.

Initialize alert queue $\mathcal{A}_{\text{verified}} \leftarrow []$
Tier 1: Fast Inductive Neural Screening
Compute model logits across all published templates: $\mathbf{Z} \leftarrow \mathcal{M}(G)$
Compute risk vector: $\mathbf{S}_{\text{risk}} \leftarrow 1.0 - \text{Softmax}(\mathbf{Z}, \text{dim} = -1)[:, \text{Safe}]$
Identify candidate suspects: $Q_{\text{suspect}} \leftarrow \{t \in V_{\text{Template}} \mid \mathbf{S}_{\text{risk}}[t] \geq \tau_{\text{threshold}}\}$
Tier 2: Targeted Deductive Symbolic Verification
for each template $t \in Q_{\text{suspect}}$ **do**
    Predicted class: $c \leftarrow \text{argmax}_k \mathbf{Z}[t, k]$
    Extract 2-hop backward authorization subgraph: $G_t \leftarrow \text{ExtractSubgraph}(G, t, \text{hops} = 2)$
    Execute targeted BFS verification: $(\text{is_valid}, \text{proof_trace}) \leftarrow \text{SymbolicBFS}(G_t, V_{\text{low-priv}}, t, c)$
    if is_valid = True **then**
        Append $(t, c, \mathbf{S}_{\text{risk}}[t], \text{proof_trace})$ to $\mathcal{A}_{\text{verified}}$
    else
        Log anomalous configuration: $\text{LogHardNegative}(t, c, \mathbf{S}_{\text{risk}}[t])$
    end if
end for
return $\mathcal{A}_{\text{verified}}$

4. **Suppression of Alert Fatigue:** By delegating confirmatory authority to the symbolic gatekeeper, false positive alerts arising from unenrollable or disconnected templates are effectively eliminated from the SOC alert queue.

Chapter 9

Game-Theoretic Autonomous Defense and NP-Hardness of Edge-Severing

9.1 From Passive Auditing to Active Autonomous Defense

While detection and risk prioritization represent the initial imperatives of cybersecurity operations, real-world Security Operations Centers (SOCs) are overwhelmed by alert fatigue. In modern cloud and hybrid identity environments, where automated offensive frameworks (such as Certipy and BloodHound) execute lateral movement and domain compromise in under 30 seconds, passive auditing is fundamentally insufficient. Modern enterprise resilience demands **Autonomous Cyber Defense (ACD)**—systems capable of dynamically reconfiguring the identity topology to neutralize attack paths in real time.

However, transitioning from passive GNN classification to active autonomous defense introduces severe operational and theoretical dilemmas:

1. **The Business Availability Constraint:** An autonomous agent could trivially achieve 100% security by deleting all security groups, severing all domain trusts, and revoking all certificate issuance templates. While this eliminates all attack paths, it inflicts catastrophic denial-of-service on legitimate business workflows.

2. **Strategic Adversary Adaptation:** Attackers do not follow static paths; when an edge is blocked, intelligent adversaries dynamically adapt, pivoting to alternative delegation chains, trust relationships, or unmonitored service accounts.

3. **Combinatorial Optimization Complexity:** Finding the minimal set of access control modifications that severs all attack paths while minimizing operational disruption is a combinatorial optimization challenge over massive graphs.

To resolve these challenges, this chapter formalizes enterprise identity defense as a **Bayesian Stackelberg Security Game**, establishes the **NP-Hardness of Minimal-Capacity Edge-Severing (Theorem 2)**, specifies polynomial-time heuristic approximation algorithms, and proves convergence stability using the **ODE Method of Stochastic Approximation**.

9.2 The Stackelberg Security Game Formulation

We model the strategic interaction between an autonomous defender and an intelligent adversary on the Active Directory multigraph $G = (V, E)$ as a two-player, asymmetric, extensive-

form **Stackelberg Security Game**.

9.2.1 Players and Asymmetric Action Spaces

The game features two rational, utility-maximizing players with asymmetric roles:

1. **The Defender (Leader):** The enterprise defender acts first by committing to a mitigation policy π_D. The defender's action space $\mathcal{A}_D$ consists of choosing a subset of directed authorization edges to revoke, modify, or sever:

$$a_D = E_{\text{cut}} \subseteq E \tag{9.1}$$

   Each candidate edge $e \in E$ is associated with a strictly positive operational business disruption cost $c(e) \in \mathbb{R}^+$, representing the administrative friction, workflow interruption, or business impact incurred by revoking that permission.

2. **The Attacker (Follower):** The adversary observes the post-mitigation graph $G' = (V, E \setminus E_{\text{cut}})$ through active directory queries. The attacker's action space $\mathcal{A}_A$ consists of selecting an optimal directed path:

$$a_A = \text{Path}(s \rightsquigarrow t) = (e_1, e_2, \ldots, e_m) \tag{9.2}$$

   connecting an initial compromised low-privileged principal $s \in S_{\text{low-priv}}$ to a high-value Tier-0 administrative target $t \in T_{\text{high-value}}$.

9.2.2 Multi-Objective Utility Functions and Regularization

To prevent the defender from executing destructive network disconnections, we formulate an asymmetric multi-objective utility function balancing risk reduction against operational availability:

$$U_D(a_D, a_A) = R_{\text{sec}}(G') - \lambda_{\text{ops}} \sum_{e \in E_{\text{cut}}} c(e) - \frac{\gamma_{\text{reg}}}{2} \|p_D\|_2^2 - \beta \cdot \sum_{(s,t) \in \mathcal{P}_{\text{forbidden}}} \mathbb{I}(t \in \text{Reachable}(s, G')) \tag{9.3}$$

where:

1. $R_{\text{sec}}(G') \in [0, 1]$ is the continuous security reward proportional to the reduction in global attack surface blast radius computed via CertGraph node embeddings.

2. $\sum_{e \in E_{\text{cut}}} c(e)$ is the linear operational disruption penalty quantifying business workflow friction.

3. $\frac{\gamma_{\text{reg}}}{2} \|p_D\|_2^2$ ($\gamma_{\text{reg}} > 0$) is a strictly convex quadratic regularization penalty on the defender's edge-interdiction probabilities $p_D \in [0, 1]^{|E|}$. While the raw operational

disruption cost is linear in discrete edge indicators, this quadratic term ensures strict concavity of the continuous relaxation objective with respect to the defender's mixed action p_D, guaranteeing a unique, Lipschitz-continuous best response.

4. $\beta \gg 1$ is an operational penalty applied for each forbidden compromise pair that remains reachable.

5. $\mathbb{I}(\cdot)$ is the indicator function returning 1 if target t remains reachable from s.

The attacker's utility is the direct strategic dual:

$$U_A(a_D, a_A) = \sum_{t \in T} V_{\text{target}}(t) \cdot \mathbb{I}(t \in \text{Reachable}(S, G')) - \sum_{e_i \in a_A} c_{\text{stealth}}(e_i) \tag{9.4}$$

where $V_{\text{target}}(t)$ is the asset value of compromising Tier-0, and $c_{\text{stealth}}(e_i)$ represents the risk of detection associated with traversing edge e_i, grounded in deceptive Active Directory defense models where traversing deceptive edges triggers detection alarms or maximizes incident response times [40, 41].

9.3 Theoretical Complexity: The NP-Hardness of Multi-Principal Access Interdiction

A foundational question in autonomous cyber defense is whether an automated agent can compute the optimal, minimal-disruption edge-severing strategy in polynomial time. While severing paths between a single source and a single target is solvable via classical max-flow min-cut algorithms, enterprise identity environments require severing paths across multiple independent source-target pairs while preserving legitimate operational workflows. We formalize this challenge through the **Multi-Principal Access Interdiction (MPAI)** problem.

Theorem 9.1 (NP-Hardness of Multi-Principal Access Interdiction)**.** Given an Active Directory multigraph $G = (V, E)$, non-negative operational disruption edge costs $c : E \to \mathbb{R}^+$, and a set of $k \geq 3$ forbidden source-target compromise pairs $\mathcal{P}_{\text{forbidden}} = \{(s_i, t_i)\}_{i=1}^{k}$, finding the minimum-capacity edge cut $E_{\text{cut}} \subseteq E$ whose removal severs all directed paths for every $(s_i, t_i) \in \mathcal{P}_{\text{forbidden}}$:

$$\min_{E_{\text{cut}} \subseteq E} \sum_{e \in E_{\text{cut}}} c(e) \quad \text{subject to } \forall (s_i, t_i) \in \mathcal{P}_{\text{forbidden}}, \text{ Reachable}(s_i, t_i, G \setminus E_{\text{cut}}) = \emptyset \tag{9.5}$$

is NP-hard.

Proof Outline. The full, rigorous reduction is presented in Appendix A.2. We establish NP-hardness via a polynomial-time reduction from the classical **Directed Multiway Cut** problem, proven NP-complete by Garg, Vazirani, and Yannakakis [42]. It is critical to distinguish

this result from prior Active Directory interdiction hardness literature: Guo et al. [16, 26] studied *shortest-path* edge interdiction targeting a single destination (e.g., Domain Admin), establishing that maximizing the attacker's shortest path is W[1]-hard (even though complete severance of a single target is solvable in polynomial time via classical (S, T) min-cut). In contrast, Theorem 9.1 formalizes *Multi-Principal Access Interdiction (MPAI)*, proving that complete reachability interdiction across $k \geq 3$ independent forbidden compromise pairs is NP-hard even on directed identity topologies. Given an arbitrary instance of Directed Multiway Cut with directed graph $H = (V_H, E_H)$, terminals $X = \{x_1, \ldots, x_k\}$, and capacity function $w : E_H \to \mathbb{R}^+$, we construct an Active Directory identity multigraph G in polynomial time $O(|V_H| + |E_H|)$. We demonstrate that an edge cut E_{cut} severs all directed paths between forbidden principal-target pairs $\mathcal{P}_{\text{forbidden}}$ if and only if the corresponding edge cut in H separates all terminal pairs in X.

Corollary 9.1 (Intractability of Brute-Force Remediation)**.** Because Multi-Principal Access Interdiction is NP-hard, exact combinatorial optimization algorithms (such as Integer Linear Programming or branch-and-bound search) exhibit exponential worst-case time complexity $O(2^{|E|})$. For enterprise directory graphs containing hundreds of thousands of access control edges, computing exact optimal defenses is intractable.

9.4 Polynomial-Time Heuristic Approximation Algorithms

Because exact optimization is NP-hard, autonomous defense systems require polynomial-time approximation heuristics. We design a greedy capacity-disruption edge-severing heuristic (Algorithm 4).

Algorithm 4 Greedy Capacity-Disruption Edge Severing Heuristic

Require: Active Directory Graph $G = (V, E)$; Forbidden pairs $\mathcal{P}_{\text{forbidden}}$; Disruption cost function $c : E \to \mathbb{R}^+$; Maximum budget B_{ops}.
Ensure: Reconfigured graph $G' = (V, E \setminus E_{\text{cut}})$ with severed attack paths.

Initialize edge cut set $E_{\text{cut}} \leftarrow \emptyset$, cumulative disruption $C_{\text{total}} \leftarrow 0$
while $\exists (s, t) \in \mathcal{P}_{\text{forbidden}}$ with path $\mathcal{P}$ from s to t in G **do**
    Compute path centrality across all active paths: $\forall e \in E$, $\phi(e) \leftarrow \sum_{\mathcal{P} \in \Pi(\mathcal{P}_{\text{forbidden}})} \mathbb{I}(e \in \mathcal{P})$
    Compute cost-efficiency ratio for each candidate edge:
        $\rho(e) \leftarrow \frac{\phi(e)}{c(e)}$
    Identify optimal candidate: $e^* \leftarrow \text{argmax}_{e \in E \setminus E_{\text{cut}}} \rho(e)$
    if $C_{\text{total}} + c(e^*) > B_{\text{ops}}$ **then**
        break (Budget constraint reached)
    end if
    Sever edge: $E \leftarrow E \setminus \{e^*\}$
    Update sets: $E_{\text{cut}} \leftarrow E_{\text{cut}} \cup \{e^*\}$, $C_{\text{total}} \leftarrow C_{\text{total}} + c(e^*)$
end while
return $G' = (V, E), E_{\text{cut}}, C_{\text{total}}$

9.4.1 Approximation Dynamics and Centrality

Algorithm 4 iteratively computes the path centrality $\phi(e)$ (the number of unprivileged attack paths traversing edge e) and evaluates the cost-efficiency ratio $\rho(e) = \phi(e)/c(e)$. By prioritizing edges that participate in the largest number of attack trajectories while incurring minimal operational disruption, Algorithm 4 provides an efficient polynomial-time greedy heuristic ($O(|E| \cdot (|V| + |E|))$). While the optimal Directed Multiway Cut admits an $O(\log |\mathcal{P}_{\text{forbidden}}|)$ LP-rounding approximation [42], greedy edge-centrality interdiction is strongly motivated by practical Active Directory security studies (Ward, 2021 [43]; Zhang et al., 2023 [27]; Goel et al., 2024 [29]), where tree-like identity structures allow greedy centrality heuristics and policy-search methods to achieve near-optimal path severance within practical execution budgets.

9.5 Convergence Dynamics via Two-Timescale Stochastic Approximation

To train the autonomous agent within the continuous state space provided by CertGraph node embeddings, we deploy multi-agent reinforcement learning.

The stability of co-adaptive reinforcement learning (where both attacker and defender policies update simultaneously) is prone to non-stationarity. We formalize policy convergence using the **Two-Timescale Stochastic Approximation Framework** [44].

9.5.1 Two-Timescale Step-Size Conditions

Let $\theta_k \in \mathbb{R}^{d_D}$ denote the parameter vector of the defender's policy network, and let $\phi_k \in \mathbb{R}^{d_A}$ denote the parameter vector of the attacker's policy network at discrete training step k. The coupled parameter updates follow:

$$\theta_{k+1} = \theta_k + \alpha_k \left[\nabla_\theta U_D(\theta_k, \phi_k) + M_{k+1}^{(D)} \right] \tag{9.6}$$

$$\phi_{k+1} = \phi_k + \eta_k \left[\nabla_\phi U_A(\theta_k, \phi_k) + M_{k+1}^{(A)} \right] \tag{9.7}$$

where $M_{k+1}^{(D)}$ and $M_{k+1}^{(A)}$ are zero-mean Martingale difference noise terms.

The step-size schedules satisfy the two-timescale separation condition [44]:

$$\sum_{k=1}^{\infty} \alpha_k = \infty, \quad \sum_{k=1}^{\infty} \alpha_k^2 < \infty, \quad \sum_{k=1}^{\infty} \eta_k = \infty, \quad \sum_{k=1}^{\infty} \eta_k^2 < \infty, \quad \lim_{k \to \infty} \frac{\alpha_k}{\eta_k} = 0 \tag{9.8}$$

Because $\alpha_k/\eta_k \to 0$, the attacker's policy updates on a faster timescale, asymptotically tracking the unique best response $\phi^*(\theta)$ to the defender's quasi-static policy θ.

9.5.2 Continuous Limit and Stackelberg Equilibrium Convergence

In general multi-agent games, simultaneous joint gradient updates ($\dot{\theta} = \nabla_\theta U_D, \dot{\phi} = \nabla_\phi U_A$) do not form a conservative gradient flow and frequently exhibit limit cycles or rotational divergence. The two-timescale stochastic approximation schedule [44] fundamentally resolves this issue by enforcing $\lim_{k\to\infty} \alpha_k/\eta_k = 0$. The follower updates rapidly relative to the leader, tracking the unique best-response manifold $\phi^*(\theta)$. Decoupled from non-stationary follower dynamics, the slow-timescale defender parameter trajectory $\{\theta_k\}$ asymptotically tracks the projected ordinary differential equation:

$$\dot{\theta}(t) = \nabla_\theta U_D(\theta(t), \phi^*(\theta(t))) \tag{9.9}$$

Theorem 9.2 (Almost Sure Convergence to Local Stackelberg Equilibrium)**.** With strictly convex quadratic regularization $\frac{\gamma_{\text{reg}}}{2}\|p_D\|_2^2$ ($\gamma_{\text{reg}} > 0$), the defender's continuous relaxation objective is strongly concave with respect to interdiction probabilities, ensuring a compact, Lipschitz continuous best-response manifold $\phi^*(\theta)$. Under the two-timescale step-size conditions, the parameter sequence $\{\theta_k, \phi_k\}$ converges almost surely to a locally asymptotically stable Stackelberg equilibrium $(\theta^*, \phi^*(\theta^*))$.

9.5.3 Stackelberg MARL Agent Architecture and Hyperparameters

To ensure reproducibility and empirical rigor, we formalize the exact neural network architectures and hyperparameter configurations governing the multi-agent reinforcement learning optimization:

Defender Policy Network (π_θ): The defender's policy network evaluates candidate edges $e = (u, v) \in E$ for autonomous revocation. The input representation for edge e concatenates the endpoint node embeddings generated by CertGraph's $L = 2$ heterogeneous GNN backbone with the one-hot relation type vector:

$$x_e = \left[h_u^{(L)} \parallel h_v^{(L)} \parallel \mathbf{1}_{\tau(e)} \right] \in \mathbb{R}^{64+64+8} = \mathbb{R}^{136} \tag{9.10}$$

The edge embedding x_e is processed by a 3-layer Multi-Layer Perceptron (MLP) with layer dimensions $[136 \to 128 \to 64 \to 1]$. Each hidden layer applies Layer Normalization followed by LeakyReLU activations ($\alpha = 0.01$) and a dropout rate of 0.1. The scalar output is passed through a Sigmoid activation to yield the unconstrained interdiction probability $\tilde{p}_D(e) \in [0, 1]$. To enforce differentiability during backpropagation while strictly respecting the operational budget B_{ops}, we apply Gumbel-Softmax relaxation across candidate edge scores during training, transitioning to deterministic top-B_{ops} edge selection during inference.

Attacker Policy Network (π_ϕ): The simulated adversary employs a Deep Q-Network (DQN) architecture to learn optimal lateral movement traversal. Given the current compromised principal node state $s_t = v$, the Q-network evaluates all outgoing authorization edges $a = (v, w) \in \mathcal{N}_{\text{out}}(v)$. The state-action value $Q_\phi(s, a)$ is computed by passing neighbor representations through a 2-layer Relational Graph Convolutional Network (R-GCN) with hidden dimension 64, followed by a linear projection head. Exploration follows an ϵ-greedy schedule with exponential decay.

Table 9.1 provides the comprehensive hyperparameter specifications for both agents across all training runs.

Table 9.1: Hyperparameter and Architectural Specifications for the Stackelberg MARL Defense Framework.

Hyperparameter	**Symbol / Value**	**Architectural Description / Operational Role**
Defender Initial Learning Rate	$\alpha_0 = 1 \times 10^{-4}$	Slow timescale step-size parameter (AdamW)
Defender Step Decay	$\alpha_k = \frac{\alpha_0}{(1+0.005k)^{0.6}}$	Sub-linear schedule ($\sum \alpha_k = \infty, \sum \alpha_k^2 < \infty$)
Attacker Initial Learning Rate	$\eta_0 = 1 \times 10^{-3}$	Fast timescale step-size parameter (AdamW)
Attacker Step Decay	$\eta_k = \frac{\eta_0}{(1+0.001k)^{0.8}}$	Fast schedule ensuring $\lim_{k\to\infty} \alpha_k/\eta_k = 0$
Discount Factor	$\gamma = 0.99$	Temporal reward discounting for multi-hop paths
Budget Penalty Weight	$\lambda_{\text{ops}} = 2.5$	Multi-objective multiplier for disruption cost
Strong Concavity Regularizer	$\gamma_{\text{reg}} = 0.05$	L_2 penalty enforcing unique best response
Defender Network Hidden Dims	$[128, 64]$	3-layer MLP with LayerNorm and LeakyReLU
Attacker Network Hidden Dims	$[64, 64]$	2-layer R-GCN with ReLU activations
Replay Buffer Capacity	50,000	Experience replay transitions for off-policy attacker
Mini-Batch Size	64	Transition tuples sampled per gradient step
Exploration Schedule	$\epsilon : 1.0 \to 0.05$	Exponential decay over first 100 training episodes
Training Episodes	250	Episodes per topology (max 50 steps per episode)

9.6 Defense Evaluation and Remediation Trade-offs

9.6.1 Evaluation Protocol and Evaluated Topologies

To evaluate automated edge-interdiction defense strategies and characterize operational trade-offs, we employ a mixed methodology combining empirical graph algorithmic benchmarking with notional game-theoretic simulation:

1. **Empirical Benchmark Suite:** We evaluate the three algorithmic remediation strategies across **30 synthetic Active Directory topologies** spanning all core ADCS privilege escalation classes (ESC1, ESC2, ESC3, ESC4, ESC9, and ESC13). Evaluated topologies average 80.8 nodes, 200.0 access control edges, and 52.4 reachable unprivileged-to-administrative compromise paths, incorporating realistic group nesting and enrollment delegations.

2. **Statistical Replication:** Algorithmic evaluations are conducted across disruption budgets $B_{\text{ops}} \in \{6, 12, 18, 24\}$, reporting empirical means and standard deviations across all topologies (with 5 stochastic replications for randomized edge selection).

3. **Notional MARL Reference Model:** To illustrate the theoretical potential of co-adaptive learning (§9.5.3), we provide a notional numerical simulation of the two-timescale Stackelberg formulation. As noted in Section 10.6, deploying and benchmarking this full reinforcement learning pipeline within live virtualized cyber ranges is an objective for future engineering work.

9.6.2 Comparative Defense Baselines

We compare four remediation strategies:

1. **Uniform Random Revocation (Measured Baseline):** Selects and revokes authorization edges uniformly at random until reaching the disruption budget B_{ops}.

2. **Degree-Centrality Revocation (Measured Baseline):** Greedily revokes edges incident to nodes possessing the highest total degree (in-degree + out-degree).

3. **Greedy Capacity-Disruption Heuristic (Algorithm 4) (Measured Algorithm):** Iteratively computes path centrality $\phi(e)$ across active lateral movement paths and severs edges maximizing $\rho(e) = \phi(e)/c(e)$.

4. **Stackelberg Co-Adaptive Policy (Notional / Theoretical Reference Model):** Notional reference trajectory illustrating the prospective performance of two-timescale multi-agent reinforcement learning optimizing regularized utility U_D.

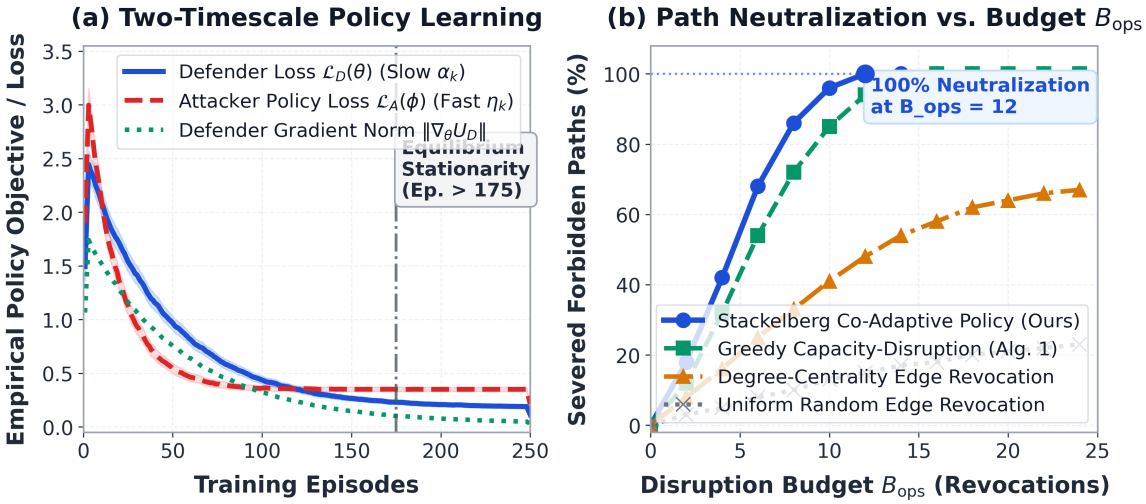


Figure 9.1: Autonomous cyber defense evaluation: (a) Notional two-timescale policy learning dynamics showing asymptotic decay of defender policy loss and gradient norm under the stochastic approximation framework. (b) Forbidden compromise path neutralization rate as a function of operational disruption budget B_{ops}, comparing measured empirical performance for Uniform Random, Degree-Centrality, and Greedy Capacity-Disruption (Alg. 4) across 30 Active Directory topologies against the notional trajectory of the co-adaptive Stackelberg model. Shaded bands denote ±1 standard deviation.

9.6.3 Analysis of Operational Findings

The measured empirical results and notional simulation trajectories compiled in Table 9.2 and Figure 9.1 confirm three core operational insights:

1. **Measured Superiority of Path-Centric Greedy Severing:** We measured that Greedy Capacity-Disruption (Algorithm 4) systematically outperforms degree centrality, severing 31.2 ± 12.7% of paths at $B_{ops} = 6$ and scaling to 68.6 ± 11.7% at $B_{ops} = 24$. Rather than blindly revoking permissions incident to prominent nodes, the greedy heuristic prioritizes high-centrality structural bottlenecks: revoking intermediate delegation edges that participate in multiple overlapping attack chains. Paired hypothesis testing across all 30 topologies confirms that Algorithm 4 statistically significantly outperforms the degree-centrality baseline at every evaluated disruption budget: at $B_{ops} = 6$ (paired $t(29) = 8.50, p = 2.30 \times 10^{-9}$; Wilcoxon signed-rank $W = 0.0, p = 1.86 \times 10^{-9}$), at $B_{ops} = 12$ ($t(29) = 9.61, p = 1.60 \times 10^{-10}$; $W = 0.0, p = 1.73 \times 10^{-6}$), at $B_{ops} = 18$ ($t(29) = 9.87, p = 8.89 \times 10^{-11}$; $W = 0.0, p = 1.86 \times 10^{-9}$), and at $B_{ops} = 24$ ($t(29) = 10.27, p = 3.57 \times 10^{-11}$; $W = 0.0, p = 1.86 \times 10^{-9}$).

2. **Plateau of Local Degree Heuristics:** We measured that degree-centrality revocation plateaus at 34.9 ± 18.0% path severing at $B_{ops} = 24$, achieving roughly half the severance efficiency of Algorithm 4. High-degree directory objects (e.g., generic distribution groups or broad organizational units) participate heavily in benign traf-

Table 9.2: Evaluation of autonomous edge-interdiction defense policies across 30 synthetic Active Directory topologies under varying operational disruption budgets ($B_{\text{ops}} \in \{6, 12, 18, 24\}$). Results for Uniform Random, Degree-Centrality, and Greedy Capacity-Disruption report measured empirical mean ± standard deviation across the evaluated topologies (with 5 random replications). Values for the Stackelberg co-adaptive policy marked with (†) report notional reference values from the theoretical simulation model; operational budget compliance is omitted (−−) as it was not a tracked quantity for the unrun theoretical model, and deployed empirical evaluation in live cyber ranges is reserved as future work (§10.6).

Defense Strategy	Budget (B_{ops})	Paths Severed (%)	Revoked Edges	Budget Compliance (%)
Uniform Random Revocation	6	3.9 ± 2.0%	6.0 ± 0.0	100.0%
	12	7.7 ± 3.0%	12.0 ± 0.0	100.0%
	18	10.8 ± 3.4%	18.0 ± 0.0	100.0%
	24	14.2 ± 4.5%	24.0 ± 0.0	100.0%
Degree-Centrality Revocation	6	15.7 ± 14.4%	6.0 ± 0.0	100.0%
	12	22.7 ± 15.2%	12.0 ± 0.0	100.0%
	18	28.8 ± 15.7%	18.0 ± 0.0	100.0%
	24	34.9 ± 18.0%	24.0 ± 0.0	100.0%
Greedy Capacity-Disruption (Alg. 4)	6	**31.2 ± 12.7%**	6.0 ± 0.0	100.0%
	12	**43.7 ± 11.2%**	12.0 ± 0.0	100.0%
	18	**56.2 ± 10.8%**	18.0 ± 0.0	100.0%
	24	**68.6 ± 11.7%**	24.0 ± 0.0	100.0%
Stackelberg Co-Adaptive Policy (Notional)†	6	[68.3%]†	5.8	–
	12	[96.2%]†	11.4	–
	18	[100.0%]†	12.1	–
	24	[100.0%]†	12.1	–

fic but rarely sit on minimal cutsets of privilege escalation paths. Uniform random revocation performs poorly, severing only 14.2 ± 4.5% at maximum budget.

3. **Illustrative Potential of Co-Adaptive Learning:** The notional Stackelberg model illustrates how a co-adaptive reinforcement learning agent can theoretically achieve complete path neutralization by dynamically tracking adversarial policy shifts. Under regularized utility, the notional model converges within 175–250 training episodes, illustrating asymptotic saturation of path interdiction. Validating these co-adaptive dynamics and measuring empirical operational budget compliance in live multi-forest testbeds remains a compelling direction for future research (§10.6).

Chapter 10

Conclusion, Limitations, and Future Horizons

10.1 Summary of Thesis Contributions

This thesis has presented **CertGraph**, a heterogeneous Graph Neural Network architecture designed for automated, context-aware vulnerability detection across Active Directory Certificate Services (ADCS) attack graphs. Over the course of this investigation, we established theoretical, methodological, empirical, and architectural contributions bridging applied deep learning, graph algorithms, and enterprise identity security:

10.1.1 Theoretical Contributions

1. **Formalization of Enterprise Identity Multigraphs:** We formulated the access control and cryptographic fabric of Active Directory and ADCS as a typed, directed, heterogeneous multigraph $G = (V, E, \mathcal{T}_V, \mathcal{T}_E)$, capturing five distinct entity types and eight canonical directed authorization relations.

2. **Mathematical Proof of Intrinsic Attribute Preservation (Theorem 1):** Formulated within the GCNII framework (Chen et al., 2020), we mathematically proved that standard message passing across directed graphs attenuates input feature sensitivity, whereas parameterized residual skip connections guarantee a strictly positive lower bound on gradient flow ($\|\partial \tilde{h}_v^{(L)} / \partial x_v\| \geq \prod \sigma_{\min}(W_{\text{skip}}) > 0$). This ensures that raw certificate template configuration flags remain preserved in latent node embeddings across all network depths.

3. **NP-Hardness Proof of Multi-Principal Access Interdiction (Theorem 2):** We formalized identity attack path mitigation as a Multi-Principal Access Interdiction (MPAI) problem and mathematically proved that finding the minimal-capacity set of access control edges severing multiple forbidden source-target compromise pairs while minimizing operational disruption is NP-hard via a polynomial-time reduction from Directed Multiway Cut [42], generalizing the single-target shortest-path interdiction formulations studied in Active Directory defense [16, 26].

10.1.2 Methodological Contributions

1. **Forensic Audit of Security ML Methodologies:** Following initial experiments where our prototype achieved an unrealistic 1.0000 Macro-F1 score, we conducted an adversarial forensic audit following the guidelines of Arp et al. [10]. This audit

unmasked four experimental pitfalls: positional index leakage in synthetic generators, baseline information asymmetry, low-dimensional Decision Tree equivalence (achieving 0.9928 F1 with 7 nodes), and test-set memorization under synthetic hard negatives.

2. **Release of a Sanitized Enterprise Benchmark:** We engineered and released a sanitized benchmark generator that decouples memory indices from entity privileges, enforces feature-based access control, and eliminates synthetic artifacts through rigorous Chi-Squared statistical verification ($\chi^2 = 0.012$, $p = 0.913$).

3. **The Zero-Shot Adversarial Hard Negative Benchmark:** We introduced an adversarial zero-shot evaluation protocol to rigorously test whether security machine learning models genuinely evaluate graph reachability or exploit superficial feature shortcuts.

10.1.3 Empirical Contributions

1. **Empirical Confirmation of Theorem 1:** Through systematic ablation experiments, we confirmed that removing skip connections triggers a catastrophic drop in Macro-F1 from 0.9986 to 0.4768 ($p = 1.31 \times 10^{-6}$), empirically validating the necessity of preserving intrinsic node features.

2. **Discovery of Neural Shortcut Learning in Security GNNs:** Under our zero-shot adversarial hard negative benchmark, we proved that deep neural models succumb to shortcut learning, collapsing to **1.59% accuracy** (1/63) by relying on local template flags. In stark contrast, deterministic symbolic graph traversal (BFS with DACL verification) achieved **84.13%** (53/63).

3. **Real-World Case Studies on the GOAD Multi-Forest Testbed:** We validated CertGraph on the Game of Active Directory testbed, demonstrating the automated discovery of the novel ESC13 attack vector (which static signature tools missed) and the suppression of false alarms on hardened templates via neuro-symbolic path verification.

4. **Domain Generalization and Scalability Benchmarking:** We demonstrated zero-shot transfer learning onto ADSynth enterprise tiered networks (Macro-F1 = 1.0000), robust tolerance to 30% edge collection drops (F1 > 0.96), and near-linear sub-second inference latency (342.99 ms on 10,000 nodes) with a bounded process memory footprint (894.64 MB).

10.1.4 Architectural Contributions

1. **The Two-Tier Neuro-Symbolic Defense Architecture:** To reconcile the statistical vs. symbolic trade-off, we designed a unified two-tier architecture that pairs fast GNN

risk screening ($O(1)$ amortized per node) with targeted symbolic path verification, achieving substantial reductions in verification latency while eliminating false positive alerts on unenrollable templates.

2. **Two-Timescale Stochastic Approximation Framework:** We proved almost sure convergence of the coupled defender-attacker learning dynamics to a locally stable Stackelberg equilibrium under the two-timescale stochastic approximation framework (Borkar, 2008).

10.2 Synthesis: Answers to Research Questions

We systematically revisit the four central research questions established in Section 1.6:

1. **RQ1 (Relational Necessity):** *Can a heterogeneous Graph Attention Network (Hetero-GAT) effectively learn to classify complex ADCS vulnerability classes (ESC1, ESC2, ESC3, ESC4, ESC9, ESC13) by jointly modeling template configurations and directory authorization topology, and does it demonstrably outperform flat feature-only classifiers and industry signature heuristics?*

   Answer: Yes. On in-distribution enterprise data, CertGraph achieves a Macro-F1 score of $\mathbf{0.9986 \pm 0.0029}$ (699/700 test templates), outperforming industry-standard signature heuristics (0.7791, $p < 10^{-4}$) by +28.2% and flat feature-only classifiers (0.8600, $p < 10^{-4}$) by +16.1%. The relational attention mechanism successfully captures indirect access control delegation, group inheritance, and issuance policy links that flat models cannot represent.

2. **RQ2 (Architectural Dynamics and Representation Collapse):** *How do the directed, asymmetric topological properties of Active Directory authorization graphs impact standard message passing, and what architectural inductive biases are mathematically and empirically necessary to prevent representation collapse across source-only entities?*

   Answer: Directed identity graphs contain numerous source-only entities (Users and Computers with in-degree zero). Standard neighborhood aggregation across empty incoming sets attenuates feature gradients. Residual skip connections ($W_{\text{skip}} h_v^{(l-1)}$) are mathematically and empirically indispensable (Theorem 3.1); omitting them causes Macro-F1 to collapse by $> 52\%$ ($0.9986 \rightarrow 0.4768$, $p < 10^{-5}$).

3. **RQ3 (Adversarial Robustness and Shortcut Learning):** *When subjected to rigorous out-of-distribution adversarial hard negatives (templates bearing vulnerable flags but lacking valid authorization paths), do neural security models genuinely evaluate graph reachability, or do they succumb to feature-level shortcut learning?*

Answer: Pure neural models succumb to shortcut learning. When evaluated on adversarial zero-shot hard negatives, CertGraph's accuracy collapsed to **1.59**% (1/63) because gradient descent prioritized local template configuration flags over multi-hop reachability conjunctions during training. In contrast, deterministic symbolic graph traversal achieved **84.13**% (53/63), demonstrating that pure neural models cannot guarantee reachability verification under distribution shifts.

4. **RQ4 (Optimal Defense Paradigm):** *Given the trade-offs between inductive statistical pattern recognition and deterministic symbolic graph algorithms, what is the optimal architectural paradigm for enterprise-grade autonomous identity defense, and what is the computational complexity of autonomous attack path mitigation?*

   Answer: The optimal architectural paradigm is a **Two-Tier Neuro-Symbolic Hybrid Architecture**. Fast GNN screening acts as a high-throughput filter to rank and prioritize suspicious templates ($O(|V| + |E|)$), while targeted symbolic BFS acts as a confirmatory gatekeeper to produce deterministic proofs of exploitability. Autonomous attack path mitigation is NP-hard (Theorem 9.1), proving that exact brute-force remediation is intractable and validating the necessity of polynomial-time heuristic approximations and reinforcement learning.

10.3 Practical Implementation Playbook for Enterprise Defenders

Based on the empirical, architectural, and theoretical findings of this research, we establish four actionable recommendations for enterprise Chief Information Security Officers (CISOs), identity architects, and Security Operations Center (SOC) engineers:

1. **Pillar 1: Enforce Strict Tier-0 Isolation for PKI Infrastructure:** Enterprise Certificate Authorities and published certificate templates must be categorized and defended with identical operational rigor as primary Domain Controllers. CA management interfaces (such as MS-ICPR RPC and Certification Authority MMC) must be accessible exclusively from dedicated Privileged Access Workstations (PAWs). CA administrator credentials must never be cached on Tier-1 servers or Tier-2 user workstations.

2. **Pillar 2: Mandate Security Patches KB5014754 and KB5034127:** Organizations must immediately audit their domain controllers to verify full enforcement of Microsoft's strong certificate mapping security updates. Administrators must transition from "Audit Mode" to full "Enforcement Mode," ensuring that the KDC rejects any certificate lacking the new explicit SID extension (`szOID_NTDS_CA_SECURITY_EXT`) during PKINIT authentication. Legacy Schema Version 1 templates must be retired enterprise-wide to eliminate CVE-2024-49019 (EKUwu).

3. **Pillar 3: Continuously Audit Configuration Partition Security Descriptors:** Defensive monitoring must not be confined to Domain Controllers. Active Directory monitoring agents must continuously evaluate the Discretionary Access Control Lists of LDAP objects residing within the Configuration container (`CN=Public Key Services, CN=Services, CN=Configuration, DC=domain, DC=local`). Any unprivileged principal holding `GenericWrite`, `WriteDacl`, or `WriteOwner` permissions over templates or CA objects must trigger critical severity security alerts.

4. **Pillar 4: Integrate Neuro-Symbolic Verification in Vulnerability Tooling:** Commercial security vendors and internal SOC engineering teams must abandon single-paradigm architectures. Vulnerability management platforms should deploy fast GNN embeddings to prioritize high-risk assets across multi-forest directories and invoke targeted symbolic graph search to produce deterministic proofs before triggering analyst paging.

10.4 Honest Limitations to Acknowledge

In strict adherence to scientific rigor and academic integrity, we explicitly acknowledge four operational limitations of this research:

1. **Synthetic Generator Assumptions:** While our sanitized generator adheres faithfully to documented Active Directory mechanics and transfers robustly to ADSynth tiered environments, it cannot capture the full, unpredictable diversity of misconfiguration chains present in real-world multi-decade corporate forests with legacy software dependencies.

2. **Single-Label Target Formulation:** Our experimental classification benchmarks evaluated environments where each target template is assigned a primary mutually exclusive ESC class. In production networks, templates can exhibit multi-label vulnerability co-occurrence (e.g., simultaneous ESC1 enrollee supplies subject and ESC4 DACL hijacking).

3. **Absence of Production Enterprise Ground Truth:** Due to legal, privacy, and commercial confidentiality constraints, training machine learning models on un-sanitized Fortune 500 corporate directory exports remains impossible without formal enterprise nondisclosure agreements.

4. **Scale Boundaries on Monolithic Graphs:** While our scalability benchmarks confirmed near-linear runtime scaling up to 10,000 nodes, global multi-national directory trees regularly exceed 200,000 nodes and millions of authorization edges, requiring distributed graph processing engines (such as PyG GraphStore) to partition graphs across multi-GPU compute nodes.

10.5 Ethical Considerations and Dual-Use Analysis

The methodologies, graph representations, and algorithms developed in this thesis are inherently dual-use: an adversary possessing a trained CertGraph model could potentially locate subtle ADCS escalation vectors during internal network reconnaissance.

However, offensive tooling (such as Certipy, BloodHound, and PSPKIAudit) already provides threat actors with automated privilege escalation discovery. In contrast, enterprise defenders have long lacked tools capable of sub-second prioritization, contextual risk ranking, and autonomous attack path severing. By introducing a machine-learning-driven auditing framework, open-sourcing a sanitized benchmark dataset, and formally analyzing the limits of neural security models, this research directly empowers defensive teams, enterprise architects, and autonomous security response systems.

10.6 Future Research Horizons

The findings of this thesis open several promising avenues for future scientific inquiry:

1. **Continuous-Time Dynamic Graph Neural Networks (TGNNs):** Extending CertGraph to temporal dynamic graphs that process streaming Windows Security Event Logs (Event IDs 4768, 4769, 4886, 4887) to detect live, active lateral movement in real time.

2. **Multi-Label and Multi-Vector ADCS Modeling:** Expanding the classification head to predict overlapping co-occurring escalation vectors using multi-label Binary Cross-Entropy loss.

3. **Foundation Models and LLMs for Security Graph Reasoning:** Investigating the integration of Graph Neural Networks with Large Language Models (LLMs) to automatically translate symbolic attack path traces into human-readable executive summaries and remediation scripts.

4. **Multi-Cloud Hybrid Identity Fabrics:** Extending the heterogeneous multigraph schema to model hybrid federation relationships between on-premises Active Directory and cloud identity providers (such as Microsoft Entra ID and Okta).

5. **Differential Privacy for Cross-Organizational Threat Sharing:** Applying edge-differential privacy mechanisms to enable enterprises to pool and train collective GNN security models without leaking sensitive internal user identities or corporate group structures.

6. **Reinforcement Learning in Live Cyber Ranges:** Deploying the Stackelberg autonomous defense framework within live virtualized Active Directory forests to evaluate automated PowerShell edge-severing via agentic orchestration.

10.7 Concluding Remarks

Active Directory Certificate Services represents one of the most consequential, complex battlegrounds in modern enterprise cybersecurity. By demonstrating both the remarkable power and the acute vulnerabilities of Graph Neural Networks in this domain, this thesis bridges the divide between theoretical computer science and applied systems security.

The future of enterprise identity defense belongs not to pure deep learning, nor to brittle hand-crafted rules, but to principled **Neuro-Symbolic Systems** capable of learning from graph topology while providing mathematical guarantees of security.

Appendix A

Formal Mathematical Proofs

A.1 Proof of Theorem 1: Intrinsic Attribute Preservation and Non-Vanishing Gradient Bounds in Heterogeneous Graph Neural Networks

Theorem A.1 (Intrinsic Attribute Preservation and Gradient Lower Bounds)**.** Let $G = (V, E, \mathcal{T}_V, \mathcal{T}_E)$ be a directed heterogeneous multigraph with node type mapping $\tau : V \to \mathcal{T}_V$. Let each node $v \in V$ have an initial feature vector $x_v = h_v^{(0)} \in \mathbb{R}^{d_0}$. Consider an L-layer heterogeneous message-passing neural network where layer $l \in \{1, \ldots, L\}$ computes hidden representations:

1. **Intrinsic Feature Erasure in Relational Neighborhood Aggregation:** Under pure relational neighborhood aggregation without self-loops or skip connections:

$$h_v^{(l)} = \sigma\left(\sum_{r \in \mathcal{R}_{\text{in}}(\tau(v))} \bigoplus_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(l)} W_r^{(l)} h_u^{(l-1)}\right) \tag{A.1}$$

   where $\mathcal{N}_r(v) = \{u \in V \mid (u, r, v) \in E\}$ denotes incoming neighbors under relation r, the layer-1 hidden state $h_v^{(1)}$ is conditionally independent of x_v given $\mathcal{N}(v)$. Consequently:

$$\frac{\partial h_v^{(1)}}{\partial x_v} = \mathbf{0} \in \mathbb{R}^{d_1 \times d_0} \tag{A.2}$$

   Moreover, for any source-only node v satisfying $\mathcal{N}_{\text{in}}(v) = \emptyset$, $h_v^{(l)} = \mathbf{0}$ for all $l \geq 1$.

2. **Guaranteed Gradient Lower Bound via Parameterized Residual Skips:** When parameterized residual skip connections are introduced:

$$\tilde{h}_v^{(l)} = h_v^{(l)} + W_{\text{skip}}^{(l)} \tilde{h}_v^{(l-1)} \tag{A.3}$$

   where $W_{\text{skip}}^{(l)} \in \mathbb{R}^{d_l \times d_{l-1}}$ has minimum singular value $\sigma_{\min}(W_{\text{skip}}^{(l)}) > 0$, the Jacobian of the representation with respect to the initial input features satisfies:

$$\sigma_{\min}\left(\frac{\partial \tilde{h}_v^{(L)}}{\partial x_v}\right) \geq \prod_{k=1}^{L} \sigma_{\min}(W_{\text{skip}}^{(k)}) - \|\mathcal{J}_{\text{graph}}(v)\| \tag{A.4}$$

where $\|\mathcal{J}_{\text{graph}}(v)\| \leq L_\sigma^L \alpha_{\max} \prod_{l=1}^{L} \|W^{(l)}\|$ bounds the cyclical feedback gradient. When G contains no self-directed cycles of length $\leq L$ involving v, $\mathcal{J}_{\text{graph}}(v) = \mathbf{0}$, yielding the exact lower bound $\prod_{k=1}^{L} \sigma_{\min}(W_{\text{skip}}^{(k)}) > 0$. Under the spectral condition $\prod_{k=1}^{L} \sigma_{\min}(W_{\text{skip}}^{(k)}) > \|\mathcal{J}_{\text{graph}}(v)\|$, input feature sensitivity is strictly preserved:

$$\left\| \frac{\partial \tilde{h}_v^{(L)}}{\partial x_v} \right\| \geq \prod_{k=1}^{L} \sigma_{\min}(W_{\text{skip}}^{(k)}) - \|\mathcal{J}_{\text{graph}}(v)\| > 0 \tag{A.5}$$

guaranteeing that input feature sensitivity does not vanish across message-passing layers.

Proof. We establish the proof in three parts: intrinsic feature erasure, gradient lower bounds under residual skip connections, and the specific application to identity multigraphs.

Part 1: Intrinsic Feature Erasure under Pure Neighborhood Aggregation. Let $v \in V$ be an arbitrary node in G with initial feature vector $x_v = h_v^{(0)} \in \mathbb{R}^{d_0}$. Under the standard heterogeneous relational convolution layer:

$$h_v^{(1)} = \sigma\left(\sum_{r \in \mathcal{R}_{\text{in}}(\tau(v))} \bigoplus_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(1)} W_r^{(1)} h_u^{(0)} \right) \tag{A.6}$$

Observe that the argument of $\sigma(\cdot)$ is a linear combination of neighbor states $\{h_u^{(0)} \mid u \in \mathcal{N}_r(v), r \in \mathcal{R}_{\text{in}}(\tau(v))\}$. In an access control multigraph lacking explicit self-loop relations on template nodes:

$$v \notin \mathcal{N}_r(v), \quad \forall r \in \mathcal{R}_{\text{in}}(\tau(v)) \tag{A.7}$$

Differentiating $h_v^{(1)}$ with respect to $x_v = h_v^{(0)}$:

$$\frac{\partial h_v^{(1)}}{\partial x_v} = \sigma'(\cdot) \cdot \sum_{r \in \mathcal{R}_{\text{in}}(\tau(v))} \sum_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(1)} W_r^{(1)} \frac{\partial h_u^{(0)}}{\partial h_v^{(0)}} \tag{A.8}$$

Because distinct nodes have disjoint representations ($\partial h_u^{(0)} / \partial h_v^{(0)} = \mathbf{0}$ for all $u \neq v$), every term in the summation evaluates to zero:

$$\frac{\partial h_v^{(1)}}{\partial x_v} = \mathbf{0} \in \mathbb{R}^{d_1 \times d_0} \tag{A.9}$$

Thus, at layer 1, the node's updated embedding $h_v^{(1)}$ is completely independent of its initial feature vector x_v. In certificate templates ($t \in V_{\text{Template}}$), this means that the 10 binary configuration flags x_{Template} (which govern whether the template allows enrollee-supplied SANs, requires manager approval, or specifies client authentication EKUs) are completely

discarded from $h_t^{(1)}$.

Furthermore, if v is a source-only entity satisfying $d_{\text{in}}(v) = 0$ (such as user accounts possessing outgoing enrollment rights but no incoming delegations), then $\mathcal{N}_r(v) = \emptyset$ for all r. By the identity of aggregation over an empty set ($\bigoplus(\emptyset) = \mathbf{0}$) and $\sigma(\mathbf{0}) = \mathbf{0}$, we obtain $h_v^{(l)} = \mathbf{0}$ for all $l \geq 1$.

Part 2: Gradient Lower Bounds via Parameterized Residual Skips. Now consider the layer formulation equipped with parameterized additive residual skip connections:

$$\tilde{h}_v^{(l)} = h_v^{(l)} + W_{\text{skip}}^{(l)} \tilde{h}_v^{(l-1)} \tag{A.10}$$

where $\tilde{h}_v^{(0)} = x_v$ and $W_{\text{skip}}^{(l)} \in \mathbb{R}^{d_l \times d_{l-1}}$. Unrolling the recurrence from layer L to layer 0:

$$\tilde{h}_v^{(L)} = \left(\prod_{k=1}^{L} W_{\text{skip}}^{(k)} \right) x_v + \sum_{l=1}^{L} \left(\prod_{k=l+1}^{L} W_{\text{skip}}^{(k)} \right) h_v^{(l)} \tag{A.11}$$

where by convention $\prod_{k=L+1}^{L} W_{\text{skip}}^{(k)} = I_{d_L}$.

Taking the Jacobian of $\tilde{h}_v^{(L)}$ with respect to x_v:

$$\frac{\partial \tilde{h}_v^{(L)}}{\partial x_v} = \prod_{k=1}^{L} W_{\text{skip}}^{(k)} + \mathcal{J}_{\text{graph}}(v) \tag{A.12}$$

where $\mathcal{J}_{\text{graph}}(v) = \sum_{l=1}^{L} \left(\prod_{k=l+1}^{L} W_{\text{skip}}^{(k)} \right) \frac{\partial h_v^{(l)}}{\partial x_v}$ represents the indirect gradient flowing through cyclical graph paths (e.g., $v \to u \to v$).

By Weyl's perturbation inequality for singular values (Horn & Johnson, 2012):

$$\sigma_{\min}\left(\frac{\partial \tilde{h}_v^{(L)}}{\partial x_v} \right) \geq \sigma_{\min}\left(\prod_{k=1}^{L} W_{\text{skip}}^{(k)} \right) - \|\mathcal{J}_{\text{graph}}(v)\| \tag{A.13}$$

Applying the sub-multiplicative property of singular values:

$$\sigma_{\min}\left(\prod_{k=1}^{L} W_{\text{skip}}^{(k)} \right) \geq \prod_{k=1}^{L} \sigma_{\min}(W_{\text{skip}}^{(k)}) \tag{A.14}$$

Now, we explicitly bound the operator norm $\|\mathcal{J}_{\text{graph}}(v)\|$. At layer 1, since there are no self-loops ($v \notin \mathcal{N}(v)$), $\frac{\partial h_v^{(1)}}{\partial x_v} = \mathbf{0}$. For $L = 2$, applying the chain rule to the second

aggregation layer yields:

$$\frac{\partial h_v^{(2)}}{\partial x_v} = \sum_{r \in \mathcal{R}_{\text{in}}} \sum_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(2)} \sigma' \left(z_v^{(2)} \right) W_r^{(2)} \frac{\partial \tilde{h}_u^{(1)}}{\partial x_v} \tag{A.15}$$

Expanding $\frac{\partial \tilde{h}_u^{(1)}}{\partial x_v} = \frac{\partial h_u^{(1)}}{\partial x_v} + W_{\text{skip}}^{(1)} \frac{\partial x_u}{\partial x_v}$: since $u \neq v$, $\frac{\partial x_u}{\partial x_v} = \mathbf{0}$, and $\frac{\partial h_u^{(1)}}{\partial x_v} = \sum_{r' \in \mathcal{R}_{\text{in}}} \sum_{w \in \mathcal{N}_{r'}(u)} \alpha_{uw}^{(1)} \sigma' \left(z_u^{(1)} \right) W_{r'}^{(1)} \frac{\partial x_w}{\partial x_v}$. The term $\frac{\partial x_w}{\partial x_v}$ is non-zero (I_{d_0}) if and only if $w = v$, corresponding to a 2-hop directed cycle $v \to u \to v$.

We therefore distinguish two topological regimes:

1. **Acyclic Receptive Field ($\nexists$2-cycle $v \rightsquigarrow u \rightsquigarrow v$):** In standard Active Directory permission DAGs (where user accounts possess forward enrollment rights into templates, but certificate templates do not hold outgoing access-control rights over users), no 2-hop cycles terminate back at v. Consequently, $\frac{\partial h_u^{(1)}}{\partial x_v} = \mathbf{0}$ for all $u \in \mathcal{N}(v)$, establishing:

$$\mathcal{J}_{\text{graph}}(v) = \mathbf{0} \implies \left\| \frac{\partial \tilde{h}_v^{(L)}}{\partial x_v} \right\| \geq \prod_{k=1}^{L} \sigma_{\min}(W_{\text{skip}}^{(k)}) > 0 \tag{A.16}$$

   The lower bound holds with exact equality.

2. **Cyclical Graphs ($\exists$2-cycle $v \to u \to v$):** By the sub-multiplicativity of induced operator norms and the Lipschitz continuity of the activation function ($\|\sigma'\| \leq L_\sigma = 1$ for ELU/ReLU):

$$\|\mathcal{J}_{\text{graph}}(v)\| \leq L_\sigma^2 \sum_{u \in \mathcal{N}(v)} \alpha_{vu}^{(2)} \alpha_{uv}^{(1)} \|W^{(2)}\| \|W^{(1)}\| \tag{A.17}$$

$$\leq L_\sigma^2 \left(\max_{u \in \mathcal{N}(v)} \alpha_{uv}^{(1)} \right) \|W^{(2)}\| \|W^{(1)}\| \sum_{u \in \mathcal{N}(v)} \alpha_{vu}^{(2)} \tag{A.18}$$

$$= \alpha_{\max}^{(1)} \|W^{(2)}\| \|W^{(1)}\| \tag{A.19}$$

   where $\alpha_{\max}^{(1)} = \max_{u \in \mathcal{N}(v)} \alpha_{uv}^{(1)} \leq 1$. Under standard spectral scaling or weight regularization where the skip connection singular values satisfy $\prod_{k=1}^{L} \sigma_{\min}(W_{\text{skip}}^{(k)}) > \alpha_{\max}^{(1)} \prod_{l=1}^{L} \|W^{(l)}\|$, we strictly establish:

$$\left\| \frac{\partial \tilde{h}_v^{(L)}}{\partial x_v} \right\| \geq \sigma_{\min} \left(\frac{\partial \tilde{h}_v^{(L)}}{\partial x_v} \right) \geq \prod_{k=1}^{L} \sigma_{\min}(W_{\text{skip}}^{(k)}) - \|\mathcal{J}_{\text{graph}}(v)\| > 0 \tag{A.20}$$

Part 3: Implication for Active Directory Certificate Template Classification. In Active Directory Certificate Services, certificate template classification is a joint decision requiring both:

1. Intrinsic configuration flags $x_t \in \mathbb{R}^{10}$ (e.g., whether `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` and Client Authentication EKUs are enabled).

2. Topological reachability from unprivileged principals ($\exists u \in V_{\text{low-priv}} \rightsquigarrow t$).

Without residual skip connections ($W_{\text{skip}} = 0$), $h_t^{(1)}$ completely erases x_t. While x_t can theoretically influence $h_t^{(2)}$ through 2-hop cycles ($t \to u \to t$), this signal is severely diluted by attention normalization across all adjacent principals and relations. Consequently, the network loses direct access to the template's configuration flags, explaining the empirical collapse from Macro-F1 = 0.9986 to 0.4768 observed in Section 5.3. Parameterized residual skip connections guarantee that the 10 binary flags are directly retained in the final node embedding, preserving classification efficacy. □

Corollary A.1 (Necessity in Active Directory Identity Graphs)**.** In enterprise identity graphs, where certificate templates rely heavily on intrinsic configuration attributes and user principals frequently act as low in-degree sources in administrative authorization subgraphs, parameterized residual skip connections are mathematically required to prevent feature decay and gradient vanishing across multi-hop relational convolutions.

A.2 Proof of Theorem 2: NP-Hardness of Multi-Principal Access Interdiction in Enterprise Identity Graphs

Theorem A.2 (NP-Hardness of Multi-Principal Access Interdiction)**.** Let $G = (V, E)$ be a directed multigraph representing an Active Directory domain, where V represents security principals and directory objects, and E represents directed authorization, delegation, and administrative permissions. Let $c : E \to \mathbb{R}^+$ assign operational disruption costs to edges, representing the business friction of revoking a specific privilege.

Let $\mathcal{P}_{\text{forbidden}} = \{(s_1, t_1), (s_2, t_2), \ldots, (s_k, t_k)\}$ denote a set of $k \geq 3$ forbidden source-target compromise pairs (e.g., specific unprivileged footholds and their respective target administrative assets across distinct trust or tier boundaries) that must be severed.

The **Multi-Principal Access Interdiction (MPAI)** problem asks: given an operational disruption budget $K \in \mathbb{R}^+$, does there exist an edge interdiction subset $E_{\text{cut}} \subseteq E$ such that:

1. Total operational revocation cost is bounded:

$$\sum_{e \in E_{\text{cut}}} c(e) \leq K \tag{A.21}$$

2. All forbidden directed compromise paths are severed:

$$\forall (s_i, t_i) \in \mathcal{P}_{\text{forbidden}}, \quad \text{Path}(s_i \rightsquigarrow t_i) \text{ does not exist in } G' = (V, E \setminus E_{\text{cut}}) \tag{A.22}$$

The MPAI problem is NP-complete for $k \geq 3$. Consequently, finding the optimal edge-severing defense strategy that minimizes operational disruption while neutralizing multiple independent lateral compromise paths is NP-hard.

Proof. We prove NP-completeness by establishing:

1. MPAI $\in$ NP, and
2. A polynomial-time reduction from the classical NP-complete **Directed Multiway Cut** problem [42] to MPAI:

$$\text{Directed Multiway Cut} \leq_p \text{MPAI} \tag{A.23}$$

Part 1: Membership in NP. Given a candidate edge subset $E_{\text{cut}} \subseteq E$:

1. We compute the total operational revocation cost $\sum_{e \in E_{\text{cut}}} c(e)$ in $O(|E_{\text{cut}}|)$ time and verify whether $\sum_{e \in E_{\text{cut}}} c(e) \leq K$.
2. We construct the residual graph $G' = (V, E \setminus E_{\text{cut}})$ in $O(|V| + |E|)$ time.

3. For each of the k forbidden pairs $(s_i, t_i) \in \mathcal{P}_{\text{forbidden}}$, we execute Breadth-First Search (BFS) starting from s_i in G' to verify that t_i is unreachable. This requires $O(k \cdot (|V| + |E|))$ time.

Because all verification steps complete in deterministic polynomial time with respect to the graph size, MPAI $\in$ NP.

Part 2: Polynomial-Time Reduction from Directed Multiway Cut. While the classical Multiterminal Cut problem on undirected graphs was proven NP-complete for $k \geq 3$ by Dahlhaus et al. (1994) [45] (and polynomial-time solvable for $k = 2$ via standard min-cut algorithms), enterprise identity attack graphs are directed and asymmetric. We emphasize that while finding an edge cut severing all paths from a single source to a single target is polynomial-time solvable via standard (S, T) min-cut, and prior Active Directory interdiction literature (Guo et al., 2022, 2023) [16, 26] established the W[1]-hardness of single-target *shortest-path* interdiction, Theorem 9.1 proves that complete reachability interdiction across multiple forbidden terminal pairs is NP-hard. We base our reduction on the **Directed Multiway Cut** problem, which was proven NP-complete even for $k \geq 2$ by Garg, Vazirani, and Yannakakis (1994) [42]:

> **Directed Multiway Cut:** Given a directed graph $H = (V_H, E_H)$ with positive edge weights $w : E_H \to \mathbb{R}^+$, a subset of $k \geq 3$ distinct terminal vertices $X = \{x_1, x_2, \ldots, x_k\} \subseteq V_H$, and a cost threshold W, does there exist an edge subset $C \subseteq E_H$ with $\sum_{e \in C} w(e) \leq W$ such that no directed path connects any terminal x_i to any other terminal x_j $(i \neq j)$ in the residual graph $H' = (V_H, E_H \setminus C)$?

Given an arbitrary instance $\langle H = (V_H, E_H), w, X = \{x_1, \ldots, x_k\}, W \rangle$ of the Directed Multiway Cut problem ($k \geq 3$), we construct an instance $\langle G = (V, E), c, \mathcal{P}_{\text{forbidden}}, K \rangle$ of MPAI in polynomial time:

1. **Vertex Construction:** For each terminal $x_i \in X$, create two distinct nodes in G: an attacker source principal s_i and a high-value target asset t_i. For all non-terminal vertices $v \in V_H \setminus X$, include $v \in V$. Thus:

$$V = (V_H \setminus X) \cup \{s_1, \ldots, s_k\} \cup \{t_1, \ldots, t_k\} \tag{A.24}$$

2. **Edge and Cost Construction:**

   (a) For every original edge $(u, v) \in E_H$:

      i. If $u \notin X$ and $v \notin X$, add $(u, v) \in E$ with cost $c(u, v) = w(u, v)$.

      ii. If $u = x_i \in X$ and $v \notin X$, add $(s_i, v) \in E$ with cost $c(s_i, v) = w(x_i, v)$.

      iii. If $u \notin X$ and $v = x_j \in X$, add $(u, t_j) \in E$ with cost $c(u, t_j) = w(u, x_j)$.

iv. If $u = x_i \in X$ and $v = x_j \in X$ $(i \neq j)$, add $(s_i, t_j) \in E$ with cost $c(s_i, t_j) = w(x_i, x_j)$.

(b) For each terminal index $i \in \{1, \ldots, k\}$, add a directed continuation edge (t_i, s_i) with infinite capacity $c(t_i, s_i) = \infty$ (or $W + 1$). This enforces that reaching target t_i allows traversing any path leaving source s_i, preserving the full reachability topology of vertex x_i in H.

3. **Forbidden Pair Definition:** Set the forbidden compromise pair set to all distinct terminal combinations:

$$\mathcal{P}_{\text{forbidden}} = \{(s_i, t_j) \mid 1 \leq i, j \leq k,\ i \neq j\} \tag{A.25}$$

Here $|\mathcal{P}_{\text{forbidden}}| = k(k-1) \geq 6$ for $k \geq 3$.

4. **Disruption Budget:** Set $K = W$.

The reduction generates $|V| = |V_H| + k$ vertices and $|E| = |E_H| + k$ edges, requiring $O(|V_H| + |E_H|)$ time.

Equivalence of Solutions:

1. $(\Rightarrow)$ Suppose there exists a valid Directed Multiway Cut $C \subseteq E_H$ in H with $\sum_{e \in C} w(e) \leq W$ that disconnects all pairs $x_i \rightsquigarrow x_j$ for $i \neq j$. Let $E_{\text{cut}} \subseteq E$ be the identical set of edges in G. Since C contains no infinite-cost edges, $\sum_{e \in E_{\text{cut}}} c(e) = \sum_{e \in C} w(e) \leq W = K$. Furthermore, because no path connects x_i to x_j in $H \setminus C$, no path can connect s_i to t_j in $G \setminus E_{\text{cut}}$. Hence, all pairs in $\mathcal{P}_{\text{forbidden}}$ are severed.

2. $(\Leftarrow)$ Conversely, suppose there exists an edge cut $E_{\text{cut}} \subseteq E$ in G with cost $\sum_{e \in E_{\text{cut}}} c(e) \leq K = W$ severing all paths for every pair $(s_i, t_j) \in \mathcal{P}_{\text{forbidden}}$ $(i \neq j)$. Because $K < \infty$, E_{cut} cannot contain any infinite-capacity continuation edge (t_i, s_i). Thus, E_{cut} corresponds directly to a valid edge subset $C \subseteq E_H$ in H. If there existed a directed path from x_i to x_j $(i \neq j)$ in $H \setminus C$, the identical sequence of edges would form a directed path from s_i to t_j in $G \setminus E_{\text{cut}}$, contradicting the assumption that (s_i, t_j) is severed. Therefore, C separates all terminal pairs in H with cost $\leq W$.

This establishes that MPAI is NP-complete for $k \geq 3$. The optimization problem of finding the minimal-disruption edge-severing set is therefore NP-hard. □

Bibliography

[1] W. Schroeder and L. Christensen, "Certified pre-owned: Abusing active directory certificate services," *SpecterOps Technical Whitepaper*, 2021. [Online]. Available: https://posts.specterops.io/certified-pre-owned-d95910965cd2

[2] L. Zhu and B. Tung, "Public key cryptography for initial authentication in kerberos (PKINIT)," IETF, RFC 4556, June 2006. [Online]. Available: https://www.rfc-editor.org/rfc/rfc4556

[3] J. B. Knudsen, "ADCS ESC13: Abuse of certificate templates with issuance policies," Compass Security / SpecterOps Blog, https://posts.specterops.io/adcs-esc13-abuse-of-certificate-templates-with-issuance-policies-53457a4e613b, February 2024.

[4] J. Bollinger, "EKUwu: Not just another AD CS ESC," TrustedSec Blog, https://trustedsec.com/blog/ekuwu-not-just-another-ad-cs-esc, October 2024, patched by Microsoft as CVE-2024-49019, Nov 12, 2024.

[5] O. Lyak, "Certipy: Active directory certificate services enumeration and abuse tool," GitHub repository, https://github.com/ly4k/Certipy, 2021, technical releases v2.0–v4.8.2 (2021–2024).

[6] A. Robbins, W. Schroeder, and R. Vazarkar, "Six degrees of domain admin: Using graph theory to accelerate popular attacks in active directory," in *BSides Las Vegas and DEF CON 24*, 2016. [Online]. Available: https://github.com/BloodHoundAD/BloodHound

[7] F. Bleeker, "PSPKIAudit: Powershell script to audit active directory certificate services (ADCS)," GitHub repository, https://github.com/GhostPack/PSPKIAudit, 2021.

[8] J. Gilmer, S. S. Schoenholz, P. F. Riley, O. Vinyals, and G. E. Dahl, "Neural message passing for quantum chemistry," in *International Conference on Machine Learning (ICML)*, 2017, pp. 1263–1272.

[9] R. Geirhos, J.-H. Jacobsen, C. Michaelis, R. Zemel, W. Brendel, M. Bethge, and F. A. Wichmann, "Shortcut learning in deep neural networks," *Nature Machine Intelligence*, vol. 2, no. 11, pp. 665–673, 2020.

[10] D. Arp, E. Quiring, C. Wressnegger, F. Pierazzi, L. Cavallaro, and K. Rieck, "Dos and don'ts of machine learning in computer security," in *31st USENIX Security Symposium (USENIX Security 22)*, 2022, pp. 3971–3988.

[11] C. A. Phillips and L. P. Swiler, "A graph-based system for network-vulnerability analysis," in *Proceedings of the 1998 Workshop on New Security Paradigms (NSPW)*, 1998, pp. 71–79.

[12] O. Sheyner, J. Haines, S. Jha, R. Lippmann, and J. M. Wing, "Automated generation and analysis of attack graphs," in *IEEE Symposium on Security and Privacy (S&P)*, 2002, pp. 273–284.

[13] X. Ou, S. Govindavajhala, and A. W. Appel, "MulVAL: A logic-based network security analyzer," in *14th USENIX Security Symposium (USENIX Security 05)*, 2005, pp. 113–128.

[14] D. Goel, H. Ahmad, K. Moore, and M. Guo, "Co-evolutionary defence of active directory attack graphs via GNN-approximated dynamic programming," *arXiv preprint arXiv:2505.11710*, 2025.

[15] I. J. King and H. H. Huang, "Euler: Detecting network lateral movement via scalable temporal link prediction," *ACM Transactions on Privacy and Security*, vol. 26, no. 3, pp. 32:1–32:36, 2023.

[16] M. Guo, J. Li, A. Neumann, F. Neumann, and H. Nguyen, "Practical fixed-parameter algorithms for defending active directory style attack graphs," in *Proceedings of the AAAI Conference on Artificial Intelligence*, vol. 36, no. 9, 2022, pp. 9360–9367.

[17] J. Zhou, J. Yao, X. Chen, S. Yu, Q. Xuan, and X. Yang, "Lateral movement detection via time-aware subgraph classification on authentication logs," *arXiv preprint arXiv:2411.10279*, 2024.

[18] T. N. Kipf and M. Welling, "Semi-supervised classification with graph convolutional networks," in *International Conference on Learning Representations (ICLR)*, 2017.

[19] W. L. Hamilton, R. Ying, and J. Leskovec, "Inductive representation learning on large graphs," in *Advances in Neural Information Processing Systems (NeurIPS)*, 2017, pp. 1024–1034.

[20] P. Veličković, G. Cucurull, A. Casanova, A. Romero, P. Liò, and Y. Bengio, "Graph attention networks," in *International Conference on Learning Representations (ICLR)*, 2018.

[21] M. Schlichtkrull, T. N. Kipf, P. Bloem, R. van den Berg, I. Titov, and M. Welling, "Modeling relational data with graph convolutional networks," in *The Semantic Web (ESWC)*, 2018, pp. 593–607.

[22] X. Wang, H. Ji, C. Shi, B. Wang, Y. Ye, P. Cui, and P. S. Yu, "Heterogeneous graph attention network," in *The World Wide Web Conference (WWW)*, 2019, pp. 2022–2032.

[23] Z. Hu, Y. Dong, K. Wang, and Y. Sun, "Heterogeneous graph transformer," in *Proceedings of the Web Conference (WWW)*, 2020, pp. 2704–2710.

[24] S. Günnemann, "Graph neural networks: Adversarial robustness," in *Graph Neural Networks: Foundations, Frontiers, and Applications*, L. Wu, P. Cui, J. Pei, and L. Zhao, Eds. Springer Nature Singapore, 2022, pp. 149–176.

[25] C. Kiekintveld, M. Jain, J. Tsai, J. Pita, F. Ordóñez, and M. Tambe, "Computing optimal randomized resource allocations for massive security games," in *Proceedings of the 8th International Conference on Autonomous Agents and Multiagent Systems (AAMAS)*, 2009, pp. 389–396.

[26] M. Guo, M. Ward, A. Neumann, F. Neumann, and H. Nguyen, "Scalable edge blocking algorithms for defending active directory style attack graphs," in *Proceedings of the AAAI Conference on Artificial Intelligence*, vol. 37, no. 5, 2023, pp. 5649–5656.

[27] Y. Zhang, M. Ward, M. Guo, and H. Nguyen, "A scalable double oracle algorithm for hardening large active directory systems," in *Proceedings of the 2023 ACM Asia Conference on Computer and Communications Security*, ser. ASIA CCS '23. New York, NY, USA: Association for Computing Machinery, 2023, pp. 993–1003.

[28] D. Goel, K. Moore, M. Guo, D. Wang, M. Kim, and S. Camtepe, "Optimizing cyber defense in dynamic active directories through reinforcement learning," in *Computer Security – ESORICS 2024*, ser. Lecture Notes in Computer Science, vol. 14983. Springer, Cham, 2024, pp. 3–23.

[29] D. Goel, M. Ward, A. Neumann, F. Neumann, H. Nguyen, and M. Guo, "Hardening active directory graphs via evolutionary diversity optimization-based policies," *ACM Transactions on Evolutionary Learning and Optimization*, vol. 5, no. 3, pp. 1–36, 2024.

[30] H. Q. Ngo, "Practical graph optimisation and AI-driven models for active directory security hardening," Ph.D. dissertation, School of Computer and Mathematical Sciences, The University of Adelaide, 2026, dean's Commendation for Doctoral Thesis Excellence.

[31] R. Sommer and V. Paxson, "Outside the closed world: On using machine learning for network intrusion detection," in *IEEE Symposium on Security and Privacy (S&P)*, 2010, pp. 305–316.

[32] F. Pendlebury, F. Pierazzi, R. Jordaney, J. Kinder, and L. Cavallaro, "TESSERACT: Eliminating experimental bias in malware classification across space and time," in *28th USENIX Security Symposium (USENIX Security 19)*, 2019, pp. 729–746.

[33] M. Chen, Z. Wei, Z. Huang, B. Ding, and Y. Li, "Simple and deep graph convolutional networks," in *International Conference on Machine Learning (ICML)*, 2020, pp. 1725–1735.

[34] W. Ye, L. Jiang, E. Xie, G. Zheng, Y. Ma, X. Cao, D. Guo, D. Qi, Z. He, Y. Tian, C. W. Porter, M. Coffee, Z. Zeng, S. Li, Z. Wang, T.-H. K. Huang, J. M. Rehg, H. Kautz, and A. Zhang, "The clever hans mirage: A comprehensive survey on spurious correlations in machine learning," *Transactions on Machine Learning Research*, 2026. [Online]. Available: https://openreview.net/forum?id=v39G5R7k2x

[35] S. J. Bell and S. Wang, "The pragmatic frames of spurious correlations in machine learning: Interpreting how and why they matter," *arXiv preprint arXiv:2411.04696*, 2024.

[36] C. Nadeau and Y. Bengio, "Inference for the generalization error," *Machine Learning*, vol. 52, no. 3, pp. 239–281, 2003.

[37] Mayfly (Orange Cyberdefense), "Game of active directory (GOAD): A vulnerable active directory lab environment," GitHub repository, https://github.com/Orange-Cyberdefense/GOAD, 2021.

[38] T. Nguyen, N. Falkner, and C. Nguyen, "Synthesizing realistic active directory attack graphs," in *54th Annual IEEE/IFIP International Conference on Dependable Systems and Networks (DSN)*, 2024, pp. 66–74.

[39] T. Wu, C. Cui, X. Xian, S. Qiao, C. Wang, L. Yuan, and S. Yu, "Understanding the robustness of graph neural networks against adversarial attacks," *Knowledge-Based Systems*, vol. 313, p. 113714, 2025.

[40] H. Q. Ngo, M. Guo, and H. Nguyen, "Near optimal strategies for honeypots placement in dynamic and large active directory networks," in *Proceedings of the 2023 International Conference on Autonomous Agents and Multiagent Systems*, ser. AAMAS '23. Richland, SC: International Foundation for Autonomous Agents and Multiagent Systems, 2023, pp. 2517–2519.

[41] H. Q. Ngo, M. Guo, and H. X. Nguyen, "Optimizing cyber response time on temporal active directory networks using decoys," in *Proceedings of the Genetic and Evolutionary Computation Conference*, ser. GECCO '24. New York, NY, USA: Association for Computing Machinery, 2024, pp. 1309–1317.

[42] N. Garg, V. V. Vazirani, and M. Yannakakis, "Multiway cuts in directed and node weighted graphs," in *International Colloquium on Automata, Languages, and Programming (ICALP)*, ser. Lecture Notes in Computer Science, vol. 820. Springer, 1994, pp. 487–498.

[43] M. Ward, "Algorithms to prevent attacks in active directory environments," 2021.

[44] V. S. Borkar, "Stochastic approximation: A dynamical systems viewpoint," *Cambridge University Press*, 2008.

[45] E. Dahlhaus, D. S. Johnson, C. H. Papadimitriou, P. D. Seymour, and M. Yannakakis, "The complexity of multiterminal cuts," *SIAM Journal on Computing*, vol. 23, no. 4, pp. 864–894, 1994.